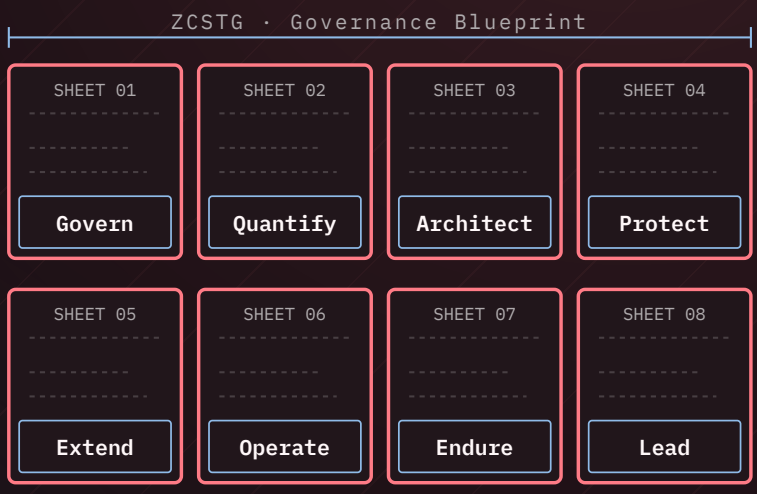
ZCSTG

ZyeemZia™ Cyber Security – Technology and Governance

Secure the technology. Govern the risk.



COURSE BOOK · WORKBOOK · EXAM PREPARATION

8 MODULES · 38 LESSONS · 60 EXAM QUESTIONS

COPYRIGHT © ZYEEMZIA

BEFORE YOU BEGIN

How to use this book

An expert track for security leaders and architects that joins security technology with governance: frameworks, cyber-risk quantification, zero-trust and cloud architecture, OT and identity security, data protection, supply-chain risk, security operations metrics, resilience, regulation and audit, and leading a security programme in front of the board.

01
Learn
Work through 38 lessons. Each ends with a knowledge check.

02
Practise
Fill in the templates, answer the scenarios and case studies, review the glossary.

03
Certify
Take the 45-question official exam at zcstg.zyeemzia.com, graded on the ZyeemZia server. Pass mark 85%.

04
Get certified
Download your certificate online. Anyone can verify its credential ID at zcstg.zyeemzia.com/#verify. 92%+ and the capstone earn Distinction.

Eight-week study plan

WHEN	MODULE	DO THIS	DONE
Month 1	m1 Govern	Decision rights, CSF profile and policy architecture	☐
Month 2	m2 Quantify	Risk scenarios, FAIR-style estimates, simulation	☐
Month 3	m3 Architect	Zero-trust, cloud guardrails and OT zoning	☐
Month 4	m4 Protect	Identity governance, data classification, DPIA	☐
Month 5	m5 Extend	Supplier tiering and software supply chain	☐
Month 6	m6 Operate	SOC model, vulnerability programme and metrics	☐
Month 7	m7 Endure	BIA, recovery testing and crisis exercise	☐
Month 8	m8 Lead	Regulation, audit, board pack, capstone and exam	☐

Learner name .....

Start date ..... Target exam date .....

ZCSTG is an independent certification programme created and issued by ZyeemZia. It is not affiliated with, endorsed by, sponsored by or equivalent to any certification, standard or framework from ISACA (including CISM®, CISA®, CGEIT® and COBIT®), ISC2 (including CISSP®), the International Organization for Standardization (ISO) or the International Electrotechnical Commission (IEC), the US National Institute of Standards and Technology (NIST), the Center for Internet Security (CIS), The Open Group (FAIR) or any other certifying, standards or

Copyright © ZyeemZia

government body. Frameworks, standards and laws are summarised in our own words for learning only; always consult the official current texts. Nothing in this track is legal advice. All names and trademarks belong to their respective owners.

Copyright © ZyeemZia

CONTENTS

What you will learn

01 Govern — Security Governance and Frameworks

1. Security Governance, Accountability and the Three Lines · 30 min
2. NIST CSF 2.0: Functions, Profiles and Tiers · 35 min
3. ISO/IEC 27001:2022: Building and Certifying an ISMS · 35 min
4. CIS Controls and COBIT-Style Governance of Enterprise IT · 30 min
5. Policy Architecture, Crosswalks and the GRC Operating Model · 35 min

02 Quantify — Risk Assessment and Cyber-Risk Quantification

1. Risk Assessment Methods and the Limits of Heat Maps · 30 min
2. Risk Appetite, Tolerance and Treatment · 30 min
3. FAIR-Style Risk Decomposition · 40 min
4. Monte Carlo, Loss Exceedance and the Value of Controls · 40 min
5. Threat-Informed Risk Scenarios · 30 min

03 Architect — Security Architecture, Zero Trust, Cloud and OT

1. Security Architecture Principles and Reference Models · 30 min
2. Zero Trust: Principles, Components and Roadmap · 35 min
3. Segmentation, Secure Access and Application Security · 35 min
4. Cloud and Hybrid Security Governance · 35 min
5. OT, ICS and IoT Security · 40 min

04 Protect — Identity, Data Protection and Privacy

1. Identity Governance and Administration · 35 min
2. Privileged Access, Strong Authentication and Non-Human Identities · 35 min
3. Data Governance, Classification and Loss Prevention · 30 min
4. Cryptography and Key Management Governance · 35 min
5. Privacy Engineering and Data Protection · 35 min

05 Extend — Third-Party and Supply-Chain Risk

1. The Third-Party Risk Management Lifecycle · 35 min
2. Assessing and Monitoring Suppliers · 35 min
3. Software Supply Chain Security · 40 min
4. Cloud, SaaS and Outsourcing: Contracts, Exit and Concentration · 35 min

06 Operate — Security Operations Strategy and Metrics

1. Security Operations Operating Models · 35 min
2. Detection Engineering and Threat-Informed Defence · 35 min
3. Incident Response Governance · 40 min
4. Vulnerability and Exposure Management · 35 min
5. Security Metrics, KPIs and KRIs · 35 min

07 Endure — Resilience, Continuity and Crisis Management

1. Operational Resilience and Business Impact Analysis · 35 min
2. Continuity and Disaster Recovery Strategy · 35 min
3. Crisis Management and Communications · 35 min
4. Ransomware Resilience and Exercising · 40 min

Copyright © ZyeemZia

08 Lead — Regulation, Audit and Board Leadership

1. The Global Regulatory Landscape for Cyber and Data · 35 min
2. Bangladesh's Digital and Cyber Laws · 35 min
3. Audit and Assurance · 35 min
4. Board Reporting and Security Budgets · 35 min
5. Leading the Security Programme and the Capstone · 35 min

+ Glossary · Capstone guide · Practice exam & answers · Certificate · Notes

Copyright © ZyeemZia

THE FRAMEWORK

The ZCSTG Security Governance Blueprint

Eight blueprint sheets that make a defensible security programme: govern, quantify, architect, protect, extend, operate, endure and lead. A programme is only complete when every sheet is drawn, owned, measured and reported to the board.



01 Govern
Direct and oversee cyber risk with clear accountability, the right frameworks and a lean control library

02 Quantify
Turn cyber risk into decision-ready estimates of frequency, magnitude and value

03 Architect
Design security into enterprise, cloud and industrial environments with traceable decisions

04 Protect
Govern who can access what, and protect data and personal information throughout its life

05 Extend
Govern the suppliers, software and services that extend your attack surface

06 Operate
Run detection, response and exposure management as measurable, accountable services

07 Endure
Keep important services running through disruption and lead the organisation through crisis

08 Lead
Meet legal duties, earn assurance and lead the security programme in front of the board

Copyright © ZyeemZia

01

MODULE 1 · GOVERN

Security Governance and Frameworks

Direct and oversee cyber risk with clear accountability, the right frameworks and a lean control library

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Separate governance, management and operations and assign accountability for cyber risk
- Use NIST CSF 2.0 profiles and tiers to describe current and target security outcomes
- Explain how an ISO/IEC 27001:2022 ISMS is built, scoped and certified
- Combine CIS Controls and COBIT-style objectives with other frameworks for the right purpose
- Design a policy architecture, unified control framework and GRC operating rhythm

LESSONS

1. Security Governance, Accountability and the Three Lines · 30 min
2. NIST CSF 2.0: Functions, Profiles and Tiers · 35 min
3. ISO/IEC 27001:2022: Building and Certifying an ISMS · 35 min
4. CIS Controls and COBIT-Style Governance of Enterprise IT · 30 min
5. Policy Architecture, Crosswalks and the GRC Operating Model · 35 min

MODULE 1 · GOVERN · LESSON 1 · 30 MIN

Security Governance, Accountability and the Three Lines

Who decides, who does and who checks: the foundations of governing cyber risk

- Distinguish security governance from security management and operations
- Assign accountability for cyber risk across the board, executives and the security function
- Apply the three lines model and decide where the CISO should report

Security failures in large organisations are rarely caused by a missing tool. They are caused by unclear decisions: nobody owned the risk, nobody approved the exception, nobody told the board. **Security governance** is the system by which an organisation directs and controls security so that it supports business objectives, stays within risk appetite and meets its legal duties. **Security management** plans and runs the activities that carry out those directions. **Operations** do the daily work. Expert leaders keep the three distinct, because each needs different people, information and decision rights.

Governance, management and operations

Governance (direct and oversee)

- Sets risk appetite and priorities
- Approves strategy, policy and budget envelope
- Holds executives to account
- Asks: are we doing the right things?
- Board, risk committee, executive committee

Management (plan and run)

- Turns direction into programmes and standards
- Allocates people and money
- Reports performance and risk upward
- Asks: are we doing things right?
- CISO, CIO, business unit heads

Operations (execute)

- Runs controls day to day
- Monitors, patches, responds
- Produces evidence and metrics
- Asks: is it working right now?
- SOC, IT operations, engineering teams

DEFINITION · ACCOUNTABLE VERSUS RESPONSIBLE

Accountable means you answer for the outcome and cannot delegate that duty; there is exactly one accountable person per risk or decision. **Responsible** means you do the work. A CISO is usually responsible for designing and running the security programme, but the business owner of a payment service is accountable for accepting the cyber risk to that service.

Six questions every governance system must answer

G1
Direction
What are we protecting, why, and how much risk will we accept? Captured in strategy and risk appetite.

G2
Decision rights
Who may approve policy, accept risk, grant exceptions and spend money, and at what thresholds?

G3
Accountability
Which named owner answers for each critical service, asset class and top risk?

G4
Policy
What rules apply, and how are they kept short, current and enforceable?

G5
Oversight
How do leaders know the programme is working: metrics, assurance, audit?

G6
Adaptation
How are strategy and controls changed when threats, the business or the law change?

Copyright © ZyeemZia

The **three lines model** gives a simple shape to accountability. The **first line** (business and IT teams who own services) owns and manages risk and runs controls. The **second line** (risk management, compliance and, in many organisations, the security risk function) sets frameworks, challenges and monitors. The **third line** (internal audit) gives independent assurance to the governing body. The model works only if roles are clear and the lines cooperate rather than duplicate.

The three lines model applied to cyber risk

Governing body	`Board and its risk or audit committee` `Sets appetite, oversees, receives assurance`
Third line	`Internal audit` `Independent assurance on design and effectiveness of cyber controls`
Second line	`Enterprise and cyber risk management` `Compliance and privacy office` `Policy, challenge, monitoring, risk reporting`
First line	`Business service owners` `IT, cloud and engineering teams` `Security operations running controls`
External assurance	`External auditors, regulators, certification bodies` `Sits outside the organisation but informs the board`

Where should the CISO report? Common options

REPORTING LINE	STRENGTHS	WATCH-OUTS
CIO or CTO	Close to technology delivery; fast execution	Conflict when security slows IT delivery; risk can be filtered before reaching the board
CEO or COO	Business-wide authority; visibility of all risk	CEO bandwidth; may lack technical sponsorship
Chief Risk Officer	Strong second-line independence; aligns with enterprise risk	Can drift away from engineering; operations may need to sit elsewhere
General Counsel	Strong on regulation and privacy	Programme may become compliance-only
Split model	Operational security under CIO, cyber risk oversight under CRO	Needs very clear boundaries and a shared risk register

> **INSIGHT · REPORTING LINE MATTERS LESS THAN ACCESS**
> What protects the organisation is the CISO's direct, regular and unfiltered access to the board or its risk committee, plus a budget process that is not simply a percentage of IT spend. If either is missing, fix that before redrawing the organisation chart.

Copyright © ZyeemZia

SCENARIO · DECIDE · A RISK THAT NOBODY OWNS

At a Chattogram container-terminal operator, the CISO discovers that the terminal operating system runs on an unsupported database. IT says the business must approve downtime for the upgrade; operations says IT owns all systems. The risk has sat on the register for 14 months without an owner. What should the CISO do FIRST?

(A) Schedule the upgrade over a weekend under the CISO's own authority.

(B) Escalate through the agreed governance route so the executive committee names the terminal's business owner as accountable for the risk and its treatment decision.

(C) Record the CISO as risk owner so that the register is complete.

(D) Ask internal audit to raise a finding so that someone is forced to act.

Circle your choice. Answer and feedback: module answer key.

Signs that governance is working

- Every top risk has one named accountable owner at the right level
- Risk acceptance and policy exceptions have thresholds, expiry dates and are reported
- The board discusses cyber risk in business terms at least quarterly
- Security investment decisions reference the risk register and appetite
- Internal audit covers cyber risk on a risk-based plan, not only IT general controls

REFLECT

Draw your organisation's current decision path for accepting a high cyber risk. Who actually decides today, and who should decide? Where does the information get filtered?

Key terms

Security governance
The system by which leaders direct and oversee security so it supports objectives, stays within risk appetite and meets obligations.

Security management
Planning, organising and running the security activities that carry out governance direction.

Accountability
The duty to answer for an outcome; it cannot be delegated and sits with exactly one person per decision or risk.

Decision rights
The documented authority to make specific decisions, such as accepting risk or approving exceptions, often with value thresholds.

Three lines model
An accountability model separating risk ownership (first line), oversight and challenge (second line) and independent assurance (third line).

Governing body
The board or equivalent group that sets direction, approves appetite and holds management to account.

Copyright © ZyeemZia

Risk owner
The person with the authority and budget to decide how a specific risk is treated and to accept what remains.

CISO
Chief Information Security Officer: the executive responsible for the security programme, strategy and reporting on cyber risk.

KNOWLEDGE CHECK

1. Which activity is primarily a governance activity rather than a management activity?
   - (A) Approving the organisation's cyber risk appetite
   - (B) Writing the detailed patching standard for Windows and Linux servers
   - (C) Choosing a new endpoint detection product
   - (D) Running a quarterly phishing simulation
2. In the three lines model, internal audit's main contribution to cyber risk is to:
   - (A) Own and operate the key security controls for the business units
   - (B) Write the information security policy
   - (C) Accept residual risk for business units
   - (D) Provide independent assurance to the governing body
3. A business unit head wants the CISO to be named owner of a ransomware risk to the unit's ERP system. Why is this weak?
   - (A) The CISO is a third-line function
   - (B) The CISO lacks authority over the ERP's budget, downtime and business trade-offs
   - (C) Risk owners must always be board members
   - (D) Ransomware risks cannot have an owner
4. Which signal best shows a CISO has effective access to governance?
   - (A) A reporting line directly to the CEO shown on the organisation chart, whatever the meeting access
   - (B) A security budget equal to ten per cent of IT spend
   - (C) Regular, direct reporting to the board's risk committee without filtering
   - (D) Membership of the IT change advisory board
5. Which statement correctly separates accountable and responsible?
   - (A) Many people can be responsible for work, but one person is accountable for the outcome
   - (B) Accountability can be delegated to a contractor along with the work, if the contract says so
   - (C) Responsible means the person who approves the budget
   - (D) Accountable and responsible are the same in security

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · GOVERN · LESSON 2 · 35 MIN

NIST CSF 2.0: Functions, Profiles and Tiers

Using the most widely referenced cyber framework as a common language for programmes and boards

- Explain the six CSF 2.0 functions and why Govern sits at the centre
- Build current and target profiles and derive a prioritised gap plan
- Use implementation tiers to describe the rigour of risk practices

The **NIST Cybersecurity Framework (CSF) 2.0**, published in February 2024 by the US National Institute of Standards and Technology, is a voluntary, outcome-based framework. It does not tell you which products to buy or exactly how to configure them. It describes **outcomes** an organisation should achieve, organised so that executives, engineers and auditors can talk about the same thing. Version 2.0 widened the scope beyond critical infrastructure to every organisation and added a sixth function, **Govern**.

The six functions in plain words

GV
Govern
Set and monitor the organisation's cyber risk strategy, expectations, roles, policy, oversight and supply-chain risk approach. It informs all the others.

ID
Identify
Understand current risk: assets, business environment, risk assessment and improvement opportunities.

PR
Protect
Use safeguards to manage risk: identity and access, awareness, data security, platform security and resilient technology infrastructure.

DE
Detect
Find and analyse possible attacks and compromises through continuous monitoring and adverse-event analysis.

RS
Respond
Take action on a detected incident: manage, analyse, communicate and contain or mitigate it.

RC
Recover
Restore assets and operations affected by an incident and communicate during recovery.

INSIGHT · WHY GOVERN SITS IN THE MIDDLE

In the CSF 2.0 wheel, Govern is drawn at the centre because it shapes how the other five are prioritised and funded. Its categories cover organisational context, risk-management strategy, roles and authorities, policy, oversight and cybersecurity supply-chain risk management. If your programme has strong tools but no Govern outcomes, the framework is telling you the foundation is missing.

CSF 2.0 structure

ELEMENT	WHAT IT IS	HOW YOU USE IT
Core	Functions, then categories, then subcategories (6 functions, 22 categories, 106 subcategories)	A checklist of outcomes to assess and target
Implementation examples	Short illustrations of actions that could achieve a subcategory	Ideas, not mandatory controls
Informative references	Mappings to other standards and guidance	Link CSF outcomes to ISO, CIS and sector controls

Copyright © ZyeemZia

ELEMENT	WHAT IT IS	HOW YOU USE IT
Organisational profiles	Current and target states of selected outcomes	Gap analysis and roadmap
Community profiles	Shared target profiles for a sector or use case	Start from a sector baseline instead of a blank page
Tiers	Four levels describing rigour of risk governance and management	Set an ambition, not a score

Building a CSF profile-based roadmap

1. **Scope** Choose the scope: the whole organisation, a business unit or a critical service such as mobile payments.
2. **Gather context** Collect mission, regulatory duties, risk appetite, threat picture and dependencies.
3. **Create the current profile** For each selected subcategory, record what is achieved today with evidence, not opinion.
4. **Create the target profile** Decide which outcomes must be achieved, to what degree, by when, based on risk and obligations.
5. **Analyse gaps** Compare profiles, estimate cost and risk reduction of closing each gap.
6. **Prioritise and plan** Build a sequenced action plan with owners, budget and milestones.
7. **Implement and repeat** Execute, measure, and refresh profiles at least annually or after major change.

Implementation tiers (described in our words)

TIER	NAME	WHAT IT LOOKS LIKE
1	Partial	Ad hoc, reactive; limited awareness of cyber risk at organisational level
2	Risk informed	Management approves risk practices but they are not organisation-wide policy
3	Repeatable	Formally approved, consistently applied and updated as threats and business change
4	Adaptive	Practices adapt from lessons and predictive indicators; cyber risk part of culture and decisions

WATCH OUT · TIERS ARE NOT MATURITY SCORES TO MAXIMISE

Tier 4 everywhere is expensive and unnecessary for many organisations. Choose a target tier that matches risk and resources. A regional garment exporter may sensibly target Tier 2 to 3; a central bank's payment system would aim higher.

SCENARIO · DECIDE · CHOOSING THE FIRST USE OF CSF

A Dhaka-based mobile financial services provider has dozens of security tools but no board-approved cyber strategy, unclear risk ownership and growing regulator questions. The new CISO wants to adopt CSF 2.0. Which focus should come FIRST?

(A) Score all 106 subcategories at once and present the average to the board.

(B) Start with Detect, because tools already exist and quick wins are visible.

(C) Assess Govern outcomes (context, risk strategy, roles, policy and oversight) and use the gaps to shape the target profile for the rest.

(D) Aim for Tier 4 in every function to impress the regulator.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

TEMPLATE

CSF profile gap register

Record current and target outcomes for selected subcategories and turn the differences into prioritised, owned actions.

FUNCTION.CATEGORY	OUTCOME IN OUR WORDS	CURRENT STATE (EVIDENCE)	TARGET STATE AND DATE	GAP AND ACTION	OWNER	PRIORITY
GV.RR	*Roles and authorities for cyber risk are defined and communicated*	*Informal; CISO role only in job description*	*Board-approved RACI by Q2*	*Draft RACI, approve at risk committee*	*Chief Risk Officer*	*High*
PR.AA	*Identities and access are managed for users, services and hardware*	*MFA for 60% of staff; no service account inventory*	*Phishing-resistant MFA for admins; NHI inventory by Q3*	*MFA rollout; service account discovery*	*Head of IAM*	*High*

REFLECT

If you had to present only three CSF outcomes to your board this year, which would they be and why? What evidence would show progress?

Key terms

NIST CSF 2.0
A voluntary, outcome-based cybersecurity framework from the US National Institute of Standards and Technology, released in 2024 with six functions.

Govern function
The CSF 2.0 function covering context, risk strategy, roles, policy, oversight and supply-chain risk management; it informs the other five.

Copyright © ZyeemZia

CSF Core
The hierarchy of functions, categories and subcategories describing desired cybersecurity outcomes.

Organisational profile
A description of an organisation's current or target cybersecurity outcomes, used to find and prioritise gaps.

Implementation tier
One of four levels (Partial, Risk informed, Repeatable, Adaptive) describing the rigour of cyber risk practices.

Subcategory
The most specific CSF outcome statement, used for assessment and target setting.

Community profile
A shared target profile for a sector, threat or technology that organisations can adapt.

Informative reference
A mapping from a CSF outcome to a specific clause or control in another standard or guide.

KNOWLEDGE CHECK

6. Which function was added in CSF 2.0?

   (A) Identify
   (B) Recover
   (C) Assure
   (D) Govern

7. A team writes down which CSF outcomes it achieves today and which it must achieve in 18 months. What are they creating?

   (A) Implementation tiers
   (B) Current and target organisational profiles
   (C) Informative references
   (D) A community profile shared across the whole sector

8. What is the most accurate description of CSF implementation tiers?

   (A) Mandatory certification levels issued by NIST
   (B) A ranking of control strength for each subcategory
   (C) Levels of rigour in risk practices, chosen to fit the organisation
   (D) Maturity scores that every organisation should push to the highest level as quickly as possible

9. Why are informative references useful to a GRC team?

   (A) They link CSF outcomes to controls in other standards, reducing duplicate work
   (B) They replace the need for risk assessment
   (C) They list the legal requirements that apply to each sector and country using CSF
   (D) They define the budget for each function

10. Which statement about CSF 2.0 is correct?

    (A) It mandates specific product categories and configurations for each of the six functions
    (B) It describes outcomes and leaves the choice of specific controls to the organisation
    (C) It applies only to US critical infrastructure
    (D) It replaces the need for an ISMS

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · GOVERN · LESSON 3 · 35 MIN

ISO/IEC 27001:2022: Building and Certifying an ISMS

A management-system approach to information security that auditors can certify

- Describe the clause structure of an ISMS and the Plan-Do-Check-Act logic behind it
- Explain the four Annex A themes and how a Statement of Applicability is built
- Plan a realistic certification journey and avoid common audit failures

ISO/IEC 27001 specifies requirements for an **information security management system (ISMS)**: a set of policies, processes, roles and controls that an organisation uses to manage information security risk and to improve continually. Unlike CSF, it is **certifiable**: an accredited certification body can audit you and issue a certificate for a defined scope. The 2022 edition reorganised its control annex; certificates against the older 2013 edition had to transition by 31 October 2025.

The ISMS as a management cycle

01 Plan
Context, scope, leadership, risk assessment and treatment plan

→

02 Do
Implement controls, train people, operate processes

→

03 Check
Monitor, measure, internal audit, management review

→

04 Act
Correct nonconformities and improve continually

Mandatory clauses 4 to 10 (our summary)

CLAUSE	THEME	KEY EXPECTATIONS
4	Context	Understand internal and external issues and interested parties; define ISMS scope
5	Leadership	Top management commitment, information security policy, roles and authorities
6	Planning	Risk assessment and treatment process, objectives, planning of changes
7	Support	Resources, competence, awareness, communication, documented information
8	Operation	Run the planned processes, perform risk assessments and treatment
9	Performance evaluation	Monitoring and measurement, internal audit, management review
10	Improvement	Nonconformity, corrective action and continual improvement

Annex A: four control themes (93 controls)

A.5
Organisational (37)
Policies, roles, asset and information management, supplier relationships, cloud use, incident management, continuity readiness, legal and privacy.

A.6
People (8)
Screening, terms of employment, awareness and training, disciplinary process, remote working and event reporting.

A.7
Physical (14)
Perimeters, entry, offices, monitoring, equipment siting, storage media, utilities, cabling and secure disposal.

Copyright © ZyeemZia

A.8

Technological (34)

Endpoints, privileged access, authentication, malware, vulnerabilities, configuration, logging, network and application security, secure development.

PRO TIP · CONTROLS ADDED IN 2022 WORTH KNOWING

The 2022 edition introduced controls such as threat intelligence, information security for cloud services, ICT readiness for business continuity, physical security monitoring, configuration management, information deletion, data masking, data leakage prevention, monitoring activities, web filtering and secure coding. They signal what auditors now expect a modern ISMS to address.

The **Statement of Applicability (SoA)** is the bridge between risk and controls. For every Annex A control it records whether the control is included, why (risk, legal, contractual or business reason), whether it is implemented, and, if excluded, why. Annex A is a reference list: you may add controls from other sources, and you compare your chosen controls against Annex A to make sure nothing necessary was omitted.

A pragmatic certification journey

1. **Define scope** Choose a scope that matters to customers and regulators and that you can control, such as the payment platform and its supporting teams.
2. **Gap assessment** Compare current practice to clauses 4 to 10 and Annex A; estimate effort.
3. **Risk assessment and treatment** Run a documented method; select controls; produce the SoA and treatment plan approved by risk owners.
4. **Implement and operate** Run controls for long enough to generate evidence, typically three months or more.
5. **Internal audit and management review** Audit the whole ISMS once and hold a management review before certification.
6. **Stage 1 audit** The certification body reviews documentation and readiness.
7. **Stage 2 audit** Auditors test implementation and effectiveness; nonconformities must be corrected.
8. **Surveillance and recertification** Annual surveillance audits and full recertification every three years.

WATCH OUT · COMMON REASONS ISMS AUDITS GO BADLY

A scope that excludes the systems customers care about; risk assessments copied from templates; an SoA that does not match reality; no evidence that management review happened; internal audit performed by the people who run the controls; and metrics that were invented the week before the audit.

CASE STUDY · A CERTIFICATE THAT DID NOT REASSURE

A software house in Dhaka supplies a hospital network with a patient-records platform. It holds an ISO/IEC 27001 certificate and the hospital's procurement team accepted it without further questions. After a breach traced to the vendor's production cloud environment, the hospital learns the certificate scope covered only the company's head-office IT and HR processes, not product development or cloud hosting.

1. What should the hospital have checked before relying on the certificate?

Copyright © ZyeemZia

2. Was the vendor's certificate misleading, and what is the governance lesson for the vendor?

3. How should the hospital's supplier assurance process change?

Model answer: module answer key.

TEMPLATE **Statement of Applicability extract**

Record, for each control, whether it applies, why, and its implementation status, so auditors and managers can trace controls back to risk.

CONTROL	APPLICABLE?	JUSTIFICATION	IMPLEMENTATION STATUS	EVIDENCE LOCATION	OWNER
A.8.24 Use of cryptography	*Yes*	*Risk R-12 data disclosure; contract with bank partners*	*Implemented for data at rest; TLS 1.2+ enforced*	*Crypto standard v3; config reports*	*Head of platform*
A.7.5 Protecting against physical and environmental threats	*Yes*	*Flood risk at Chattogram data room*	*Partially implemented; raised plinth planned Q3*	*Facilities risk report*	*Facilities manager*

REFLECT

If your organisation pursued ISO/IEC 27001 certification next year, which scope would give customers the most confidence while staying achievable? What would you leave out and why?

Copyright © ZyeemZia

Key terms

ISMS
Information security management system: the policies, processes, roles and controls used to manage information security risk and improve continually.

ISO/IEC 27001
The international standard specifying requirements for establishing, running and improving an ISMS; organisations can be certified against it.

Annex A
The reference list of 93 information security controls in ISO/IEC 27001:2022, grouped into organisational, people, physical and technological themes.

Statement of Applicability
A document listing each control, whether it is applicable, why, and its implementation status.

Certification scope
The defined boundary of organisation, locations, services and assets covered by an ISMS certificate.

Nonconformity
A failure to meet a requirement of the standard or of the organisation's own ISMS; major ones can block certification.

Management review
A planned review by top management of ISMS performance, risks, audit results and improvement opportunities.

Surveillance audit
A periodic audit by the certification body between recertifications to confirm the ISMS still works.

KNOWLEDGE CHECK

11. What makes ISO/IEC 27001 different from NIST CSF in practice?

(A) It is purely a list of technical controls with no management requirements
(B) It does not require risk assessment
(C) It is only for government agencies
(D) Organisations can be certified against it by an accredited body

12. Which Annex A theme contains controls on screening, awareness and disciplinary processes?

(A) Organisational
(B) Physical
(C) People
(D) Technological

13. A control from Annex A is not relevant to a company. What must the SoA show?

(A) Nothing, because only included controls are listed
(B) That it is implemented anyway, since every Annex A control is mandatory
(C) That it is excluded and the justification for exclusion
(D) A management signature for every control

14. Which activity belongs to the Check phase of an ISMS?

(A) Defining scope and interested parties
(B) Implementing endpoint controls
(C) Correcting a nonconformity
(D) Internal audit and management review

15. A procurement team receives a supplier's ISO/IEC 27001 certificate. What should it check first?

(A) The total number of Annex A controls the supplier says it has implemented
(B) Whether the certificate scope covers the service being bought
(C) Whether the certificate is printed on letterhead
(D) The supplier's market share

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · GOVERN · LESSON 4 · 30 MIN

CIS Controls and COBIT-Style Governance of Enterprise IT

Prioritised technical safeguards meet structured governance objectives

- Use the CIS Controls and implementation groups to prioritise technical safeguards
- Explain COBIT-style governance and management objectives and capability levels
- Decide when each framework is the right tool for a problem

Frameworks answer different questions. **CSF** asks what outcomes you need. **ISO/IEC 27001** asks whether you have a management system that keeps risk under control. The **CIS Critical Security Controls** ask which concrete safeguards stop the most common attacks first. **COBIT**, published by ISACA, asks how the whole of enterprise IT, including security, is governed and managed to create value. An expert leader uses each for its strength rather than arguing about which is best.

The 18 CIS Controls (version 8.1, in short)

#	CONTROL AREA	#	CONTROL AREA
1	Inventory of enterprise assets	10	Malware defences
2	Inventory of software assets	11	Data recovery
3	Data protection	12	Network infrastructure management
4	Secure configuration	13	Network monitoring and defence
5	Account management	14	Security awareness and skills training
6	Access control management	15	Service provider management
7	Continuous vulnerability management	16	Application software security
8	Audit log management	17	Incident response management
9	Email and web browser protections	18	Penetration testing

CIS implementation groups

IG1: essential hygiene

- 56 safeguards
- Small or resource-limited organisations
- Defends against common, untargeted attacks
- The minimum every organisation should meet

IG2: adds 74 safeguards

- Organisations with IT staff and some sensitive data
- Handles more complex environments and regulation
- Builds on IG1

IG3: all 153 safeguards

- Organisations with dedicated security experts
- Sensitive data and targeted attackers
- Includes advanced testing and monitoring

EXAMPLE · IG1 AT A GARMENT FACTORY GROUP

A Gazipur garment group with 4,000 workers and a six-person IT team cannot run a full SOC. By committing to IG1 first, it inventories laptops and production PCs, enforces MFA for email and remote access, patches internet-facing systems quickly, keeps offline backups of the ERP and trains supervisors to report suspicious messages. These steps block most of the attacks it actually faces.

Copyright © ZyeemZia

COBIT treats governance and management of enterprise information and technology as a system. In its 2019 edition it defines 40 **governance and management objectives** grouped into five domains. One domain is governance (evaluate, direct and monitor); four are management. Each objective is supported by components such as processes, organisational structures, policies, information flows, culture, skills and infrastructure. Design factors such as strategy, risk profile, sourcing model and threat landscape tailor which objectives matter most.

COBIT-style objective domains

EDM: Evaluate, Direct and Monitor	`Governance objectives for the board` `Benefits, risk optimisation, resource optimisation, stakeholder engagement`
APO: Align, Plan and Organise	`Strategy, architecture, budget, risk, security management, suppliers`
BAI: Build, Acquire and Implement	`Programmes, requirements, solutions, change, configuration`
DSS: Deliver, Service and Support	`Operations, service requests, problems, continuity, security services, business process controls`
MEA: Monitor, Evaluate and Assess	`Performance, internal control, compliance, assurance`

Capability levels for a process (COBIT-style, 0 to 5)

LEVEL	MEANING
0	Lack of basic capability; activities missing or incomplete
1	Process more or less achieves its purpose through incomplete activities
2	Basic activities performed; process achieves its purpose
3	Process is well defined, documented and consistently performed
4	Process is measured and controlled with quantitative data
5	Process is continuously improved using measurement

Which framework for which question?

QUESTION	BEST FIT	WHY
Which safeguards should we implement first with limited staff?	CIS Controls IG1	Prescriptive, prioritised, measurable
How do we show customers our security is managed and audited?	ISO/IEC 27001	Certifiable management system
How do we describe our programme to the board and regulators?	NIST CSF 2.0	Plain outcome language, profiles and tiers
How is IT, including security, governed with the rest of the enterprise?	COBIT-style objectives	Links IT governance to enterprise goals and assurance

Copyright © ZyeemZia

SCENARIO · DECIDE · FRAMEWORK CHOICE FOR A BANK SUBSIDIARY

The IT subsidiary of a Bangladeshi commercial bank already holds ISO/IEC 27001 certification for its data centre. The parent board now complains that it cannot see how IT investment, IT risk and security decisions connect to business goals, and internal audit struggles to assess IT governance consistently. Which addition helps MOST?

(A) Replace ISO/IEC 27001 with the CIS Controls.

(B) Extend the ISMS scope to every branch first.

(C) Buy a GRC tool that produces dashboards.

(D) Adopt COBIT-style governance and management objectives to structure IT governance, decision rights and assurance across the subsidiary.

Circle your choice. Answer and feedback: module answer key.

Choosing and combining frameworks

☐ Name the question each framework will answer before adopting it

☐ Select one anchor framework for reporting and map others to it

☐ Use CIS Controls safeguards as measurable technical baselines

☐ Keep ISO/IEC 27001 scope aligned with services customers rely on

☐ Use COBIT-style objectives where IT governance and audit need structure

☐ Avoid running separate assessments for each framework on the same control

REFLECT

Which framework does your organisation lean on most, and which question is it currently being asked to answer that it was not designed for?

Key terms

CIS Controls
A prioritised set of 18 cyber defence controls and 153 safeguards maintained by the Center for Internet Security.

Implementation group
One of three CIS tiers (IG1 to IG3) indicating which safeguards suit an organisation's resources and risk.

COBIT
ISACA's framework for governance and management of enterprise information and technology.

Design factor
A characteristic such as strategy, risk profile or sourcing model used to tailor a governance system.

Safeguard
A specific, measurable action within a CIS Control, such as maintaining a software inventory.

Essential cyber hygiene
The IG1 baseline of safeguards that every organisation should implement to resist common attacks.

Governance objective
A COBIT-style objective for the governing body: evaluate options, direct management and monitor results.

Capability level
A 0 to 5 rating of how well a process achieves its purpose and is defined, measured and improved.

Copyright © ZyeemZia

KNOWLEDGE CHECK

16. A small NGO with one IT officer wants a practical technical starting point. Which is most suitable?

(A) CIS Controls implementation group 1
(B) COBIT capability level 5 for all processes
(C) ISO/IEC 27001 certification of the whole NGO
(D) CSF Tier 4 in every function

17. Which COBIT-style domain contains governance (as opposed to management) objectives?

(A) Evaluate, Direct and Monitor
(B) Align, Plan and Organise
(C) Deliver, Service and Support
(D) Monitor, Evaluate and Assess

18. A process is documented and consistently performed but not yet measured quantitatively. Which capability level fits best?

(A) Level 1
(B) Level 3
(C) Level 4
(D) Level 5

19. Why might an organisation use both ISO/IEC 27001 and the CIS Controls?

(A) CIS Controls are required for ISO certification
(B) ISO/IEC 27001 forbids other frameworks
(C) They cover entirely unrelated subjects, so using both never creates any overlap or duplicated effort
(D) The ISMS manages risk systematically while CIS safeguards give concrete technical baselines

20. Which CIS Control most directly addresses keeping offline, tested backups?

(A) Audit log management
(B) Secure configuration
(C) Data recovery
(D) Penetration testing

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · GOVERN · LESSON 5 · 35 MIN

Policy Architecture, Crosswalks and the GRC Operating Model

Turning frameworks into a lean set of policies, one control library and an operating rhythm

- Design a layered policy architecture that people actually follow
- Build a unified control framework that maps one control to many obligations
- Set up a GRC operating rhythm with exceptions, attestations and reporting

Most organisations do not suffer from too few policies; they suffer from too many, written in different styles, never reviewed and impossible to test. A **policy architecture** separates what the board mandates from how teams comply. A **unified control framework (UCF)** then lets one well-designed control satisfy many frameworks and regulations at once, so teams test once and report many times.

A layered policy architecture

Policy	`Short statements of intent and principles` `Approved by board or executive committee` `Changes rarely`
Standards	`Mandatory, measurable requirements` `Owned by CISO or domain owner` `Example: admin accounts use phishing-resistant MFA`
Procedures	`Step-by-step how-to for a team` `Owned by the operating team` `Example: how to request privileged access`
Guidelines	`Recommended practice, not mandatory` `Helps people make good choices`
Evidence	`Records, reports and logs proving the standard is met` `Feeds audits and metrics`

PRO TIP · THE TWO-PAGE POLICY TEST

A top-level information security policy that fits on two pages, avoids technical detail and names who owns what is far more likely to be read, approved and enforced. Push detail down into standards that can change without board approval.

Building a unified control framework

1. **List obligations** Collect regulations, contracts, certifications and internal policies that apply.
2. **Pick an anchor** Choose one structure (often CSF categories or ISO Annex A) to organise controls.
3. **Write controls once** Define each control with objective, owner, frequency, evidence and test method.
4. **Map obligations** Link each control to every requirement it satisfies: ISO, CIS, sector rules, customer clauses.
5. **Find gaps and overlaps** Unmapped requirements are gaps; duplicate controls are merged.
6. **Test once, report many** Collect evidence once per control and reuse it for every mapped obligation.

TEMPLATE **Unified control library entry**

Describe one control so that it can be owned, tested and mapped to many frameworks.

Copyright © ZyeemZia

CONTROL ID	CONTROL STATEMENT	OWNER	FREQUENCY	EVIDENCE	MAPPED TO	TEST METHOD
IAM-04	*Privileged accounts use phishing-resistant MFA and are reviewed quarterly*	*Head of IAM*	*Continuous; review quarterly*	*MFA policy report; signed review*	*CSF PR.AA; ISO A.8.2, A.8.5; CIS 5, 6; Bangladesh Bank ICT guideline access section*	*Sample 25 admin accounts; inspect review records*

Policies always meet reality. An **exception process** lets a business proceed with a documented deviation when the risk is understood and accepted by the right person for a limited time. Without one, teams either stop work or quietly ignore the policy. With one that is too easy, exceptions become permanent. Good exception processes have risk-based approval thresholds, compensating controls, an expiry date and visible reporting.

Policy exception lifecycle

01 Request — Requester states standard, reason, scope and duration →

02 Assess — Security assesses risk and compensating controls →

03 Approve — Owner at the right authority level accepts risk →

04 Track — Exception recorded with expiry and owner →

05 Review — Renew, remediate or close before expiry →

06 Report — Exception volume and age reported to risk committee

GRC operating rhythm

CADENCE	ACTIVITY	AUDIENCE
Weekly	Exception and high-risk finding review	Security leadership
Monthly	Control health metrics, overdue remediation	CISO and domain owners
Quarterly	Risk register refresh, KRI review, top risks	Executive risk committee
Half-yearly	Policy and standard attestation by managers	All people leaders
Annually	Policy review, framework profile refresh, board deep dive	Board or risk committee

Copyright © ZyeemZia

SCENARIO · DECIDE · EXCEPTIONS OUT OF CONTROL

A university in Rajshahi has 140 open security exceptions, 90 of them older than a year and many approved by the IT help desk. Auditors call the exception process ineffective. What is the BEST first change?

(A) Introduce risk-based approval levels with mandatory expiry dates, then review all existing exceptions with their owners and report ageing to the risk committee.

(B) Close all exceptions immediately and enforce the policy.

(C) Rewrite the security policy so fewer exceptions are needed.

(D) Move exception approval to the vice-chancellor's office for every case.

Circle your choice. Answer and feedback: module answer key.

CASE STUDY · ONE CONTROL, FIVE FRAMEWORKS

An MFS provider must satisfy Bangladesh Bank guidance, PCI DSS for card services, ISO/IEC 27001 certification and contractual requirements from two international partner banks. Each team runs its own assessment, so the identity team answers four different questionnaires on access reviews each year and still receives findings.

1. What is the root cause of duplicate effort?

2. How would a unified control framework change the identity team's year?

3. What governance decision is needed to make it work?

Model answer: module answer key.

REFLECT

Pick one security standard in your organisation. Who owns it, when was it last reviewed, how is compliance measured and how many exceptions exist against it?

Key terms

Policy architecture
A layered structure of policies, standards, procedures and guidelines with clear owners and approval levels.

Procedure
Step-by-step instructions for performing a task in line with a standard.

Standard
A mandatory, measurable requirement that implements a policy, such as minimum encryption settings.

Unified control framework
A single library of controls, each mapped to all the frameworks and obligations it satisfies.

Copyright © ZyeemZia

Crosswalk
A mapping between requirements in two or more frameworks showing where they overlap.

Compensating control
An alternative control that reduces risk when the required control cannot be applied.

Policy exception
A documented, time-limited and approved deviation from a policy or standard with accepted risk.

Attestation
A formal confirmation by a manager or owner that requirements are understood and met.

KNOWLEDGE CHECK

21. Which document should contain a requirement such as 'TLS 1.2 or higher for all external services'?

(A) The board-approved policy
(B) A guideline
(C) A procedure for help-desk staff
(D) A standard

22. What is the main benefit of a unified control framework?

(A) It removes the need for audits
(B) It replaces all regulations
(C) Evidence is collected once per control and reused for many obligations
(D) It lets each assurance team keep its own control definitions and testing calendar

23. Which feature is essential in a healthy exception process?

(A) Unlimited duration once approved
(B) An expiry date with review before renewal
(C) Approval by a peer in the requester's own team to keep things fast
(D) No reporting, to protect the business

24. A compensating control is best described as:

(A) An alternative safeguard that reduces risk when the required control cannot be applied
(B) A control that compensates staff for overtime
(C) A control added only after an external audit finding has been raised against the organisation
(D) A duplicate control kept for redundancy

25. Who should normally approve a high-risk exception to the access control standard for a core banking system?

(A) Any member of the IT service desk who is on duty when the request is logged
(B) The accountable business owner at the authority level set for high risks
(C) The person requesting the exception
(D) The external auditor

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 1 · GOVERN

Answer key

Knowledge checks

1. A Setting appetite is direction-setting by the governing body. The others turn direction into practice and belong to management or operations.

2. D The third line is independent. Operating controls is first-line work, policy is typically management or second line, and accepting risk belongs to risk owners.

3. B The risk owner must have the authority to decide treatment and accept the residual risk. That lies with the business owner of the service.

4. C Access and unfiltered information flow matter more than the box on the chart or a benchmark ratio.

5. A Responsibility for doing work can be shared or delegated; accountability for the outcome stays with one named person.

6. D CSF 2.0 added Govern to the original five functions. Assure is not a CSF function.

7. B Profiles capture current and target outcomes. Tiers describe rigour, references are mappings, and a community profile is shared across organisations.

8. C Tiers characterise practices and should be set to fit risk and resources; NIST does not certify against them.

9. A References map outcomes to frameworks such as ISO/IEC 27001 or the CIS Controls, which supports crosswalks and shared evidence.

10. B CSF is outcome-based and voluntary; version 2.0 explicitly addresses organisations of all sizes and sectors.

11. D 27001 specifies management-system requirements against which organisations are audited and certified; CSF is voluntary guidance without certification.

12. C The people theme (A.6) has eight controls covering the employment life cycle and awareness.

13. C The SoA covers every Annex A control and justifies inclusion or exclusion.

14. D Check covers monitoring, measurement, audit and review; correction belongs to Act.

15. B A certificate is only meaningful for its scope; many failures come from relying on narrow scopes.

16. A IG1 is designed for organisations with limited resources and focuses on essential hygiene.

17. A EDM is the governance domain; the other four contain management objectives.

18. B Level 3 is defined and consistent; level 4 adds quantitative measurement and control.

19. D The two complement each other: one provides the management system, the other prescriptive safeguards that can be mapped into the SoA.

20. C Data recovery (Control 11) covers backup and restoration practices.

21. D Measurable mandatory technical requirements belong in standards so they can change without board approval.

22. C A UCF reduces duplication by mapping one control to many requirements.

23. B Expiry forces review and stops temporary exceptions becoming permanent.

24. A Compensating controls provide comparable risk reduction by other means.

25. B Risk acceptance requires the right owner and authority level; auditors must stay independent.

Scenarios & case studies

> **Scenario · A risk that nobody owns**
> **B** is best. Best. The core failure is missing accountability. Once an owner with authority over downtime and budget is named, treatment can be decided and tracked.

> **Scenario · Choosing the first use of CSF**
> **C** is best. Best. The symptoms point to a governance gap. Govern outcomes give direction for prioritising Identify through Recover.

Copyright © ZyeemZia

Case study · A certificate that did not reassure
The hospital should have read the certificate's scope statement and asked for the SoA summary and the certification body's accreditation; a certificate only covers what is in scope. The vendor did nothing technically invalid, but presenting a narrow certificate as assurance for a service it did not cover is a governance and trust failure; the scope should cover the service sold to customers. The hospital should require scope confirmation, evidence for out-of-scope service components, contractual security obligations and the right to further assurance for critical suppliers.

Scenario · Framework choice for a bank subsidiary
D is best. Best. The gap is enterprise IT governance and assurance, which is COBIT's focus. The ISMS remains in place for security management.

Scenario · Exceptions out of control
A is best. Best. It fixes authority and time limits, cleans up the backlog and makes the problem visible to governance.

Case study · One control, five frameworks
The root cause is that each obligation is managed separately rather than through a single control library. With a UCF the identity team owns a small set of well-defined controls (for example quarterly privileged access review), each mapped to every relevant requirement; evidence is gathered once and reused, and testing is coordinated. The governance decision is to appoint one GRC owner for the library, agree the anchor structure and require all assurance teams to use it.

Copyright © ZyeemZia

02

MODULE 2 · QUANTIFY

Risk Assessment and Cyber-Risk Quantification

Turn cyber risk into decision-ready estimates of frequency, magnitude and value

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Write well-formed risk scenarios and choose a fit-for-purpose assessment method
- Set risk appetite, tolerances and accountable treatment decisions
- Apply FAIR-style decomposition with calibrated ranges
- Use Monte Carlo results, loss exceedance curves and ROSI to compare investments
- Keep scenarios current using threat intelligence and near misses

LESSONS

1. Risk Assessment Methods and the Limits of Heat Maps · 30 min
2. Risk Appetite, Tolerance and Treatment · 30 min
3. FAIR-Style Risk Decomposition · 40 min
4. Monte Carlo, Loss Exceedance and the Value of Controls · 40 min
5. Threat-Informed Risk Scenarios · 30 min

MODULE 2 · QUANTIFY · LESSON 1 · 30 MIN

Risk Assessment Methods and the Limits of Heat Maps

From asset lists to decision-ready risk statements

- Write well-formed cyber risk statements that link threat, weakness and business impact
- Compare asset-based, scenario-based and threat-based assessment approaches
- Explain why ordinal heat maps mislead and when they are still acceptable

A **risk** is the effect of uncertainty on objectives. In cyber terms, it is the possibility that a **threat** exploits a **weakness** to cause a **loss** to something the organisation values. A risk assessment identifies such possibilities, estimates how often they might happen and how much they could cost, and compares the result with the organisation's appetite. The output is not a colourful chart; it is information that helps someone decide what to do and how much to spend.

A well-formed risk statement

01	→	02	→	03	→	04	→	05
Threat		**Event**		**Weakness**		**Asset or service**		**Consequence**
Who or what could act: a ransomware group, an insider, a flood		What happens: encrypts the hospital's patient system		Why it could succeed: flat network, no offline backups		What is affected: outpatient and emergency services		Business impact: 5 days of disruption, diverted ambulances, regulatory scrutiny

EXAMPLE · WEAK VERSUS STRONG

Weak: 'Risk of cyber attack.' **Strong:** 'A financially motivated ransomware group gains access through an unpatched VPN appliance and encrypts the core banking database, halting branch and app transactions for up to three days and triggering regulatory reporting and customer compensation.' Only the second can be estimated, owned and treated.

Three ways to structure an assessment

Asset-based

- Start from an inventory of assets and their value
- Identify threats and vulnerabilities per asset
- Thorough but can produce thousands of low-value rows
- Common in traditional ISMS work

Scenario-based

- Start from a small set of loss scenarios that matter to the business
- Estimate frequency and magnitude for each
- Fits board conversations and quantification
- Risk of missing scenarios if workshops are narrow

Threat-based

- Start from threat actors and their techniques
- Map techniques to controls and detection
- Excellent for security engineering priorities
- Needs translation into business impact for leaders

A practical assessment cycle

1. **Establish context** Objectives, scope, appetite, criteria for likelihood and impact, and who must be consulted.
2. **Identify** List loss scenarios from business services, threat intelligence, incidents and audit findings.
3. **Analyse** Estimate frequency and magnitude, ideally as ranges with stated confidence.
4. **Evaluate** Compare with appetite and tolerance; rank by exposure and urgency.

Copyright © ZyeemZia

5. **Treat** Choose to mitigate, transfer, avoid or accept, with an owner and plan.
6. **Monitor and review** Track key risk indicators and refresh when the business, threats or controls change.

Many organisations rate likelihood and impact from 1 to 5 and multiply them. This is quick and helps start conversations, but it has serious weaknesses. Ordinal numbers are labels, not quantities: a 4 is not twice a 2. Multiplying them creates **range compression** (very different risks land in the same cell) and **rank reversal** (a cell that looks higher can hide a smaller loss). Different people interpret 'likely' differently, and risks cannot be added up into a portfolio.

Heat-map problems and practical fixes

PROBLEM	EXAMPLE	FIX
Ambiguous words	'Likely' means 20% to one manager and 80% to another	Anchor each level to a numeric frequency range
Range compression	A BDT 50 lakh and a BDT 40 crore loss both score 'major'	Use wider, logarithmic impact bands or real ranges
Cannot aggregate	Twenty 'medium' risks do not add up to anything	Quantify top risks in money so they can be summed
False precision	Scores like 13.5 suggest accuracy that does not exist	Show ranges and confidence instead of single scores
Anchoring and politics	Scores drift to whatever unlocks budget	Calibrate estimators and document evidence

INSIGHT · WHEN QUALITATIVE IS ENOUGH

A qualitative scale is acceptable for triage, for low-value risks and where data is genuinely missing, provided each level is anchored to numbers. Reserve quantitative analysis for the top risks, investment decisions and anything the board must compare with money.

SCENARIO · DECIDE · A BOARD ASKS FOR ONE NUMBER

The audit committee of a listed cement manufacturer asks the CISO: 'How much could we lose from cyber in a bad year?' The current register has 85 risks scored on a 5x5 matrix. What is the BEST response?

(A) Add up the 85 scores and convert the total to taka using an average loss per point.

(B) Quote the largest single breach fine reported in the industry.

(C) Say that cyber losses cannot be estimated and offer more training.

(D) Explain that the matrix cannot answer the question, then quantify the top five loss scenarios as ranges and present an annual loss distribution with a bad-year percentile.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Cyber risk scenario register**

Describe the top loss scenarios in a form that can be owned, estimated and compared with appetite.

Copyright © ZyeemZia

ID	THREAT AND EVENT	WEAKNESS	SERVICE AFFECTED	FREQUENCY (RANGE)	IMPACT (RANGE)	OWNER
CR-01	*Ransomware encrypts core banking and backups*	*Flat network; backups online*	*Branch and app payments*	*1 in 10 to 1 in 4 years*	*BDT 15 to 120 crore*	*Chief Operating Officer*
CR-02	*Insider exports customer data to a competitor*	*Broad data access; weak DLP*	*Retail lending*	*1 in 5 to 1 in 2 years*	*BDT 2 to 25 crore*	*Head of retail*

REFLECT

Take the top three risks from your organisation's register. Could a newcomer estimate how often each happens and what it would cost from the wording alone? Rewrite one using the five-part structure.

Key terms

Risk
The effect of uncertainty on objectives; in cyber, the possibility of loss when a threat exploits a weakness.

Threat
Anything capable of acting against an asset to cause harm, such as a criminal group, insider or natural event.

Vulnerability
A weakness that a threat could exploit, in technology, process or people.

Loss scenario
A specific, plausible story of a threat event and its business consequence that can be estimated.

Ordinal scale
A ranking scale such as 1 to 5 where numbers show order but not size; arithmetic on them is misleading.

Range compression
The heat-map effect where very different risks fall into the same score or cell.

Risk register
The managed record of identified risks with owners, ratings, treatments and status.

Risk criteria
The terms of reference, including appetite and rating scales, against which risks are evaluated.

KNOWLEDGE CHECK

Copyright © ZyeemZia

1. Which element is missing from the statement 'Ransomware could hit our ERP'?

(A) The weakness and the business consequence
(B) The name of the threat actor's country of origin
(C) A five-by-five score
(D) The name of the security vendor

2. Why is multiplying a 1 to 5 likelihood by a 1 to 5 impact problematic?

(A) Multiplication exaggerates every score, so all risks look worse than they really are
(B) The scores are always too low
(C) Ordinal numbers show order, not quantity, so the products mislead
(D) Regulators forbid matrices

3. A threat-based assessment starts from:

(A) A complete inventory of hardware, software and data assets
(B) The previous year's audit report only
(C) The insurance policy schedule
(D) Threat actors and their techniques

4. Which practice most improves a qualitative scale?

(A) Adding more colours to the heat map
(B) Anchoring each level to numeric frequency and impact ranges
(C) Allowing decimals in scores
(D) Letting each assessor define the levels personally, based on experience

5. For which purpose is a qualitative heat map most acceptable?

(A) Quick triage of many lower-value risks
(B) Comparing a BDT 30 crore investment with expected loss reduction
(C) Summing total exposure for the board
(D) Pricing cyber insurance

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · QUANTIFY · LESSON 2 · 30 MIN

Risk Appetite, Tolerance and Treatment

Deciding how much cyber risk is acceptable and what to do about the rest

- Write a cyber risk appetite statement with measurable tolerances
- Choose between mitigation, transfer, avoidance and acceptance with sound reasoning
- Run a risk acceptance process that is fast, accountable and auditable

A **risk appetite** is the amount and type of risk an organisation is willing to pursue or retain to achieve its objectives. It is set by the board. **Risk tolerance** turns appetite into measurable limits for specific risks or metrics. **Risk capacity** is the maximum loss the organisation could survive. Appetite should sit comfortably inside capacity, and tolerances should trigger action before appetite is breached.

From capacity to daily decisions

Risk capacity	`Maximum loss the organisation can absorb` `Capital, liquidity, licence conditions`
Risk appetite	`Board statement of how much risk to take for which goals` `Qualitative plus a few headline metrics`
Risk tolerances	`Measurable limits per risk type or metric` `Example: critical vulnerabilities on internet-facing systems fixed within 7 days, 95% of the time`
Key risk indicators	`Metrics that warn when tolerances are approached` `Reported monthly or quarterly`
Operational limits and standards	`Day-to-day rules teams follow`

EXAMPLE · APPETITE STATEMENT FOR A MOBILE FINANCIAL SERVICE

'We have **low appetite** for cyber events that interrupt customer payments or expose customer data, and **moderate appetite** for risk in experimenting with new digital channels, provided they are isolated from the core ledger. We will tolerate no more than **4 hours** of unplanned payment downtime per quarter and **zero** confirmed exposures of more than 1,000 customer records per year.'

Four treatment options

T1

Mitigate (modify)

Reduce frequency or impact with controls: MFA, segmentation, backups, monitoring.

T2

Transfer (share)

Shift part of the financial impact to others through insurance or contracts. Accountability stays with you.

T3

Avoid

Stop or change the activity that creates the risk, such as retiring an exposed legacy service.

Copyright © ZyeemZia

T4

Accept (retain)

Knowingly keep the risk because it is within appetite or treatment costs more than the benefit, with owner sign-off.

WATCH OUT · INSURANCE DOES NOT TRANSFER ACCOUNTABILITY

Cyber insurance can pay for response, recovery and some liabilities, but it cannot restore customer trust, prevent regulatory action or bring back lost data. Policies also contain exclusions and security conditions; failing to maintain stated controls such as MFA can reduce or void cover. Treat insurance as one part of a treatment plan, not the plan.

Acceptance authority by residual risk

RESIDUAL RISK LEVEL	WHO MAY ACCEPT	MAXIMUM DURATION	REPORTING
Low	Service owner	12 months	Register only
Medium	Business unit head with CISO consultation	12 months	Quarterly summary to risk committee
High	Executive committee member	6 months	Named in risk committee report
Outside appetite	Board or board risk committee	3 months with a plan	Board pack, every meeting

A disciplined treatment decision

1. **Confirm the risk** Check the scenario, current controls and current exposure estimate.
2. **List options** Include at least one mitigation, one transfer or avoidance option and 'accept'.
3. **Estimate effect and cost** Expected reduction in frequency or impact, cost to implement and run, time to effect.
4. **Compare with appetite** Choose the cheapest option that brings residual risk within tolerance.
5. **Decide and record** Owner approves; record rationale, residual estimate and review date.
6. **Track** Monitor implementation and key risk indicators; revisit if they drift.

SCENARIO · DECIDE · ACCEPT OR MITIGATE?

A garment buying house in Dhaka relies on a legacy order-tracking system that cannot support MFA. Replacing it costs BDT 3 crore and takes a year. The estimated annual loss from account takeover is BDT 20 to 40 lakh. The system will be retired in 18 months anyway. What is the BEST treatment decision?

(A) Replace the system immediately because all MFA gaps are unacceptable.

(B) Accept the residual risk for a fixed period with compensating controls such as VPN-only access with MFA at the gateway and login monitoring, approved by the business owner.

(C) Buy cyber insurance and take no other action.

(D) Let the IT manager accept the risk informally.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

TEMPLATE

Risk acceptance record

Document a decision to retain risk so that it is accountable, time-limited and reviewable.

RISK ID	RESIDUAL RISK AND ESTIMATE	REASON FOR ACCEPTANCE	COMPENSATING CONTROLS	ACCEPTED BY	EXPIRY	REVIEW TRIGGER
CR-07	*Medium: BDT 20 to 40 lakh per year*	*System retiring in 18 months; replacement cost disproportionate*	*VPN with MFA, login alerts*	*Head of merchandising*	*30 June*	*Any confirmed account takeover*

REFLECT

Does your organisation's appetite statement mention cyber explicitly? Write one sentence of appetite and two measurable tolerances for the service you know best.

Key terms

Risk appetite
The amount and type of risk an organisation is willing to pursue or retain to meet its objectives, set by the board.

Risk capacity
The maximum level of loss an organisation can absorb before failing its obligations or survival.

Inherent risk
The risk level before considering controls; useful mainly to show how much controls matter.

Risk acceptance
A documented decision by an authorised owner to retain a risk, usually time-limited and reviewed.

Risk tolerance
A measurable limit that turns appetite into thresholds for specific risks or metrics.

Residual risk
The risk that remains after treatment and existing controls are taken into account.

Risk transfer
Sharing the financial consequences of a risk with another party, such as an insurer or supplier.

Key risk indicator
A metric that signals increasing risk exposure before a loss occurs.

KNOWLEDGE CHECK

Copyright © ZyeemZia

6. Who should set the organisation's overall cyber risk appetite?

   (A) The SOC manager
   (B) The external auditor, after testing controls
   (C) The cyber insurer
   (D) The board or its risk committee

7. Which is an example of risk avoidance?

   (A) Buying a cyber insurance policy that covers incidents on the portal
   (B) Adding a web application firewall in front of the portal
   (C) Retiring an internet-facing legacy portal that cannot be secured
   (D) Documenting acceptance of the portal risk for six months

8. How does risk tolerance differ from risk appetite?

   (A) Tolerance is always higher than capacity
   (B) Tolerance sets measurable limits that put appetite into practice
   (C) Tolerance is set by the SOC, while appetite is set by the IT department
   (D) They are identical terms

9. Why should risk acceptances expire?

   (A) Because insurers require monthly renewals
   (B) Because accepted risks automatically become illegal after twelve months
   (C) So that the decision is revisited when conditions or controls change
   (D) To create more audit findings

10. Which statement about cyber insurance is most accurate?

    (A) It transfers all accountability to the insurer
    (B) It makes security controls unnecessary
    (C) It always covers regulatory fines and penalties in every country where you operate
    (D) It can share financial impact but leaves accountability and reputation with the organisation

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · QUANTIFY · LESSON 3 · 40 MIN

FAIR-Style Risk Decomposition

Breaking cyber risk into frequency and magnitude you can actually estimate

- Decompose a loss scenario into frequency and magnitude factors
- Estimate factors as calibrated ranges rather than single guesses
- Calculate expected annual loss using simple FAIR-style formulas

Factor Analysis of Information Risk (**FAIR**), an open standard maintained by The Open Group, is the best-known model for quantifying cyber risk. Its key idea is simple: risk is the probable **frequency** and probable **magnitude** of future loss. When a factor is hard to estimate directly, you break it into smaller factors that are easier to estimate. The description below is our own simplified, FAIR-style reasoning for leaders; formal practitioners use the full published taxonomy.

A FAIR-style factor tree (top to bottom)

Risk	`Annualised loss exposure, expressed as a distribution in money`
Frequency and magnitude	`Loss event frequency (how often per year)` `Loss magnitude (how much per event)`
Frequency drivers	`Threat event frequency: how often threats act` `Vulnerability (susceptibility): chance an attempt becomes a loss`
Susceptibility drivers	`Threat capability` `Resistance strength of controls`
Magnitude drivers	`Primary loss: borne directly by the organisation` `Secondary loss: from reactions of regulators, customers, partners`

Core FAIR-style relationships

MEASURE	FORMULA	WHAT IT TELLS YOU
Risk (annualised)	`Risk = LEF × LM`	Expected yearly loss equals how often loss events happen times how much each costs; in practice both are distributions, combined by simulation.
Loss event frequency	`LEF = TEF × Vuln`	Threat events per year multiplied by the probability that an event becomes a loss.
Susceptibility	`Vuln = P(TCap > RS)`	The probability that the threat's capability exceeds the resistance strength of your controls.
Loss magnitude	`LM = PL + (SLEF × SLM)`	Primary loss plus the chance of secondary reactions times their size.
Classic single-point version	`ALE = SLE × ARO; SLE = AV × EF`	Annualised loss expectancy from single loss expectancy, asset value, exposure factor and annual rate; useful for intuition, weak for decisions because it hides uncertainty.

Copyright © ZyeemZia

Forms of loss to consider

FORM	EXAMPLES	USUALLY PRIMARY OR SECONDARY
Productivity	Lost sales, idle staff, delayed shipments	Primary
Response	Incident responders, forensics, legal advice, notifications	Primary (some secondary)
Replacement	Rebuilding systems, replacing hardware, re-issuing cards	Primary
Fines and judgements	Regulatory penalties, lawsuits, contractual damages	Secondary
Competitive advantage	Lost trade secrets, cancelled tenders	Secondary
Reputation	Customer churn, higher cost of capital, lost partners	Secondary

DEFINITION · CALIBRATED ESTIMATION

A **calibrated estimator** has practised giving ranges such that, when they say they are 90% confident, the true answer falls inside their range about 90% of the time. Calibration training uses trivia questions and feedback. Most untrained people give ranges that are far too narrow; calibration widens them honestly and makes estimates defensible.

Estimating one scenario

1. **Define the scenario tightly** Asset, threat community, effect and time frame, for example 'ransomware by criminal groups against the hospital EHR in the next 12 months'.
2. **Estimate threat event frequency** Use incident data, sector reports and attack telemetry; express as a range such as 2 to 12 attempts per year.
3. **Estimate susceptibility** Consider threat capability against your controls; for example 5% to 20% of serious attempts succeed.
4. **Estimate primary loss** Productivity, response and replacement costs per event, as minimum, most likely and maximum.
5. **Estimate secondary loss** Probability that regulators, customers or partners react, and the size of those losses.
6. **Combine and sanity-check** Calculate or simulate; compare with industry data and challenge outliers.

Working the numbers

MEASURE	FORMULA	WHAT IT TELLS YOU
PERT most-likely mean	`Mean ≈ (min + 4 × mode + max) ÷ 6`	A quick way to summarise a three-point estimate; e.g. (2 + 4×6 + 20) ÷ 6 ≈ 7.7.
Example LEF	`LEF = 6 attempts/yr × 0.10 = 0.6 loss events/yr`	Six serious attempts a year, one in ten succeeds.
Example LM	`LM = 8 crore + (0.4 × 15 crore) = 14 crore`	BDT 8 crore primary loss plus a 40% chance of BDT 15 crore secondary loss.
Example expected loss	`Risk ≈ 0.6 × 14 crore = BDT 8.4 crore per year`	A point summary; the decision should also consider the bad-year tail.

Copyright © ZyeemZia

SCENARIO · DECIDE · A SINGLE NUMBER OR A RANGE?

A CFO at a Chattogram shipping company asks the security team to replace its FAIR-style ranges with single 'best guess' numbers because 'ranges look uncertain'. What should the CISO do?

(A) Keep ranges, explain that they express real uncertainty honestly, and show the expected value alongside a bad-year percentile for decisions.

(B) Replace every range with its midpoint to make the report cleaner.

(C) Use only the maximum of each range to be conservative.

(D) Stop quantifying and return to the heat map.

Circle your choice. Answer and feedback: module answer key.

CASE STUDY · QUANTIFYING RANSOMWARE AT A HOSPITAL NETWORK

A private hospital network in Dhaka runs five hospitals on a shared electronic health record (EHR). Workshops estimate: 4 to 15 serious ransomware attempts per year reaching the network; with current controls 5% to 15% would succeed; primary loss per event of BDT 6 to 30 crore (diversion of patients, overtime, recovery); a 30% chance of secondary loss of BDT 10 to 50 crore from regulators, lawsuits and lost corporate contracts.

1. Using midpoints, estimate loss event frequency and expected annual loss.

2. What does the calculation hide that the board should also see?

3. Which single control investment would you analyse first, and how would it change the factors?

Model answer: module answer key.

REFLECT

Pick a risk you know well. Which factor would be easiest for you to estimate, and which one would you need to decompose further? Who in your organisation holds the data?

Key terms

FAIR
Factor Analysis of Information Risk, an open standard model that expresses risk as the probable frequency and magnitude of future loss.

Loss event frequency
How often, within a time frame, a threat event is expected to result in loss.

Copyright © ZyeemZia

Threat event frequency
How often, within a time frame, threat agents are expected to act against an asset.

Primary loss
Loss borne directly by the organisation as a result of the event, such as downtime and response costs.

Calibrated estimate
A range given by a trained estimator whose stated confidence matches how often they are right.

Susceptibility
The probability that a threat event becomes a loss event, driven by threat capability versus resistance strength.

Secondary loss
Loss arising from reactions of external parties such as regulators, customers or litigants.

Annualised loss expectancy
The classic single-point expected yearly loss: single loss expectancy times annual rate of occurrence.

KNOWLEDGE CHECK

11. In FAIR-style analysis, loss event frequency is derived from:
    - (A) Threat event frequency and susceptibility
    - (B) Asset value multiplied by the exposure factor of each asset
    - (C) Primary and secondary loss
    - (D) Capability level and maturity

12. A regulator's fine after a breach is typically treated as:
    - (A) A secondary loss
    - (B) A primary loss
    - (C) A threat event
    - (D) A resistance strength factor

13. Threat events: 10 per year. Susceptibility: 20%. Loss per event: BDT 5 crore. What is the expected annual loss?
    - (A) BDT 50 crore
    - (B) BDT 2 crore
    - (C) BDT 10 crore
    - (D) BDT 25 crore

14. Why is calibration training useful for risk workshops?
    - (A) It removes all uncertainty from estimates
    - (B) It replaces the need for data
    - (C) It guarantees that every estimate is conservative and errs on the high side
    - (D) It makes people's stated confidence match how often they are right

15. What is the main weakness of the classic ALE = SLE × ARO approach?
    - (A) It cannot be calculated without specialised simulation software
    - (B) Single points hide uncertainty and the bad-year tail
    - (C) It ignores asset value
    - (D) It only works for physical risks

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · QUANTIFY · LESSON 4 · 40 MIN

Monte Carlo, Loss Exceedance and the Value of Controls

Simulating thousands of years to show what a bad year looks like and what controls are worth

- Explain how Monte Carlo simulation combines frequency and magnitude ranges
- Read and present a loss exceedance curve against risk tolerance
- Compare control investments using risk reduction and return on security investment

When frequency and magnitude are ranges, you cannot simply multiply midpoints and call it done. **Monte Carlo simulation** draws random values from each range thousands of times, each draw representing one possible year. The result is a distribution of annual losses. From it you can read the average, the median, the probability of exceeding any amount and the losses in a bad year such as the 1-in-20.

How a cyber Monte Carlo works

01 Choose distributions — Poisson for event counts; lognormal or PERT for losses →

02 Fit to estimates — Use calibrated 90% ranges to set parameters →

03 Simulate years — Draw number of events, then a loss for each event →

04 Sum per year — Each simulated year gives one annual loss →

05 Analyse — Mean, percentiles, exceedance probabilities →

06 Compare — Repeat with proposed controls and measure the shift

A minimal annual-loss simulation

Python notebook

```
import numpy as np
rng = np.random.default_rng(7)
N = 100_000                        # simulated years
events = rng.poisson(0.3, N)       # about 0.3 loss events per year
lo, hi = 2e7, 4e8                  # 90% range per event: BDT 2 to 40 crore
mu = (np.log(lo) + np.log(hi)) / 2
sigma = (np.log(hi) - np.log(lo)) / 3.29
annual = np.array([rng.lognormal(mu, sigma, k).sum() for k in events])
print('Mean annual loss (crore):', round(annual.mean() / 1e7, 1))
print('P(annual loss > 10 crore):', round((annual > 1e8).mean(), 3))
print('95th percentile (crore):', round(np.percentile(annual, 95) / 1e7, 1))
# Mean annual loss (crore): 4.1
# P(annual loss > 10 crore): 0.134
# 95th percentile (crore): 23.3
```

3.29 is twice 1.645, the z-value for a 90% two-sided interval, so the lognormal matches the stated range. Most simulated years have no loss at all; the mean is pulled up by rare, large years.

INSIGHT · THE MEAN IS NOT THE STORY

In the simulation above the average annual loss is about BDT 4 crore, but in roughly one year in seven losses exceed BDT 10 crore, and a 1-in-20 year costs more than BDT 23 crore. Boards care about that tail because it threatens budgets, covenants and reputation.

Copyright © ZyeemZia

A **loss exceedance curve (LEC)** plots loss amounts on the horizontal axis and the probability of exceeding each amount in a year on the vertical axis. Draw the organisation's **risk tolerance curve** on the same chart: the maximum probability the board will accept for each loss level. Where the inherent or current LEC sits above the tolerance curve, risk is outside appetite and needs treatment.

Comparing controls

MEASURE	FORMULA	WHAT IT TELLS YOU
Risk reduction	`ΔRisk = EL(before) − EL(after)`	Expected annual loss removed by the control, from two simulations or estimates.
Return on security investment	`ROSI = (ΔRisk − annual cost) ÷ annual cost`	Positive means the expected benefit exceeds the cost; compare options on the same basis.
Risk reduction per taka	`Efficiency = ΔRisk ÷ annual cost`	Ranks options when budget is limited.
Tail reduction	`ΔP = P(L > X before) − P(L > X after)`	How much a control lowers the chance of a bad year beyond a tolerance threshold X.

Worked comparison for a payment processor

OPTION	ANNUAL COST (BDT CRORE)	EXPECTED LOSS AFTER (CRORE)	ΔRISK (CRORE)	ROSI
Current state	0	12.0	–	–
Phishing-resistant MFA for all staff	1.0	8.5	3.5	2.5
Immutable backups and restore testing	1.5	7.0	5.0	2.3
Full 24x7 managed detection service	4.0	8.0	4.0	0.0
MFA plus backups together	2.5	4.8	7.2	1.9

WATCH OUT · INTERACTIONS AND HONESTY

Controls overlap: combining MFA and backups saves less than the sum of each alone. Simulate combinations rather than adding savings. Also disclose that estimates are uncertain and that ROSI is a decision aid, not a promise. A control with lower ROSI may still be required by law or to reduce the tail below tolerance.

Copyright © ZyeemZia

SCENARIO · DECIDE · WHICH INVESTMENT FIRST?

Using the comparison table above, the payment processor has BDT 2.5 crore this year and must bring the 1-in-20-year loss below BDT 30 crore, its tolerance. Only the MFA-plus-backups combination does so in simulation. What should the CISO recommend?

(A) Fund MFA alone because it has the highest ROSI.

(B) Fund the managed detection service because detection is fashionable.

(C) Fund MFA and backups together, because it is the only affordable option that brings the tail within tolerance, even though its ROSI is lower than MFA alone.

(D) Defer all investment until estimates are more precise.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Control investment comparison**

Compare candidate controls on expected loss, tail risk and cost so that funding decisions are transparent.

OPTION	ANNUAL COST	EXPECTED LOSS BEFORE	EXPECTED LOSS AFTER	P(LOSS > TOLERANCE) AFTER	ROSI	NOTES
Immutable backups	*BDT 1.5 crore*	*BDT 12 crore*	*BDT 7 crore*	*4%*	*2.3*	*Also reduces downtime for non-cyber failures*

REFLECT

Which of your current security investments could you defend with a before-and-after estimate of expected loss and tail risk? Which one would struggle, and why might it still be justified?

Key terms

Monte Carlo simulation
A method that repeatedly samples from input distributions to build the distribution of an outcome, such as annual loss.

Loss exceedance curve
A chart showing the probability that annual losses will exceed each possible amount.

Copyright © ZyeemZia

Risk tolerance curve
A board-defined curve of the maximum acceptable probability of exceeding each loss level.

Poisson distribution
A distribution commonly used to model the number of events in a fixed period at a given average rate.

ROSI
Return on security investment: risk reduction minus cost, divided by cost.

Lognormal distribution
A right-skewed distribution often used for loss sizes because most losses are small but a few are very large.

Percentile
The value below which a given percentage of simulated outcomes fall; the 95th percentile is a 1-in-20 bad year.

Tail risk
The risk of rare, very large losses at the extreme end of the distribution.

KNOWLEDGE CHECK

16. What does each iteration of a cyber Monte Carlo simulation usually represent?
    - (A) One possible year of losses
    - (B) One employee
    - (C) One control test performed by internal audit
    - (D) One audit finding

17. A loss exceedance curve shows a 10% probability of exceeding BDT 20 crore. The tolerance curve allows 5% at that level. What does this mean?
    - (A) Risk is within appetite
    - (B) The simulation is wrong and must be rerun with more iterations
    - (C) Insurance is unnecessary
    - (D) Risk at that level is outside tolerance and needs treatment

18. A control costs BDT 2 crore per year and reduces expected loss from 10 to 5 crore. What is its ROSI?
    - (A) 2.5
    - (B) 1.5
    - (C) 0.5
    - (D) 5.0

19. Why should combined controls be simulated rather than adding individual savings?
    - (A) Simulation software cannot add separate savings figures reliably
    - (B) Regulators require combined simulation
    - (C) Controls overlap, so combined savings are usually less than the sum
    - (D) Individual savings are always zero

20. Which distribution is commonly used for the size of individual cyber losses?
    - (A) Uniform
    - (B) Normal with mean zero
    - (C) Lognormal
    - (D) Binary

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · QUANTIFY · LESSON 5 · 30 MIN

Threat-Informed Risk Scenarios

Using threat intelligence and attack techniques to make risk scenarios real

- Build risk scenarios from threat intelligence relevant to your sector and region
- Map adversary techniques to controls to estimate susceptibility
- Keep the risk register current with intelligence, incidents and near misses

Risk estimates are only as good as the scenarios behind them. **Threat-informed risk management** starts from who is actually attacking organisations like yours and how. Intelligence turns vague fears into specific scenarios; mapping attacker techniques to your controls turns gut feel about susceptibility into evidence.

Threat communities and typical goals

THREAT COMMUNITY	TYPICAL GOALS	RELEVANT SECTORS IN SOUTH ASIA
Ransomware and extortion groups	Money through encryption and data-leak extortion	Hospitals, manufacturing, logistics, universities
Financially motivated fraud groups	Payment fraud, account takeover, SIM-swap	Banks, MFS providers, e-commerce
State-aligned actors	Espionage, pre-positioning in critical infrastructure	Government, telecom, energy, defence suppliers
Hacktivists	Defacement, DDoS and leaks for political messaging	Government, media, high-profile brands
Insiders	Fraud, data theft, sabotage or careless error	All sectors, especially those with broad access
Opportunistic criminals	Mass exploitation of known vulnerabilities	Any internet-facing organisation

From intelligence to a risk scenario

01 **Collect** — Sector reports, CERT advisories, peer sharing, own incidents

→

02 **Select threats** — Choose the few communities most likely to target you

→

03 **Map techniques** — List their common initial access, movement and impact techniques

→

04 **Check controls** — Prevent, detect and recover coverage for each technique

→

05 **Write scenarios** — Threat, event, weakness, service, consequence

→

06 **Estimate** — Frequency and magnitude ranges, with evidence

PRO TIP · USE A COMMON TECHNIQUE LANGUAGE

Public knowledge bases of adversary tactics and techniques, such as MITRE ATT&CK, give security engineers and risk analysts a shared vocabulary. Mapping your preventive and detective controls to the techniques used by your priority threat groups shows where susceptibility is high and justifies the estimate in the risk register.

Copyright © ZyeemZia

Technique-to-control coverage (extract)

TECHNIQUE THEME	PREVENT	DETECT	RECOVER	COVERAGE JUDGEMENT
Phishing for credentials	Phishing-resistant MFA for 70% of staff	Impossible-travel alerts	Account reset runbook	Partial
Exploiting internet-facing apps	Patch SLA 14 days, WAF	Exploit signatures, anomaly alerts	Rebuild from images	Good
Valid accounts via stolen VPN credentials	MFA on VPN	VPN login analytics	Session revocation	Good
Disabling backups and shadow copies	Backup admin separation	Alerts on backup deletion	Immutable copies	Weak: no immutability
Data exfiltration to cloud storage	Web filtering	Large upload alerts	Not applicable	Partial

Intelligence sources worth wiring into risk

- National CIRT and sector CERT advisories (for example Bangladesh's national government CIRT and banking-sector sharing groups)
- Your own incidents, near misses and red-team findings
- Industry breach and ransomware reports, read critically for sample bias
- Lists of vulnerabilities known to be exploited in the wild
- Insurance claims data shared by brokers
- Peer CISO groups and information sharing and analysis centres

SCENARIO · DECIDE · A NEAR MISS CHANGES THE ESTIMATE

A university's SOC detects and stops attackers who used a stolen student credential to reach a research file server. The risk register still rates 'data theft from research systems' as rare because 'nothing has happened'. What should the risk owner do?

(A) Treat the near miss as evidence: raise the frequency estimate, review susceptibility controls on research systems and record the change with its rationale.

(B) Leave the rating unchanged because no data was lost.

(C) Rate the risk as certain and freeze all research system access.

(D) Wait for the annual risk review to update the register.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

Keeping scenarios current

☐ Review top scenarios after any significant incident or near miss

☐ Refresh threat community assumptions at least twice a year

☐ Update technique-to-control coverage after major control changes

☐ Record the evidence behind every frequency and susceptibility estimate

☐ Retire scenarios when the asset or service is decommissioned

☐ Share anonymised scenarios with peers to test realism

REFLECT

Name the two threat communities most likely to cause your organisation a material loss in the next year. What evidence supports your choice, and which of their techniques are you least prepared for?

Key terms

Threat intelligence
Evidence-based knowledge about threats, their capabilities and intentions, used to inform decisions.

Tactics, techniques and procedures
The behaviour of an adversary: its goals, the methods it uses and its specific implementations.

Near miss
An event that could have caused loss but was stopped or did not do so; valuable risk evidence.

Control coverage
The degree to which preventive, detective and recovery controls address a given technique.

Threat community
A group of threat agents with similar goals and methods, such as ransomware groups or insiders.

MITRE ATT&CK
A public knowledge base of adversary tactics and techniques based on real-world observations.

Threat-informed defence
Prioritising controls and detection according to the techniques of the most relevant adversaries.

KNOWLEDGE CHECK

21. What is the main benefit of mapping adversary techniques to controls?

(A) It replaces frequency estimation

(B) It gives evidence for susceptibility estimates and shows gaps

(C) It ensures compliance with every applicable cyber law and regulation

(D) It removes the need for incident response

22. A bank sees a rise in SIM-swap fraud against customers. Which threat community does this most likely reflect?

(A) Financially motivated fraud groups

(B) State-aligned espionage actors

(C) Hacktivists

(D) Natural hazards

Copyright © ZyeemZia

23. How should a near miss affect the risk register?

(A) It should be ignored, because no loss actually occurred

(B) It should be reported only to the insurer

(C) It should automatically make the risk critical

(D) It should prompt a review of frequency and control estimates

24. Which is the weakest basis for a frequency estimate?

(A) A sense that 'it has never happened here'

(B) Sector incident data from peers and CERTs

(C) Own near-miss records

(D) CERT advisories about active campaigns

25. Why read industry breach reports critically?

(A) They are always fabricated by security vendors for marketing purposes

(B) They only cover physical security

(C) They are written by regulators

(D) They often have sample bias and differing definitions

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 2 · QUANTIFY

Answer key

Knowledge checks

1. A A useful statement names how the event could succeed and what it would cost the business.

2. C Ordinal labels cannot be treated as measurements; products compress and can reverse rankings.

3. D Threat-based approaches begin with adversaries and techniques, then map controls and detection.

4. B Anchors reduce ambiguity and make scores comparable across assessors.

5. A Qualitative methods suit triage; money decisions and aggregation need quantification.

6. D Appetite is a governance decision for the board; others inform or test it.

7. C Avoidance removes the activity that creates the risk; the others are transfer, mitigation and acceptance.

8. B Appetite is the broad statement; tolerances are specific, measurable thresholds.

9. C Expiry forces review and stops temporary decisions becoming permanent.

10. D Insurance shares some financial consequences, with exclusions; accountability does not transfer.

11. A LEF combines how often threats act with how likely each attempt is to cause loss.

12. A Fines arise from reactions of external stakeholders and are classed as secondary.

13. C LEF = 10 × 0.2 = 2 events per year; 2 × 5 crore = 10 crore.

14. D Calibration aligns confidence with accuracy; it does not remove uncertainty.

15. B Single-point estimates hide spread; distributions show what a bad year looks like.

16. A Each draw simulates a year: number of events and loss per event.

17. D The current probability is above what the board accepts, so treatment is needed.

18. B (5 – 2) ÷ 2 = 1.5.

19. C Two controls often reduce the same events, so savings are not additive.

20. C Loss sizes are right-skewed; the lognormal captures many small and a few very large losses.

21. B Technique coverage shows where attacks are likely to succeed, informing susceptibility.

22. A SIM-swap is a common fraud technique for account takeover and payment theft.

23. D Near misses are evidence that the threat is active and controls may be weaker than assumed.

24. A Absence of past incidents in one organisation says little about future frequency, and may reflect poor detection.

25. D Reports draw on particular samples and definitions; adjust them for your context.

Scenarios & case studies

> **Scenario · A board asks for one number**
> **D** is best. Best. It is honest about the method's limits and gives the committee a money-based, probabilistic answer for the risks that drive exposure.

> **Scenario · Accept or mitigate?**
> **B** is best. Best. Compensating controls cut exposure cheaply, the acceptance is time-limited and the planned retirement removes the risk.

> **Scenario · A single number or a range?**
> **A** is best. Best. Ranges make uncertainty visible and support better decisions; giving the expected value and a tail percentile answers the CFO's need for simplicity.

> **Case study · Quantifying ransomware at a hospital network**
> Midpoints: TEF about 9.5, susceptibility about 10%, so LEF ≈ 0.95 events per year. Primary loss midpoint BDT 18 crore; secondary expected 0.3 × 30 = 9 crore; LM ≈ 27 crore; expected annual loss ≈ BDT 25.7 crore. The midpoint calculation hides the wide spread: a bad year could involve two events or the high end of losses, so the board should see a loss exceedance curve or a 90th to 95th percentile. A strong candidate is immutable, offline backups with tested EHR restoration plus network segmentation: segmentation reduces susceptibility, while backups reduce primary loss duration; both should be re-estimated and compared with cost.

Copyright © ZyeemZia

Scenario · Which investment first?

C is best. Best. The binding requirement is the tolerance on bad years; ROSI ranks options but does not override appetite.

Scenario · A near miss changes the estimate

A is best. Best. Near misses are valuable data about threat event frequency and control weaknesses.

Copyright © ZyeemZia

03

MODULE 3 · ARCHITECT

Security Architecture, Zero Trust, Cloud and OT

Design security into enterprise, cloud and industrial environments with traceable decisions

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Apply security architecture principles, patterns and decision records
- Plan and govern a phased zero trust programme
- Design segmentation, secure access and application security that fit delivery speed
- Govern multi-cloud and hybrid estates with landing zones and guardrails
- Protect OT, ICS and IoT environments where safety and availability come first

LESSONS

1. Security Architecture Principles and Reference Models · 30 min
2. Zero Trust: Principles, Components and Roadmap · 35 min
3. Segmentation, Secure Access and Application Security · 35 min
4. Cloud and Hybrid Security Governance · 35 min
5. OT, ICS and IoT Security · 40 min

MODULE 3 · ARCHITECT · LESSON 1 · 30 MIN

Security Architecture Principles and Reference Models

Designing security into the enterprise, not bolting it on afterwards

- Apply core security architecture principles to design decisions
- Use a layered, business-driven architecture approach to trace controls to business needs
- Record architecture decisions so they can be governed and revisited

Security architecture is the discipline of designing how security controls, technology and processes fit together across the enterprise so that business goals are met within risk appetite. Where governance sets direction, architecture translates it into structures that engineers can build: zones, trust boundaries, identity flows, data paths and patterns that teams can reuse. Good architecture makes the secure way the easy way.

Principles that stand the test of time

A1
Least privilege
Every user, service and device gets only the access it needs, for only as long as it needs it.

A2
Defence in depth
Layer independent controls so that one failure does not lead to compromise.

A3
Secure by default
Products and platforms ship with safe settings; insecure options must be deliberately enabled.

A4
Assume breach
Design so an attacker inside one zone cannot easily move to others, and detection is built in.

A5
Economy of mechanism
Prefer simple designs; complexity hides flaws and slows response.

A6
Separation of duties
No single person or service can complete a sensitive action alone.

A7
Fail securely
When a control fails it should deny rather than open access, unless safety requires otherwise.

A8
Traceability
Every control traces to a business requirement or risk, and every decision is recorded.

Business-driven architecture methods, such as the well-known SABSA approach, work top-down. They begin with what the business is trying to achieve and what it must protect, then move through conceptual, logical and physical design to the components and operations. The value is **traceability**: every firewall rule, identity policy or encryption setting can be traced back to a business attribute such as 'available', 'confidential' or 'compliant'.

Copyright © ZyeemZia

A layered, business-driven view

Contextual (business)	What the business does, its goals and obligations Business attributes such as available, private, auditable
Conceptual (architect)	Security principles, trust model, risk appetite Which attributes matter most for each service
Logical (designer)	Security services: identity, access, logging, encryption Zones, trust boundaries, data flows
Physical (builder)	Platforms, mechanisms, configurations Specific technologies and their settings
Component and operational	Products, standards, runbooks Monitoring, change and lifecycle management

PRO TIP · REFERENCE ARCHITECTURES SAVE TIME

A reference architecture is a reusable pattern for a common problem, such as 'internet-facing web application', 'partner API' or 'remote administration'. Each describes zones, controls, logging and acceptable variations. Teams that start from approved patterns move faster and pass review sooner than teams that design from scratch.

TEMPLATE **Architecture decision record (ADR)**

Capture a significant security architecture decision, its context and consequences, so that it can be reviewed, governed and revisited.

ADR #	DECISION	CONTEXT AND DRIVERS	OPTIONS CONSIDERED	CONSEQUENCES AND RESIDUAL RISK	OWNER	REVIEW DATE
ADR-014	*All admin access via a privileged access gateway with session recording*	*Audit finding on shared admin accounts; ransomware trend*	*Jump hosts; PAM gateway; cloud-native bastions*	*Extra latency for admins; licence cost; removes direct RDP/SSH*	*Head of infrastructure*	*Annual*

Running a security architecture review

1. **Understand the business need** What does the solution do, for whom, with what data and what availability?
2. **Classify** Data classification, criticality and regulatory scope.
3. **Model threats** Draw data flows and trust boundaries; identify threats using a structured method such as STRIDE.

Copyright © ZyeemZia

4. **Match patterns** Compare with reference architectures; note deviations.
5. **Agree controls** Required controls, compensating controls and residual risk.
6. **Record and approve** ADR, risk acceptance if needed, and conditions for go-live.

SCENARIO · DECIDE · ARCHITECTURE REVIEW OR RUBBER STAMP?

A bank's digital team plans to launch a new customer API in three weeks. The architecture review board meets monthly and has a backlog of 30 requests. Teams have started bypassing it. What is the BEST improvement?

(A) Make board approval mandatory and add penalties for bypassing it.

(B) Publish approved reference patterns and let teams that conform self-certify, reserving full board review for deviations and high-risk designs.

(C) Abolish the board and rely on penetration testing before launch.

(D) Let the digital team's lead developer approve their own designs.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Which three reference patterns would save the most review effort in your organisation next year? What would each one need to specify?

Key terms

Security architecture
The design of how security controls, technology and processes fit together across the enterprise to meet business goals within risk appetite.

Defence in depth
Using multiple independent layers of control so that a single failure does not lead to compromise.

Least privilege
Granting only the minimum access needed for the minimum time required.

Trust boundary
A point in a system where data or control passes between areas with different levels of trust.

Reference architecture
A reusable, approved design pattern for a common problem, including zones, controls and variations.

Architecture decision record
A short document capturing a significant decision, its context, options and consequences.

Threat modelling
A structured method to identify threats to a system by analysing its components, data flows and trust boundaries.

STRIDE
A threat modelling mnemonic: spoofing, tampering, repudiation, information disclosure, denial of service and elevation of privilege.

KNOWLEDGE CHECK

1. Which principle is applied when a payment approval needs two different people?

(A) Economy of mechanism, which keeps designs as simple as possible

(B) Secure by default

(C) Separation of duties

(D) Fail securely

Copyright © ZyeemZia

2. What is the main benefit of a business-driven, layered architecture method?

(A) It removes the need for any threat modelling at the logical layer
(B) Traceability from controls to business needs
(C) It selects products automatically
(D) It guarantees compliance with every regulation

3. An ADR is primarily used to:

(A) Approve the annual security budget for the architecture team
(B) Replace the risk register
(C) Document incident timelines
(D) Record a decision, its context and consequences

4. Which item belongs in a threat model?

(A) The vendor's market share and its most recent analyst rating
(B) Data flows and trust boundaries
(C) Staff holiday schedules
(D) The marketing launch plan

5. A firewall fails and starts allowing all traffic. Which principle has been violated?

(A) Least privilege
(B) Traceability of every control back to a business requirement
(C) Fail securely
(D) Economy of mechanism

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · ARCHITECT · LESSON 2 · 35 MIN

Zero Trust: Principles, Components and Roadmap

Replacing implicit trust in the network with continuous, policy-based decisions

- Explain zero trust tenets and the policy decision and enforcement model
- Assess maturity across identity, devices, networks, applications and data
- Build a realistic, phased zero trust roadmap

Traditional security trusted anything inside the corporate network. Remote work, cloud services, partners and ransomware broke that model: once an attacker is inside, a flat network lets them move freely. **Zero trust** is a strategy, not a product. It removes implicit trust based on network location and instead grants access per request, based on identity, device health, context and policy, with continuous monitoring. NIST's SP 800-207 is a widely used reference for the architecture.

Zero trust tenets (our summary)

- Treat every data source and computing service as a resource to protect
- Secure all communication regardless of network location
- Grant access to individual resources per session, with least privilege
- Decide access by dynamic policy using identity, device state, behaviour and environment
- Monitor and measure the security posture of all owned and associated assets
- Authenticate and authorise strictly and dynamically before access is allowed
- Collect information about assets, traffic and requests and use it to improve policy

The zero trust access decision

01 Subject — User, service or device requests a resource

→

02 Policy enforcement point — Intercepts the request; nothing passes by default

→

03 Policy engine — Evaluates identity, device posture, risk signals and policy

→

04 Policy administrator — Instructs the enforcement point to allow or deny the session

→

05 Resource — Access granted for this session only, and monitored

→

06 Feedback — Telemetry updates risk scores and future decisions

Zero trust maturity by pillar (based on widely used public models)

PILLAR	TRADITIONAL	ADVANCED	OPTIMAL
Identity	Passwords, some MFA	Phishing-resistant MFA, risk-based access	Continuous verification, identity analytics
Devices	Inventory incomplete	Posture checked at access	Real-time posture feeds every decision
Networks	Flat, perimeter-based	Macro-segmentation, encrypted traffic	Micro-segmented, application-level access
Applications and workloads	Accessible once on the network	Per-application access via proxies	Continuous authorisation, workload identity

Copyright © ZyeemZia

PILLAR	TRADITIONAL	ADVANCED	OPTIMAL
Data	Unclassified, perimeter-protected	Classified, labelled, encrypted	Dynamic data-level policy and rights management

INSIGHT · CROSS-CUTTING CAPABILITIES DECIDE SUCCESS

Public maturity models add three capabilities that cut across all pillars: **visibility and analytics**, **automation and orchestration**, and **governance**. Without them, zero trust becomes a collection of disconnected tools. Governance defines policy, ownership and exceptions; analytics provides the signals; automation enforces decisions consistently.

A phased zero trust roadmap

1. **Define protect surfaces** Identify the most critical data, applications, assets and services (DAAS) and their owners.
2. **Map transaction flows** Understand how users, services and data move around each protect surface.
3. **Strengthen identity** Phishing-resistant MFA, single sign-on and conditional access for priority users and admins.
4. **Know your devices** Inventory and posture checks; managed devices for privileged work.
5. **Replace broad network access** Move from VPN-to-everything to per-application access; segment critical zones.
6. **Protect data directly** Classify, encrypt and apply policy where data lives.
7. **Monitor and improve** Feed telemetry back into policy; measure maturity by pillar each year.

WATCH OUT · ZERO TRUST TRAPS

Buying a product labelled 'zero trust' without changing access policy; starting with the hardest legacy system; ignoring operational technology and service accounts; and declaring victory after rolling out MFA. Measure progress by how much implicit trust has actually been removed.

SCENARIO · DECIDE · WHERE TO START ZERO TRUST

A government-owned power generation company has a flat corporate network, VPN access for 900 staff and contractors to 'everything', and a newly connected plant historian. The board has funded a three-year zero trust programme. Which first step gives the MOST value?

(A) Replace every firewall with a new platform branded as zero trust.

(B) Begin by micro-segmenting every workload in the data centre.

(C) Identify protect surfaces and their flows, then put phishing-resistant MFA and per-application access in front of the most critical ones, starting with administrators and contractors.

(D) Wait until all legacy systems are retired before starting.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Zero trust maturity tracker**

Record current and target maturity per pillar with the next concrete step and owner.

PILLAR	CURRENT STAGE	TARGET (12 MONTHS)	NEXT STEP	OWNER	EVIDENCE OF PROGRESS
Identity	*Initial: MFA for email only*	*Advanced: phishing-resistant MFA for admins and contractors*	*Roll out security keys to 120 admins*	*Head of IAM*	*Percentage of privileged logins using phishing-resistant MFA*

Copyright © ZyeemZia

PILLAR	CURRENT STAGE	TARGET (12 MONTHS)	NEXT STEP	OWNER	EVIDENCE OF PROGRESS
Networks	*Traditional: flat network*	*Initial: critical zones segmented*	*Segment plant historian and finance systems*	*Network architect*	*Number of zones with deny-by-default rules*

REFLECT

Where does your organisation still grant trust simply because a device is 'on the network'? List three examples and the zero trust control that would replace each.

Key terms

Zero trust
A security strategy that removes implicit trust based on network location and grants access per request based on policy and context.

Implicit trust
Access granted simply because a user or device is inside a network or zone, without verification.

Policy decision point
The logical component, made up of the policy engine and policy administrator, that decides whether a session is allowed.

Policy enforcement point
The component that intercepts requests and allows or blocks sessions according to the decision.

Protect surface
The small set of critical data, applications, assets and services that a zero trust programme protects first.

Device posture
The security state of a device, such as patch level, encryption and endpoint protection, used in access decisions.

Conditional access
Access policy that considers conditions such as user risk, device state and location before granting access.

KNOWLEDGE CHECK

6. What does zero trust remove?

(A) Trust based only on network location

(B) All authentication requirements for users already inside the corporate network

(C) The need for logging

(D) The use of encryption

Copyright © ZyeemZia

7. Which component evaluates identity, posture and policy to decide on access?

   (A) Policy enforcement point sitting in front of each resource
   (B) Resource
   (C) Subject
   (D) Policy engine

8. Which is the best early zero trust step for most organisations?

   (A) Micro-segmenting every workload in all data centres in the first quarter
   (B) Phishing-resistant MFA for administrators
   (C) Buying a new firewall
   (D) Removing all logging

9. What is a protect surface?

   (A) The external attack surface visible from the internet, including every exposed port
   (B) A physical barrier
   (C) The critical data, applications, assets and services protected first
   (D) A type of firewall rule

10. Why are cross-cutting capabilities such as analytics and governance vital?

    (A) They connect pillars into consistent, enforced policy
    (B) They allow each pillar to be bought from a separate vendor without integration
    (C) They are only needed for audits
    (D) They replace identity controls

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · ARCHITECT · LESSON 3 · 35 MIN

Segmentation, Secure Access and Application Security

Limiting blast radius and building security into how software is delivered

- Design segmentation that limits the spread of attacks without breaking the business
- Compare secure access models including VPN, SSE and SASE
- Govern application and API security through a secure development lifecycle

Ransomware incidents show the same pattern repeatedly: an attacker gains one foothold and then moves sideways across a flat network to domain controllers, backups and every server. **Segmentation** limits that blast radius. At the same time, applications and APIs have become the main way customers and partners reach organisations, so **application security** must be built into delivery rather than tested at the end.

Segmentation approaches

Macro-segmentation

- Zones by function or trust: users, servers, OT, guest, management
- Enforced by firewalls or virtual routing
- Quick to start, coarse

Micro-segmentation

- Policy per workload or application tier
- Enforced by host agents, hypervisor or cloud security groups
- Fine-grained, needs good flow data

Identity-based segmentation

- Access defined by who or what is connecting
- Policy follows the user or workload
- Fits zero trust and hybrid environments

Segmenting without breaking the business

1. **Discover flows** Collect real traffic data for weeks, not assumptions from diagrams.
2. **Group assets** Group by application and sensitivity; identify crown jewels and management planes.
3. **Design policy** Write allow rules for needed flows; deny everything else between groups.
4. **Monitor mode** Run rules in alert-only mode to find missed dependencies.
5. **Enforce gradually** Enforce zone by zone, starting with the most critical.
6. **Maintain** Tie rule changes to change management and review them regularly.

Remote and branch access models

Traditional VPN

- Connects the device to the network
- Broad access once connected
- Central backhaul of traffic
- Familiar and cheap but conflicts with zero trust

Security service edge (SSE)

- Cloud-delivered secure web gateway, cloud access security broker and zero trust network access
- Per-application access
- Inspects traffic close to the user

SASE

- SSE combined with software-defined WAN
- Networking and security policy from one cloud-delivered service
- Fits branch-heavy, cloud-first organisations

Copyright © ZyeemZia

A secure development lifecycle

01 Requirements — Security and privacy requirements, abuse cases → **02 Design** — Threat modelling and approved patterns → **03 Build** — Secure coding, secrets scanning, dependency checks → **04 Test** — Static and dynamic testing, API testing → **05 Release** — Signed builds, change approval, configuration checks → **06 Operate** — Runtime protection, logging, vulnerability response

API security essentials

RISK	EXAMPLE	CONTROL
Broken object-level authorisation	Changing an account ID in a request returns another customer's data	Check authorisation on every object, server side
Weak authentication	API keys embedded in a mobile app	Short-lived tokens, mutual TLS for partners
Excessive data exposure	API returns full records and the app filters them	Return only needed fields
No rate limiting	Credential stuffing at thousands of attempts per minute	Rate limits, bot detection
Shadow APIs	Old API versions still live and unmonitored	API inventory and gateway enforcement

EXAMPLE · BROKEN AUTHORISATION AT SCALE

A regional e-commerce platform exposed an order-tracking API that returned any order when given its number. Order numbers were sequential. A researcher enumerated hundreds of thousands of orders with names, phone numbers and addresses in a few hours. The fix was simple: check that the authenticated customer owns the order. The governance lesson was harder: no API inventory, no threat model and no security testing in the release process.

SCENARIO · DECIDE · FUNDING APPLICATION SECURITY

A fintech releases code 40 times a week. Its only application security control is an annual penetration test, which last found 23 high-severity issues, many repeats. The CTO resists 'slowing developers down'. What should the CISO propose?

(A) Require a manual security sign-off before every release.

(B) Increase penetration testing to twice a year.

(C) Accept the risk because releases are frequent and bugs can be fixed quickly.

(D) Build automated security checks into the pipeline, provide secure-by-default libraries and train security champions in each squad, measuring repeat findings and fix times.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

Application security governance checklist

☐ Maintain an inventory of applications and APIs with owners and data classification
☐ Require threat models for new high-risk systems and major changes
☐ Run automated code, dependency and secrets scanning in every pipeline
☐ Define release gates for critical findings with an exception route
☐ Track mean time to fix by severity and repeat-finding rates
☐ Appoint and support security champions in delivery teams
☐ Test APIs explicitly, including authorisation on every object

REFLECT

If an attacker compromised one ordinary laptop in your organisation today, what could they reach within an hour? What segmentation change would shrink that most?

Key terms

Segmentation
Dividing networks or systems into zones with controlled communication to limit the spread of attacks.

Blast radius
The extent of damage an attacker or failure can cause from a single point of compromise.

SASE
Secure access service edge: the convergence of SSE security services with software-defined WAN networking.

Security champion
A developer or engineer in a delivery team who promotes and supports secure practices.

Micro-segmentation
Fine-grained segmentation that applies policy at the level of individual workloads or application tiers.

Security service edge
A cloud-delivered set of security services such as secure web gateway, CASB and zero trust network access.

Secure development lifecycle
A software process that builds security activities into every phase from requirements to operation.

Broken object-level authorisation
An API flaw where a user can access objects they do not own by changing identifiers in requests.

KNOWLEDGE CHECK

11. What is the first step in segmenting an existing network safely?

(A) Block all traffic between zones on day one and fix complaints as they arrive
(B) Buy micro-segmentation agents
(C) Discover actual traffic flows
(D) Rename the VLANs

12. What does SASE add to SSE?

(A) A traditional VPN concentrator located in the head-office data centre
(B) Software-defined WAN networking
(C) On-premises tape backup
(D) Physical access control

Copyright © ZyeemZia

13. An API returns another customer's record when an ID is changed. What is this?

(A) Broken object-level authorisation
(B) Excessive rate limiting applied too aggressively to legitimate users
(C) Denial of service
(D) A strong token design

14. Which control best prevents secrets being committed to code repositories?

(A) An annual penetration test of the production website by an external firm
(B) A longer password policy
(C) A new firewall rule
(D) Automated secrets scanning in the pipeline

15. Why run new segmentation rules in monitor mode first?

(A) To make the rules permanent without approval
(B) Because monitor mode blocks more traffic than enforcement mode
(C) To find missed dependencies before enforcement
(D) To avoid logging

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · ARCHITECT · LESSON 4 · 35 MIN

Cloud and Hybrid Security Governance

Shared responsibility, landing zones and guardrails across many clouds

- Apply the shared responsibility model to IaaS, PaaS and SaaS
- Design landing zones and preventive and detective guardrails
- Govern multi-cloud and hybrid estates, including data residency and cost-security trade-offs

Cloud changes who does what. A provider secures the infrastructure it runs; the customer remains responsible for how it configures and uses the service. Most cloud breaches are not caused by provider failures but by customer misconfiguration, exposed keys and over-permissive identities. **Cloud security governance** sets the rules, structures and automated guardrails that let teams move quickly while staying within policy.

Shared responsibility by service model

LAYER	IAAS	PAAS	SAAS
Data and its classification	Customer	Customer	Customer
Identities and access	Customer	Customer	Customer
Application	Customer	Customer	Provider
Operating system and runtime	Customer	Provider	Provider
Virtual network controls	Customer	Shared	Provider
Physical hosts, network, data centre	Provider	Provider	Provider

WATCH OUT · THE CUSTOMER ALWAYS OWNS DATA AND IDENTITY

Whatever the service model, the customer decides who has access and how data is classified, shared and retained. A SaaS provider cannot stop an administrator from sharing a folder publicly or from granting a third-party app access to every mailbox.

A governed landing zone

Organisation and governance	`Account or subscription hierarchy` `Policy inheritance` `Billing and tagging standards`
Identity	`Central identity provider and SSO` `Role-based access, no long-lived keys` `Break-glass accounts`
Network	`Hub-and-spoke or transit design` `Private connectivity to on-premises` `Central egress inspection`
Security services	`Central logging account` `Cloud security posture management` `Key management`
Workload accounts	`Separate accounts per application and environment` `Pre-approved patterns via infrastructure as code`

Copyright © ZyeemZia

Guardrails

Preventive

- Policies that block risky actions, such as public storage or unapproved regions
- Enforced at organisation level
- Strong but must allow approved exceptions

Detective

- Posture scanning and alerts for drift
- Cloud security posture management and CNAPP tools
- Feed findings to owners with SLAs

Corrective

- Automatic remediation of known-bad settings
- Use carefully for low-risk fixes
- Keeps estate clean at scale

Policy as code: deny public storage (generic example)

Policy engine (Rego-style)

```
package cloud.storage
# Deny any storage bucket that allows public read
deny[msg] {
  bucket := input.resources[_]
  bucket.type == "storage_bucket"
  bucket.acl == "public-read"
  msg := sprintf("Bucket %s must not be public", [bucket.name])
}
```

Policy as code lets the same rule be tested in pipelines before deployment and checked continuously afterwards. The syntax shown is illustrative of declarative policy languages.

Governance decisions for multi-cloud and hybrid

DECISION	OPTIONS	GOVERNANCE CONSIDERATION
Which clouds for what	Primary cloud plus specialised; true multi-cloud	Skills, tooling and logging multiply with each provider
Data residency	In-country region, regional, global	Sector rules, contracts and law enforcement access
Identity	One identity provider federated to all clouds	Avoid separate admin identities per cloud
Logging	Central log platform across clouds and on-premises	Retention, cost and investigation needs
Exit and concentration	Portability patterns, exit plans	Regulators increasingly expect credible exit strategies

Copyright © ZyeemZia

SCENARIO · DECIDE · SHADOW CLOUD AT A UNIVERSITY

A Dhaka university discovers 37 cloud accounts opened on personal cards by research groups, several storing student data, none connected to central logging. The registrar wants them all closed immediately. What should the CISO recommend?

(A) Offer a governed landing zone with central billing, SSO and logging, migrate accounts into it with a deadline, and close any that hold sensitive data without an owner.

(B) Close all 37 accounts today without notice.

(C) Leave them alone because research needs freedom.

(D) Ask each group to complete a 60-question security questionnaire every year.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Cloud guardrail register**

List the guardrails that apply across cloud accounts, how they are enforced and how exceptions work.

GUARDRAIL	TYPE	SCOPE	ENFORCEMENT MECHANISM	EXCEPTION PROCESS	OWNER
No public storage buckets	*Preventive*	*All accounts*	*Organisation-level policy plus pipeline check*	*CISO approval for public websites only*	*Cloud platform team*
Logs to central account for 400 days	*Preventive and detective*	*All production accounts*	*Policy plus daily posture scan*	*None*	*Security operations*

REFLECT

Which cloud services in your organisation are outside central identity and logging today? What would it take to bring the riskiest one in?

Copyright © ZyeemZia

Key terms

Shared responsibility model
The division of security duties between cloud provider and customer, which varies by service model.

Guardrail
An automated policy that prevents, detects or corrects actions outside agreed security rules.

CSPM
Cloud security posture management: tools that continuously check cloud configurations against policy.

Data residency
Requirements about the geographic location where data is stored and processed.

Landing zone
A pre-configured, governed cloud environment with identity, network, logging and policy foundations for workloads.

Policy as code
Expressing security and compliance rules in machine-readable code that can be tested and enforced automatically.

CNAPP
Cloud-native application protection platform: combined posture, workload and identity protection for cloud applications.

Shadow IT
Technology services used without the knowledge or approval of the organisation's IT and security functions.

KNOWLEDGE CHECK

16. In a SaaS service, who is responsible for deciding who can access customer data?

(A) The provider, because it runs the application and all of its infrastructure
(B) The customer
(C) The internet service provider
(D) Nobody, as it is automatic

17. Which is a preventive guardrail?

(A) An organisation policy blocking unapproved regions
(B) A weekly report of misconfigured storage sent to application owners for review
(C) A post-incident review
(D) An annual audit

18. Why use separate cloud accounts per application and environment?

(A) To increase the number of invoices the finance team must reconcile each month
(B) To avoid logging
(C) Because providers require it
(D) To limit blast radius and simplify access control

19. What is the main advantage of policy as code?

(A) It removes the need for any human approval of exceptions or policy changes
(B) It replaces encryption
(C) It makes cloud services free
(D) Rules can be tested and enforced automatically

20. What is the most common cause of cloud data breaches?

(A) Physical theft of disks from the provider's data centres by insiders
(B) Undersea cable cuts
(C) Customer misconfiguration and weak identity control
(D) Provider bankruptcy

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · ARCHITECT · LESSON 5 · 40 MIN

OT, ICS and IoT Security

Protecting physical processes where safety and availability come first

- Explain how OT security priorities differ from IT and why safety comes first
- Apply zones, conduits and security levels to an industrial site
- Govern IoT devices across their lifecycle

Operational technology (OT) monitors and controls physical processes: turbines in a power plant, pumps in a water utility, conveyors in a garment factory, chillers in a hospital. **Industrial control systems (ICS)** such as PLCs, SCADA and distributed control systems are part of OT. Attacks here can stop production, damage equipment, harm the environment and endanger lives. That changes priorities: in OT, **safety and availability** usually come before confidentiality.

IT and OT priorities

Typical IT

- Confidentiality, integrity, availability
- Patch monthly or faster
- Devices replaced every 3 to 5 years
- Rebooting is routine
- Active scanning is normal

Typical OT

- Safety, availability, integrity, then confidentiality
- Patching needs vendor approval and outage windows
- Equipment lasts 15 to 30 years
- Unplanned reboot may stop a process
- Active scanning can crash fragile devices

A reference model of industrial levels (Purdue-style)

Levels 4 and 5: Enterprise	`Business systems, email, ERP`	`Internet access`
Level 3.5: Industrial DMZ	`Brokers data between IT and OT`	`No direct traffic crosses it`
Level 3: Site operations	`Historians, engineering workstations, patch servers`	
Level 2: Supervisory control	`HMI and SCADA servers that operators use`	
Level 1: Basic control	`PLCs, controllers, safety instrumented systems`	
Level 0: Physical process	`Sensors, actuators, motors, valves`	

DEFINITION · ZONES AND CONDUITS

The international IEC 62443 series groups assets with similar security needs into **zones** and defines the communication paths between them as **conduits**. Each zone gets a target **security level** describing the attacker it must resist, from casual misuse (SL1) to sophisticated attackers with extensive resources (SL4). Conduits carry controls such as firewalls, data diodes or brokers.

Copyright © ZyeemZia

Security levels in plain words

LEVEL	PROTECTS AGAINST
SL1	Casual or accidental violation
SL2	Intentional attack using simple means, low resources and generic skills
SL3	Intentional attack using sophisticated means, moderate resources and system-specific skills
SL4	Intentional attack using sophisticated means, extended resources and high motivation

Starting an OT security programme

1. **Get leadership and engineering together** Make plant managers and safety engineers co-owners, not just IT.
2. **Build an asset inventory passively** Use passive network monitoring and engineering records; avoid aggressive scanning.
3. **Map zones and conduits** Group assets, document all connections including vendor remote access.
4. **Close the riskiest paths** Remove direct IT-to-OT routes, control remote access through a monitored broker with MFA.
5. **Back up and plan recovery** Offline backups of controller logic and configurations; tested restoration.
6. **Monitor** OT-aware detection of unusual commands and new devices.
7. **Patch and harden by risk** Coordinate with vendors; use compensating controls where patching is impossible.

CASE STUDY · RANSOMWARE REACHES THE FACTORY FLOOR

A knit-composite garment group near Narayanganj runs dyeing and finishing machines controlled by PLCs and HMI workstations. HMIs run an old desktop operating system and connect to the corporate network so production data can feed the ERP. Ransomware encrypts the corporate file servers and then the HMIs. Machines stop mid-batch, ruining a large export order with a buyer deadline.

1. Which architecture weakness allowed the spread to production?

2. What immediate recovery priorities should the incident lead set?

3. What three governance changes would you make after recovery?

Model answer: module answer key.

IoT device governance

LIFECYCLE STAGE	KEY QUESTION	CONTROL
Procure	Does the product meet a security baseline?	No universal default passwords, update support period, vulnerability disclosure policy
Onboard	Is it known and isolated?	Inventory, unique credentials, dedicated network segment

Copyright © ZyeemZia

LIFECYCLE STAGE	KEY QUESTION	CONTROL
Operate	Is it behaving normally and patched?	Monitoring, update process, certificate management
Retire	Is data removed and access revoked?	Secure wipe, credential revocation, inventory update

SCENARIO · DECIDE · THE VENDOR WANTS PERMANENT REMOTE ACCESS

A hospital's new MRI scanner vendor asks for a permanent always-on VPN into the clinical network for 'predictive maintenance'. The biomedical engineering team supports it. What should the CISO require?

(A) Approve the VPN because the vendor is reputable.

(B) Refuse any remote access.

(C) Allow the VPN but require the vendor to sign an annual security statement.

(D) Brokered remote access to the device segment only, with MFA, session approval and recording, written into the support contract.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Who in your organisation would make the decision to shut down a production or clinical system during a cyber incident? Is that decision documented and practised?

Key terms

Operational technology
Hardware and software that monitors and controls physical devices and processes.

Industrial control system
Systems such as PLCs, SCADA and distributed control systems used to operate industrial processes.

PLC
Programmable logic controller: a ruggedised computer that controls machinery and processes.

HMI
Human-machine interface: the screens and software operators use to monitor and control a process.

Industrial DMZ
A buffer zone between enterprise and control networks where data is brokered so no traffic passes directly.

Zone and conduit
Grouping of assets with similar security needs (zone) and the controlled communication path between groups (conduit).

Security level
In IEC 62443, the target strength of protection for a zone, from SL1 to SL4.

Safety instrumented system
An independent control system that brings a process to a safe state when dangerous conditions arise.

KNOWLEDGE CHECK

Copyright © ZyeemZia

21. Which priority usually comes first in OT security?

(A) Confidentiality of production data shared with buyers and partners
(B) Safety
(C) Speed of patching
(D) Cost reduction

22. Why is aggressive active scanning risky in OT networks?

(A) Fragile devices can crash and stop processes
(B) Scanning tools are illegal to use inside industrial plants in most countries
(C) It is slower than passive monitoring
(D) It requires internet access

23. What is the role of an industrial DMZ?

(A) Host the safety instrumented system so that it can be reached from the internet
(B) Store all email
(C) Broker data between IT and OT without direct traffic
(D) Replace the PLCs

24. A zone must resist sophisticated attackers with moderate resources. Which target security level fits?

(A) SL3
(B) SL1, because it is the baseline level that every zone receives
(C) SL2
(D) SL0

25. Which IoT procurement requirement best reduces mass compromise?

(A) The device must use the same password across all units for easier maintenance
(B) No universal default passwords
(C) Bright status lights
(D) A long warranty

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 3 · ARCHITECT

Answer key

Knowledge checks

1. C Requiring two people prevents one person completing a sensitive action alone.

2. B Layered methods connect technical controls to business attributes and requirements.

3. D ADRs keep the reasoning behind decisions so they can be governed and revisited.

4. B Threat modelling analyses how data moves and where trust changes.

5. C A failing control should default to denying access unless safety requires otherwise.

6. A Zero trust removes implicit trust from location and replaces it with policy-based decisions.

7. D The policy engine decides; the administrator instructs the enforcement point to act.

8. B Strong identity for the most privileged users removes major risk quickly.

9. C A protect surface is small and critical, unlike the broad attack surface.

10. A Without visibility, automation and governance, tools stay disconnected.

11. C Without real flow data, policies break business processes.

12. B SASE combines cloud-delivered security (SSE) with SD-WAN networking.

13. A The server fails to check that the requester owns the object.

14. D Scanning in the pipeline catches secrets before they are merged or deployed.

15. C Monitor mode reveals legitimate flows that would otherwise be blocked.

16. B Identity and data access remain customer responsibilities in every service model.

17. A Preventive guardrails stop the action before it happens.

18. D Account separation is a strong isolation boundary and clarifies ownership.

19. D Code-based policy is consistent, testable and automatable.

20. C Most incidents stem from how customers configure and grant access to services.

21. B Physical processes can harm people and equipment, so safety leads.

22. A Many controllers were not designed to handle unexpected traffic.

23. C The DMZ prevents direct connections across the IT-OT boundary.

24. A SL3 addresses sophisticated means with moderate resources and system-specific skills.

25. B Shared default credentials are a common cause of mass IoT compromise.

Scenarios & case studies

> **Scenario · Architecture review or rubber stamp?**
> **B** is best. Best. Patterns scale good design, reduce the queue and keep expert attention on the riskiest cases.

> **Scenario · Where to start zero trust**
> **C** is best. Best. It focuses limited effort on the highest-value assets and the riskiest identities, and removes the broadest implicit trust first.

> **Scenario · Funding application security**
> **D** is best. Best. Automation and enablement fit the release speed, prevent repeat issues and address the CTO's concern by keeping the secure path fast.

> **Scenario · Shadow cloud at a university**
> **A** is best. Best. It removes the risk while giving researchers a faster legitimate path, which stops shadow cloud recurring.

Copyright © ZyeemZia

Case study · Ransomware reaches the factory floor

The weakness was direct connectivity between corporate and production networks with no industrial DMZ, plus unsupported HMIs. Immediate priorities are safety checks on stopped processes, isolating OT from IT, restoring HMIs from known-good images and PLC logic backups, and communicating with buyers about the delayed order. Governance changes: make production leadership co-owner of OT risk; require an industrial DMZ with brokered data transfer and controlled vendor access; and fund an OT asset inventory, offline backups and a lifecycle plan for unsupported HMIs.

Scenario · The vendor wants permanent remote access

D is best. Best. It meets the vendor's legitimate need while removing broad, unmonitored access to the clinical network.

Copyright © ZyeemZia

04

MODULE 4 · PROTECT

Identity, Data Protection and Privacy

Govern who can access what, and protect data and personal information throughout its life

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Run identity governance with effective lifecycle, access models and certifications
- Control privileged access and govern non-human identities with phishing-resistant authentication
- Classify and protect data proportionately across its lifecycle
- Govern cryptography, key management and the move to post-quantum algorithms
- Apply data protection principles, DPIAs and breach notification duties

LESSONS

1. Identity Governance and Administration · 35 min
2. Privileged Access, Strong Authentication and Non-Human Identities · 35 min
3. Data Governance, Classification and Loss Prevention · 30 min
4. Cryptography and Key Management Governance · 35 min
5. Privacy Engineering and Data Protection · 35 min

MODULE 4 · PROTECT · LESSON 1 · 35 MIN

Identity Governance and Administration

Making sure the right people have the right access, and can prove it

- Design joiner, mover and leaver processes driven by authoritative sources
- Choose between role-based, attribute-based and policy-based access models
- Run access certifications and segregation-of-duties controls that actually reduce risk

Identity has become the main security perimeter. Attackers increasingly log in rather than break in, using stolen credentials, abused tokens and forgotten accounts. **Identity governance and administration (IGA)** is the set of processes and tools that decide who should have access to what, grant and remove it on time, and prove to auditors that access is appropriate. It is where security, HR, business owners and audit meet.

The identity lifecycle

01 Joiner — HR record triggers account creation with birthright access

→

02 Request — Additional access requested and approved by the owner

→

03 Mover — Role change removes old access and grants new

→

04 Review — Owners certify access periodically

→

05 Leaver — Accounts disabled on the last day, then removed

→

06 Audit — Evidence of each step retained

WATCH OUT · THE MOVER PROBLEM

Most organisations handle joiners and leavers reasonably well. **Movers** are the silent risk: people change roles and keep old access, accumulating privileges over years. A branch officer promoted to head office who still has teller rights can create and approve transactions. Mover processes must remove before they add.

Access models

Role-based (RBAC)

- Access bundled into roles matching jobs
- Easy to review and explain
- Role explosion if roles are too fine-grained

Attribute-based (ABAC)

- Decisions use attributes of user, resource and context
- Fine-grained and dynamic
- Harder to review; needs clean attribute data

Policy-based (PBAC)

- Central, readable policies evaluated at run time
- Combines roles and attributes
- Needs a policy engine and strong governance of policy changes

Segregation of duties examples

PROCESS	CONFLICTING DUTIES	WHY THEY CONFLICT
Payments	Create vendor and approve payment to vendor	One person could pay a fake supplier
Payroll	Change salary data and approve payroll run	One person could raise their own pay
IT change	Develop code and deploy to production unreviewed	Malicious or faulty code could go live unchecked
Security	Administer logs and administer the systems being logged	Activity could be hidden

Copyright © ZyeemZia

PROCESS	CONFLICTING DUTIES	WHY THEY CONFLICT
Mobile money	Reset customer PIN and approve high-value transfers	Account takeover and theft by one insider

An access certification that is not a rubber stamp

1. **Scope by risk** Review privileged, sensitive and SoD-relevant access more often; low-risk access less often.
2. **Give context** Show reviewers what each entitlement means in plain words, last use date and peer comparison.
3. **Ask the right person** The resource owner or manager who understands the need, not IT.
4. **Make revocation easy** One click to remove; automatic fulfilment within days.
5. **Detect rubber-stamping** Flag reviewers who approve everything in seconds.
6. **Close the loop** Confirm removals happened and report outcomes to the risk committee.

TEMPLATE Access review record

Document a periodic review of access for one application so decisions and removals are evidenced.

APPLICATION	USER	ENTITLEMENT (PLAIN WORDS)	LAST USED	REVIEWER DECISION	REASON	REMOVAL CONFIRMED
Core banking	*R. Hossain*	*Approve transfers above BDT 10 lakh*	*112 days ago*	*Revoke*	*Moved to compliance team*	*Yes, ticket 4471*
Core banking	*S. Akter*	*Create beneficiary*	*2 days ago*	*Keep*	*Current operations role*	*Not applicable*

Copyright © ZyeemZia

SCENARIO · DECIDE · RUBBER-STAMP REVIEWS

An insurance company's quarterly access reviews show a 99.6% approval rate. Internal audit finds 41 leavers still active and 12 users with conflicting payment rights. Managers say the reviews are 'too long to read'. What should the IAM lead change FIRST?

(A) Require managers to sign a declaration that they read every line.

(B) Fix leaver automation from HR, then redesign reviews to focus on high-risk access with plain-language entitlements, usage data and SoD flags.

(C) Move reviews from quarterly to monthly.

(D) Let the IAM team approve all access centrally instead of managers.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Pick one person who has changed roles in your organisation in the last two years. Would you be confident that their old access was removed? How would you prove it?

Key terms

Identity governance and administration
Processes and tools that manage the identity lifecycle, access requests, reviews and evidence of appropriate access.

Authoritative source
The trusted system, usually HR, that triggers identity lifecycle events.

RBAC
Role-based access control: access granted through roles that match job functions.

Segregation of duties
Splitting conflicting tasks between different people so one person cannot complete a sensitive process alone.

Joiner-mover-leaver
The lifecycle events of starting, changing role and leaving that should drive access changes.

Birthright access
Access granted automatically to everyone in a role on day one.

ABAC
Attribute-based access control: access decided from attributes of the user, resource and context.

Access certification
A periodic review in which owners confirm or revoke users' access.

KNOWLEDGE CHECK

1. Which lifecycle event most often causes privilege accumulation?
   (A) Joiner, because new staff often receive access before training is complete
   (B) Leaver
   (C) Password reset
   (D) Mover
2. What should trigger account disablement for a departing employee?
   (A) A request from a colleague in the same team
   (B) The HR record of the leaving date
   (C) The next quarterly access review
   (D) The employee's own email

Copyright © ZyeemZia

3. A reviewer approves 600 entitlements in four minutes. What does this indicate?

   (A) Rubber-stamping that the process should flag
   (B) A highly efficient review
   (C) That all access is appropriate
   (D) A need for more entitlements

4. Which pair of duties creates a segregation-of-duties conflict?

   (A) Reading a report and printing it
   (B) Logging in and changing one's own password
   (C) Viewing a dashboard and exporting a chart
   (D) Creating a vendor and approving payments to it

5. What is a common drawback of very fine-grained RBAC?

   (A) It cannot be reviewed at all
   (B) It ignores job functions
   (C) Role explosion that makes roles hard to manage
   (D) It requires no identity data

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · PROTECT · LESSON 2 · 35 MIN

Privileged Access, Strong Authentication and Non-Human Identities

Protecting the keys to the kingdom, for people and machines alike

- Design privileged access management with just-in-time and session controls
- Choose authentication strength by risk, favouring phishing-resistant methods
- Govern service accounts, API keys, tokens and other non-human identities

In almost every serious breach, attackers seek **privileged access**: domain administrator, cloud root, database owner or backup administrator rights. With them, they can disable defences, encrypt everything and erase evidence. **Privileged access management (PAM)** reduces the number of privileged accounts, limits when they can be used, controls how sessions happen and records what is done.

Privileged access principles

P1
Minimise standing privilege
Few or no permanent admin rights; elevate only when needed.

P2
Just in time
Grant privilege for a task and a time window, then remove it automatically.

P3
Separate admin identities
Use dedicated admin accounts that never read email or browse the web.

P4
Secure admin workstations
Perform privileged work from hardened, managed devices.

P5
Vault and rotate
Store shared and service credentials in a vault and rotate them automatically.

P6
Record and review
Record privileged sessions and review high-risk activity.

P7
Break glass
Keep emergency accounts with strong protection, monitoring and tested procedures.

Authentication strength (from weakest to strongest)

METHOD	RESISTS PASSWORD REUSE	RESISTS PHISHING	NOTES
Password only	No	No	Unacceptable for remote or privileged access
SMS one-time code	Yes	No	Vulnerable to SIM-swap and real-time phishing
Authenticator app code	Yes	No	Can be relayed by phishing proxies
Push approval with number matching	Yes	Partly	Reduces fatigue attacks; still phishable in some flows

Copyright © ZyeemZia

METHOD	RESISTS PASSWORD REUSE	RESISTS PHISHING	NOTES
Passkeys or FIDO2 security keys	Yes	Yes	Bound to the real site; phishing-resistant
Certificate or smart card	Yes	Yes	Strong; heavier to manage

INSIGHT · PHISHING-RESISTANT MFA IS THE NEW BASELINE FOR ADMINS

Real-time phishing kits can relay one-time codes and push approvals to attackers. Methods that cryptographically bind authentication to the genuine website, such as FIDO2 security keys and passkeys, defeat these attacks. Make them mandatory for administrators, finance approvers and executives first.

Non-human identities (NHIs) include service accounts, application credentials, API keys, cloud workload roles, bots and certificates. In many organisations they outnumber human identities many times over. They often have broad privileges, never expire, are shared between systems and have no clear owner. Stolen tokens and keys from code repositories and CI/CD systems are now a leading way into cloud environments.

Governing non-human identities

PROBLEM	CONTROL
No inventory	Discover NHIs across directories, clouds, code and pipelines; record owner and purpose
Long-lived secrets	Prefer short-lived tokens and workload identity federation; rotate what remains
Hard-coded keys	Secrets scanning; vault retrieval at run time
Excess permissions	Least-privilege roles based on observed usage
Orphaned accounts	Owner required at creation; disable when owner leaves or system retires
Invisible misuse	Baseline normal behaviour and alert on anomalies such as new locations or APIs

SCENARIO · DECIDE · DOMAIN ADMIN SPRAWL

A Dhaka garment group discovers 64 accounts with domain administrator rights, including former contractors and three service accounts with passwords unchanged since 2017. Ransomware groups are targeting its sector. What is the BEST first action?

(A) Buy a PAM product and plan a two-year rollout before changing anything.

(B) Change all 64 passwords and keep the accounts.

(C) Reduce domain admins to a small named group with separate admin accounts and phishing-resistant MFA, vault and rotate service account credentials, and disable orphaned accounts.

(D) Require admins to sign the acceptable-use policy again.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

Privileged access quick wins

☐ Count and justify every account with domain, cloud root or database owner rights
☐ Create separate admin accounts with no email or internet access
☐ Enforce phishing-resistant MFA on all privileged access
☐ Vault and rotate shared and service credentials
☐ Remove local administrator rights from standard user devices
☐ Monitor and alert on privileged group membership changes
☐ Test break-glass accounts and their alerting quarterly

REFLECT

How many non-human identities exist in your environment, and who owns them? If you cannot answer, what would be the first source you would query?

Key terms

Privileged access management
Controls and tools that minimise, broker, monitor and record the use of high-level privileges.

Just-in-time access
Granting elevated access only for a specific task and time window, then removing it automatically.

Phishing-resistant MFA
Authentication, such as FIDO2 keys or passkeys, that cannot be relayed by a fake website.

Non-human identity
An identity used by software rather than a person, such as a service account, API key or workload role.

Standing privilege
Privileged rights that remain permanently assigned whether or not they are being used.

Break-glass account
An emergency account used only when normal access fails, protected and monitored closely.

Passkey
A FIDO-based credential stored on a device or synced securely that replaces passwords and resists phishing.

Secrets vault
A secured system that stores, issues and rotates credentials and keys for people and applications.

KNOWLEDGE CHECK

6. Which authentication method is phishing-resistant?

(A) SMS one-time code sent to the user's registered mobile number
(B) Authenticator app code
(C) Security questions
(D) FIDO2 security key

7. What does just-in-time access reduce?

(A) The number of users in the organisation
(B) The need for logging
(C) Standing privilege
(D) Encryption overhead

Copyright © ZyeemZia

8. Why should administrators use separate admin accounts?

   (A) So privileged credentials are not exposed through email or browsing
   (B) Because licensing rules require a separate account for every administrator
   (C) To make passwords shorter
   (D) To avoid MFA

9. Which practice best reduces the risk of leaked cloud keys in code?

   (A) Longer static keys that are rotated every five years
   (B) Short-lived workload identity instead of static keys
   (C) Storing keys in a shared spreadsheet
   (D) Emailing keys to developers

10. Which statement about non-human identities is most accurate?

    (A) They often outnumber human identities and lack owners
    (B) They are always less privileged than human accounts
    (C) They never need rotation
    (D) They cannot be misused by attackers

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · PROTECT · LESSON 3 · 30 MIN

Data Governance, Classification and Loss Prevention

Knowing what data you have, where it lives and who may use it

- Establish data ownership and a practical classification scheme
- Apply controls proportionate to classification across the data lifecycle
- Use discovery, DLP and data security posture tools without drowning in alerts

You cannot protect data you cannot find. Most organisations hold copies of customer, employee and financial data in far more places than they realise: shared drives, SaaS apps, analytics platforms, test environments, email and now AI tools. **Data governance** sets ownership, rules and quality expectations; **data security** applies controls proportionate to value and sensitivity throughout the data lifecycle.

A four-level classification scheme

LEVEL	EXAMPLES	MINIMUM CONTROLS
Public	Published annual report, marketing pages	Integrity controls on publication
Internal	Policies, internal memos, staff directory	Access limited to staff; no public sharing
Confidential	Customer records, contracts, salary data	Need-to-know access, encryption, logging, DLP
Restricted	Card data, health records, national ID scans, encryption keys, board papers before release	Named access, strong encryption, monitoring, no external sharing without approval

PRO TIP · KEEP THE SCHEME SMALL

Four levels are enough for most organisations. More levels confuse staff and produce inconsistent labels. Pair the scheme with default labels for common repositories so that people only classify by exception.

Data lifecycle controls

01 **Create or collect** — Collect only what is needed; label at creation →

02 **Store** — Encrypt; restrict access by classification →

03 **Use** — Monitor access; mask in non-production →

04 **Share** — Approved channels; DLP; contracts with recipients →

05 **Archive** — Retention schedule; protected archives →

06 **Destroy** — Secure deletion with evidence

Data discovery and protection tools

Data discovery and classification

- Scan repositories for sensitive patterns
- Apply or suggest labels
- Feeds inventory and risk

Data loss prevention (DLP)

- Inspect data in motion and in use
- Block, warn or log risky transfers
- Needs tuning to avoid alert floods

Data security posture management

- Maps sensitive data across cloud stores
- Highlights exposure, excess access, shadow copies
- Fits cloud-heavy estates

Copyright © ZyeemZia

WATCH OUT · GENERATIVE AI TOOLS AND DATA LEAKAGE

Staff pasting customer records or source code into public AI chat tools is now one of the commonest forms of accidental disclosure. Provide approved AI tools with enterprise data controls, state clearly which classifications may be used with them, and monitor uploads to unapproved services.

SCENARIO · DECIDE · DLP ALERT FLOOD

An MFS provider deployed DLP across email and endpoints. In the first month it produced 48,000 alerts, mostly false positives from staff sending their own national ID numbers to HR. The SOC has stopped reading them. What should the data protection lead do?

(A) Switch every policy to blocking so alerts no longer need review.

(B) Turn DLP off because it does not work.

(C) Hire more SOC analysts to read every alert.

(D) Start in monitor mode for tuned, high-value policies, such as bulk customer data leaving to personal email, exempt known business flows, and add blocking only once precision is acceptable.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Data inventory entry**

Record where important data lives, who owns it and how it is protected.

DATA SET	OWNER	CLASSIFICATION	LOCATIONS	RETENTION	KEY CONTROLS	GAPS
Customer KYC records	*Head of compliance*	*Restricted*	*Core system, document store, two SaaS tools*	*5 years after account closure*	*Encryption, role-based access, DLP on email*	*Copies in test environment unmasked*

Copyright © ZyeemZia

REFLECT

Where is the most sensitive data in your organisation that nobody has formally classified? How would you find out?

Key terms

Data governance
The framework of ownership, policies and standards that ensures data is managed as an asset.

Data custodian
The person or team that operates systems storing data and applies controls set by the owner.

Data loss prevention
Technology and processes that detect and prevent unauthorised transfer of sensitive data.

Retention schedule
Rules stating how long each type of data is kept and when it must be destroyed.

Data owner
The accountable person who decides classification, access and retention for a data set.

Data classification
Assigning data to sensitivity levels that determine minimum protection requirements.

Data masking
Replacing sensitive values with realistic but fictitious data, for example in test environments.

DSPM
Data security posture management: tools that find sensitive data across cloud stores and assess its exposure.

KNOWLEDGE CHECK

11. Who should decide the classification of a customer data set?

(A) The data custodian, because it runs the database platform day to day
(B) Any employee who uses it
(C) The data owner
(D) The external auditor

12. What is the main purpose of data masking in test environments?

(A) To speed up database queries
(B) To let testing proceed without exposing real personal data
(C) To compress data for storage
(D) To satisfy the cloud provider

13. A DLP deployment produces mostly false positives. What is the best next step?

(A) Switch every rule to blocking mode so that alerts no longer reach analysts
(B) Uninstall it
(C) Ignore the alerts
(D) Tune to high-value policies in monitor mode before blocking

14. Why is a short classification scheme preferred?

(A) It satisfies every regulation automatically without any extra controls
(B) It removes the need for encryption
(C) Staff can apply it consistently
(D) It is required by all standards

15. Which lifecycle stage includes secure deletion with evidence?

(A) Archive
(B) Destroy
(C) Share
(D) Collect

Copyright © ZyeemZia

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · PROTECT · LESSON 4 · 35 MIN

Cryptography and Key Management Governance

Encryption is easy to switch on and hard to govern well

- Set encryption standards for data at rest, in transit and in use
- Govern key management, including key ownership, custody and rotation
- Plan crypto-agility and the migration to post-quantum cryptography

Encryption is only as strong as the management of its keys. Organisations commonly encrypt databases but store keys on the same server, use certificates that expire unexpectedly and take down services, or cannot say which systems still use outdated algorithms. **Cryptography governance** sets standards, ownership and lifecycle processes for algorithms, keys and certificates.

Where encryption applies

STATE	TYPICAL CONTROLS	GOVERNANCE QUESTION
Data in transit	TLS 1.2 or 1.3, mutual TLS for services, VPN or private links	Are weak protocols disabled everywhere, including internal traffic?
Data at rest	Disk, database and object encryption; field-level encryption for sensitive values	Who controls the keys, and are they separate from the data?
Data in use	Confidential computing, tokenisation, masking	Is the extra protection justified by the threat and cost?

A key management hierarchy

Root of trust	`Hardware security module (HSM)` `Master keys never leave the hardware`
Key encryption keys	`Protect data keys` `Rotated on a set schedule`
Data encryption keys	`Encrypt the actual data` `Many per system; can be rotated by re-wrapping`
Applications and services	`Request keys through a key management service` `Access controlled and logged`

Who holds the keys in cloud?

Provider-managed keys

- Simplest; provider creates and rotates
- Least customer control
- Fine for lower-sensitivity data

Customer-managed keys (BYOK)

- Customer controls key policy and rotation in the provider's KMS
- Can revoke to make data unreadable
- Common for regulated data

Hold your own key (HYOK) or external key manager

- Keys stay outside the provider
- Strongest control and sovereignty
- More complexity, latency and outage risk

Copyright © ZyeemZia

INSIGHT · POST-QUANTUM CRYPTOGRAPHY IS A GOVERNANCE PROGRAMME

A sufficiently large quantum computer could break widely used public-key algorithms such as RSA and elliptic-curve cryptography. In 2024 NIST published its first post-quantum standards, for key establishment (ML-KEM) and digital signatures (ML-DSA and SLH-DSA). Attackers can **harvest now and decrypt later**, so long-lived sensitive data is already at risk. The first step is not buying products; it is building a cryptographic inventory and making systems crypto-agile.

Preparing for post-quantum migration

1. **Inventory** Find where public-key cryptography is used: protocols, certificates, code libraries, devices, suppliers.
2. **Prioritise** Rank by data lifetime and exposure: data that must stay secret for ten years or more comes first.
3. **Engage suppliers** Ask vendors for post-quantum roadmaps and include requirements in contracts.
4. **Build crypto-agility** Centralise crypto libraries and configuration so algorithms can be swapped without rewriting systems.
5. **Pilot hybrid modes** Test combined classical and post-quantum key exchange where supported.
6. **Migrate and verify** Phase migration by priority; verify with scanning and testing.

TEMPLATE **Cryptographic inventory**

Record where cryptography is used so that weak algorithms, expiring certificates and post-quantum priorities can be managed.

SYSTEM	USE	ALGORITHM AND KEY SIZE	KEY OR CERTIFICATE OWNER	EXPIRY OR ROTATION	DATA SECRECY LIFETIME	MIGRATION PRIORITY
Payment API gateway	*TLS server certificate*	*ECDSA P-256*	*Platform team*	*Expires 14 March*	*Low (session data)*	*Medium*
Archive of signed land records	*Document signing*	*RSA 2048*	*Registry IT*	*Key rotated every 3 years*	*Decades*	*High*

Copyright © ZyeemZia

SCENARIO · DECIDE · CERTIFICATE OUTAGE

A national e-commerce platform suffers a four-hour outage on its busiest sale day because a TLS certificate on an internal API gateway expired. Nobody knew who owned it. What is the BEST long-term fix?

(A) Buy certificates with the longest available validity.

(B) Build a certificate inventory with owners, automate issuance and renewal, and alert well before expiry.

(C) Ask the network team to check certificates monthly by hand.

(D) Disable certificate validation on internal APIs.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Which data in your organisation must remain confidential for more than ten years? Which systems protect it, and what cryptography do they use?

Key terms

Key management
The governance and processes for generating, storing, distributing, rotating and destroying cryptographic keys.

Envelope encryption
Encrypting data with a data key and then encrypting that key with a key encryption key.

Crypto-agility
The ability to change algorithms and keys quickly without redesigning systems.

Harvest now, decrypt later
Collecting encrypted data today to decrypt it once more powerful computing becomes available.

Hardware security module
A tamper-resistant device that generates and protects keys and performs cryptographic operations.

BYOK
Bring your own key: the customer controls encryption keys used by a cloud service through the provider's key service.

Post-quantum cryptography
Algorithms designed to resist attack by quantum computers, such as those standardised by NIST in 2024.

Tokenisation
Replacing a sensitive value with a non-sensitive token that maps back to it only in a secured vault.

KNOWLEDGE CHECK

16. What is the main weakness of storing a database encryption key on the same server as the data?

(A) Anyone who compromises the server gets both data and key

(B) Encryption becomes slower than without a key on the server

(C) The key will expire sooner

(D) Backups become larger

17. Which key option gives a customer the most control over cloud data?

(A) Provider-managed keys created and rotated automatically by the cloud service

(B) No encryption

(C) Shared keys between tenants

(D) Hold your own key in an external key manager

Copyright © ZyeemZia

18. Why should post-quantum planning start now?

(A) Quantum computers already break all symmetric encryption used today in practice
(B) Encrypted data harvested today may be decrypted later
(C) Regulators ban RSA from next month
(D) It is cheaper to wait

19. What is the first practical step towards post-quantum migration?

(A) Replacing every algorithm in production immediately with experimental alternatives
(B) Turning off TLS
(C) Buying a quantum computer
(D) A cryptographic inventory

20. Which approach best prevents outages from expired certificates?

(A) Buying certificates with the longest possible validity and checking them once a year
(B) Disabling validation
(C) Automated issuance and renewal with an owned inventory
(D) Using self-signed certificates everywhere

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · PROTECT · LESSON 5 · 35 MIN

Privacy Engineering and Data Protection

Respecting people's data rights by design, across borders

- Apply core data protection principles and lawful bases to processing
- Run a data protection impact assessment and embed privacy by design
- Manage data subject rights, breach notification and cross-border transfers

Security protects data from unauthorised access. **Privacy** asks whether the organisation should collect and use the data at all, for what purpose, for how long and with what transparency to the person concerned. Data protection laws around the world, including the EU General Data Protection Regulation (GDPR), India's Digital Personal Data Protection Act 2023 and Bangladesh's newer personal data protection rules, share a common core even though details and penalties differ.

Common data protection principles

D1
Lawfulness and transparency
Have a valid legal basis and tell people clearly what you do with their data.

D2
Purpose limitation
Use data only for the purposes stated when it was collected.

D3
Data minimisation
Collect only what is needed for the purpose.

D4
Accuracy
Keep data correct and up to date.

D5
Storage limitation
Keep data no longer than necessary.

D6
Integrity and confidentiality
Protect data with appropriate security.

D7
Accountability
Be able to demonstrate compliance with evidence.

Typical lawful bases for processing

BASIS	EXAMPLE	CAUTION
Consent	Marketing messages to app users	Must be free, specific, informed and as easy to withdraw as to give
Contract	Processing a delivery address to ship an order	Only what is necessary for the contract
Legal obligation	Keeping KYC records for anti-money-laundering rules	Point to the specific law
Vital interests	Sharing a patient's details in an emergency	Narrow; life-or-death situations
Public task	A government agency issuing identity documents	Applies to public functions

Copyright © ZyeemZia

BASIS	EXAMPLE	CAUTION
Legitimate interests	Fraud detection on payments	Balance against the person's rights; not available in every law

Data protection impact assessment (DPIA)

1. **Screen** Is the processing likely to be high-risk: large scale, sensitive data, monitoring, new technology, profiling?
2. **Describe** Data, purposes, flows, recipients, retention and systems.
3. **Assess necessity** Is the processing proportionate to the purpose? Could less data achieve it?
4. **Identify risks to people** Discrimination, financial loss, identity theft, loss of control, chilling effects.
5. **Plan measures** Minimisation, pseudonymisation, access limits, transparency, opt-outs.
6. **Sign off and review** Data protection officer advice, owner approval, review on change.

TEMPLATE

DPIA summary

Summarise a high-risk processing activity, its risks to individuals and agreed measures.

PROCESSING ACTIVITY	PERSONAL DATA	RISK TO INDIVIDUALS	LIKELIHOOD AND SEVERITY	MEASURES	RESIDUAL RISK	APPROVED BY
Credit scoring from mobile wallet transactions	*Transaction history, location, contacts metadata*	*Unfair refusal of credit; sensitive inferences*	*Medium likelihood, high severity*	*Exclude contacts; explainable model; human review of refusals; opt-out*	*Medium*	*Chief Risk Officer after DPO review*

Breach response for personal data

01 Detect and contain
Stop the leak and preserve evidence

→

02 Assess
Which data, how many people, likely harm

→

03 Decide notifications
Regulator, affected people, partners, by legal deadlines

→

04 Notify
Clear, honest messages with advice for those affected

→

05 Remediate and learn
Fix causes; update DPIA and controls

Copyright © ZyeemZia

EXAMPLE · DEADLINES DIFFER

Under GDPR, notifiable personal data breaches must generally be reported to the supervisory authority within **72 hours** of becoming aware. Sector regulators, such as central banks and telecom regulators, often set their own, sometimes shorter, incident reporting timelines. A multinational may face several clocks at once, so map them before an incident.

SCENARIO · DECIDE · A NEW ANALYTICS IDEA

A Bangladeshi MFS provider's growth team wants to use customers' transaction histories and phone contact lists to build a 'social credit' score sold to partner lenders. The data protection officer has not been consulted. What should the CISO and privacy lead insist on FIRST?

(A) Encrypt the data set before giving it to the growth team.

(B) Let the project proceed and add a line to the privacy notice later.

(C) A DPIA that tests necessity, lawful basis, transparency and risks to customers before any data is processed or shared.

(D) Ban all analytics on customer data.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Pick one product or service your organisation runs. If a customer asked 'what data do you hold about me and why?', how long would it take to answer accurately?

Key terms

Personal data
Any information relating to an identified or identifiable living person.

Lawful basis
The legal ground, such as consent or contract, that permits processing of personal data.

DPIA
Data protection impact assessment: a structured assessment of risks to individuals from high-risk processing.

Data protection officer
A role that advises on and monitors compliance with data protection law within an organisation.

Sensitive personal data
Categories such as health, biometrics, religion or financial details that need extra protection under many laws.

Purpose limitation
The principle that data collected for one purpose should not be reused for incompatible purposes.

Privacy by design
Building privacy protections into systems and processes from the start rather than adding them later.

Pseudonymisation
Processing data so it cannot be linked to a person without separately held additional information.

KNOWLEDGE CHECK

21. Which principle is breached when a retailer keeps every customer's data forever 'just in case'?

(A) Storage limitation
(B) Accuracy
(C) Lawfulness and transparency
(D) Integrity and confidentiality

Copyright © ZyeemZia

22. When should a DPIA be carried out?

(A) After a breach has occurred and the regulator has asked for one
(B) Before high-risk processing begins
(C) Only when customers complain
(D) Once every ten years

23. Which statement about consent is correct?

(A) It can be assumed if a customer does not object within thirty days of a notice
(B) It is the only lawful basis
(C) It must be as easy to withdraw as to give
(D) It never expires

24. Under GDPR, the general deadline to notify the supervisory authority of a notifiable breach is:

(A) 72 hours after becoming aware
(B) 30 days after the breach is fully investigated and closed
(C) 24 hours after the breach occurred
(D) There is no deadline

25. Which technique reduces privacy risk while keeping data useful for analysis?

(A) Copying the full data set into a spreadsheet for every analyst
(B) Removing encryption
(C) Extending retention
(D) Pseudonymisation

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 4 · PROTECT

Answer key

Knowledge checks

1. D Role changes frequently add new access without removing the old.

2. B HR is the authoritative source and should drive timely disablement.

3. A Such speed shows decisions are not being made; good IGA processes detect this.

4. D One person could create a fake supplier and pay it.

5. C Too many narrowly defined roles become unmanageable and hard to review.

6. D FIDO2 binds authentication to the real site, so codes cannot be relayed.

7. C Privilege exists only when needed, shrinking the window for misuse.

8. A Daily activities like email are the main route for credential theft.

9. B Short-lived, federated credentials leave little for attackers to steal.

10. A NHIs are numerous, often over-privileged and poorly owned.

11. C Owners are accountable for classification and access decisions; custodians apply controls.

12. B Masking replaces sensitive values so test copies are not a breach risk.

13. D Scoping and tuning make DLP precise enough to enforce.

14. C Simplicity drives consistent labelling and practical controls.

15. B Destruction should be secure and evidenced, in line with retention schedules.

16. A Separating keys from data is fundamental; co-location defeats much of the benefit.

17. D Keeping keys outside the provider gives the strongest control, with extra complexity.

18. B Long-lived secrets are exposed to harvest-now, decrypt-later attacks.

19. D You must know where cryptography is used before prioritising migration.

20. C Automation and ownership address the root cause.

21. A Data should not be kept longer than necessary for its purpose.

22. B DPIAs are preventive and should shape the design.

23. C Valid consent is freely given, specific, informed and withdrawable.

24. A The 72-hour clock starts when the controller becomes aware of the breach.

25. D Pseudonymised data limits linkage to individuals without separate information.

Scenarios & case studies

> **Scenario · Rubber-stamp reviews**
> **B** is best. Best. Leavers are a process failure that reviews should never have to catch, and focused, contextual reviews make real decisions possible.

> **Scenario · Domain admin sprawl**
> **C** is best. Best. It removes the most dangerous standing privilege quickly and closes known orphaned and stale credentials.

> **Scenario · DLP alert flood**
> **D** is best. Best. Focusing on the highest-risk patterns and tuning before blocking turns DLP into a useful control.

> **Scenario · Certificate outage**
> **B** is best. Best. It addresses the root causes: no inventory, no owner and manual renewal.

> **Scenario · A new analytics idea**
> **C** is best. Best. This is high-risk profiling with onward sharing; the DPIA is the right gate to decide whether and how it can proceed.

Copyright © ZyeemZia

05

MODULE 5 · EXTEND

Third-Party and Supply-Chain Risk

Govern the suppliers, software and services that extend your attack surface

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Run a tiered third-party risk lifecycle with clear ownership
- Interpret assurance evidence and manage fourth-party and concentration risk
- Secure the software supply chain with SBOMs, provenance and pipeline controls
- Write security into contracts, plan exits and respond to supplier incidents

LESSONS

1. The Third-Party Risk Management Lifecycle · 35 min
2. Assessing and Monitoring Suppliers · 35 min
3. Software Supply Chain Security · 40 min
4. Cloud, SaaS and Outsourcing: Contracts, Exit and Concentration · 35 min

MODULE 5 · EXTEND · LESSON 1 · 35 MIN

The Third-Party Risk Management Lifecycle

Your attack surface includes every supplier you trust

- Explain why third-party risk has become a board-level concern
- Run a tiered third-party risk lifecycle from sourcing to offboarding
- Assign clear ownership between procurement, business owners and security

Modern organisations run on suppliers: cloud platforms, SaaS applications, payment processors, managed service providers, software vendors, call centres and logistics partners. Each relationship extends trust and often network or data access beyond your walls. Attackers know this. Compromising one supplier can open doors to hundreds of customers, and a single supplier outage can stop an entire sector. **Third-party risk management (TPRM)** is the discipline of knowing, assessing and controlling these dependencies.

Why boards now ask about suppliers

- Supply-chain compromises have hit thousands of organisations through one trusted update or file-transfer product
- A faulty security software update in July 2024 crashed millions of computers worldwide, showing that a supplier failure need not be an attack
- Regulators in banking and critical infrastructure now hold firms accountable for outsourced services
- Customers judge you for a breach at your processor as if it were your own
- Concentration on a few cloud and software providers creates sector-wide single points of failure

The TPRM lifecycle

01 Plan and source — Define need, risk appetite and requirements before choosing →

02 Tier — Rate inherent risk by data, access, criticality →

03 Due diligence — Assess security, resilience, finance, legal, ESG →

04 Contract — Embed security, audit, notification and exit terms →

05 Monitor — Ongoing assurance proportional to tier →

06 Offboard — Revoke access, retrieve or destroy data, confirm exit

Tiering by inherent risk

TIER	TYPICAL PROFILE	ASSURANCE DEPTH	REVIEW CYCLE
1 Critical	Supports an important business service or holds large volumes of restricted data; hard to replace	Full assessment, evidence review, on-site or virtual audit, exit plan	Annual plus continuous monitoring
2 High	Access to confidential data or internal network; moderate substitutability	Questionnaire with evidence, certificate review	Annual
3 Moderate	Limited data or access; replaceable	Short questionnaire, certificate check	Every two years

Copyright © ZyeemZia

TIER	TYPICAL PROFILE	ASSURANCE DEPTH	REVIEW CYCLE
4 Low	No data, no access, commodity service	Basic checks at onboarding	On renewal

INSIGHT · TIER FIRST, THEN ASSESS

The commonest TPRM failure is sending the same 300-question questionnaire to every supplier. The team drowns, suppliers give boilerplate answers and the few critical relationships get no more attention than the stationery vendor. Tiering by inherent risk lets you spend effort where it matters.

Who does what in TPRM

ROLE	RESPONSIBILITIES
Business owner	Accountable for the supplier relationship and accepting its residual risk
Procurement	Runs sourcing and contracting; ensures TPRM steps are completed before signature
Security and privacy	Defines requirements, assesses controls, advises on residual risk
Legal	Drafts and negotiates contractual protections
Risk management (second line)	Sets TPRM framework, monitors portfolio risk and concentration
Internal audit (third line)	Assures that the TPRM process works

SCENARIO · DECIDE · ASSESSMENT AFTER SIGNATURE

A Bangladeshi insurer's marketing team signs a three-year contract with a customer-engagement SaaS platform and uploads 900,000 policyholder records before security hears about it. What is the BEST response from the CISO?

(A) Run a prioritised risk assessment of the platform now, agree remediation or compensating controls with the business owner, and fix the procurement process so TPRM is completed before signature.

(B) Order the data deleted from the platform immediately.

(C) Accept the situation because the contract is signed.

(D) Report the marketing team to the board for breaching policy.

Circle your choice. Answer and feedback: module answer key.

Minimum TPRM controls

☐ Maintain a complete supplier inventory with business owner and tier

☐ Block purchase orders for tier 1 and 2 suppliers until assessment is complete

☐ Record what data and system access each supplier has

☐ Use contract templates with security and notification clauses

☐ Track remediation actions agreed with suppliers

☐ Report critical supplier risk and concentration to the risk committee

☐ Offboard with access revocation and data return or destruction evidence

Copyright © ZyeemZia

REFLECT

Which supplier, if it disappeared tomorrow, would stop your organisation's most important service? Do you have a tested plan for that day?

Key terms

Third-party risk management
The discipline of identifying, assessing, controlling and monitoring risks arising from suppliers and partners.

Supplier tiering
Classifying suppliers by inherent risk to decide the depth and frequency of assurance.

Offboarding
Ending a supplier relationship safely, including access removal and data return or destruction.

Business owner of a supplier
The person accountable for the relationship and for accepting its residual risk.

Inherent supplier risk
The risk a supplier relationship carries before considering the supplier's controls, based on data, access and criticality.

Due diligence
Investigation of a supplier's security, resilience, financial, legal and other risks before contracting.

Supply-chain attack
An attack that compromises a trusted supplier or its products to reach the supplier's customers.

KNOWLEDGE CHECK

1. What should determine how deeply a supplier is assessed?
   - (A) Its inherent risk tier
   - (B) The supplier's size and brand recognition in the market
   - (C) Alphabetical order
   - (D) The length of the contract document
2. Who should be accountable for accepting residual risk from a supplier?
   - (A) Procurement, because it signed the purchase order and manages the contract file
   - (B) The supplier
   - (C) The business owner of the relationship
   - (D) Internal audit
3. Which stage includes revoking supplier access and confirming data destruction?
   - (A) Due diligence
   - (B) Tiering
   - (C) Sourcing
   - (D) Offboarding
4. Why is sending one long questionnaire to every supplier ineffective?
   - (A) Suppliers are legally prohibited from answering questionnaires longer than fifty questions
   - (B) Effort is spread evenly regardless of risk
   - (C) It is too cheap
   - (D) It covers too few topics
5. Which event best illustrates supplier risk that is not an attack?
   - (A) A phishing email sent to staff
   - (B) A faulty software update from a security vendor crashing many systems
   - (C) A stolen laptop
   - (D) A brute-force login attempt

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · EXTEND · LESSON 2 · 35 MIN

Assessing and Monitoring Suppliers

Evidence over promises: questionnaires, reports, certificates and continuous signals

- Interpret assurance evidence such as SOC 2 reports and ISO/IEC 27001 certificates
- Combine questionnaires, evidence and external signals into a supplier risk view
- Manage fourth-party and concentration risk

Supplier assurance is about **evidence**. A questionnaire tells you what a supplier says; independent reports, certificates, test results and observable signals tell you what is likely true. Expert TPRM teams know what each form of evidence proves, what it does not, and how to read the fine print.

Common assurance evidence

EVIDENCE	WHAT IT SHOWS	READ CAREFULLY
SOC 2 Type I report	Controls were suitably designed at a point in time	Says nothing about whether controls operated over time
SOC 2 Type II report	Controls were designed and operated effectively over a period, often 6 to 12 months	Scope, exceptions found, complementary user entity controls
ISO/IEC 27001 certificate	An ISMS meeting the standard exists for the stated scope	Scope statement, issuing body accreditation, validity date
Penetration test summary	Specific systems were tested at a point in time	Scope, date, severity of findings, remediation status
Completed questionnaire	Supplier's self-description of controls	Unverified unless backed by evidence
Security ratings	Externally observable hygiene signals	Can be noisy; validate before acting

WATCH OUT · COMPLEMENTARY USER ENTITY CONTROLS

SOC 2 reports often list **complementary user entity controls (CUECs)**: controls the customer must operate for the supplier's controls to work, such as managing your own users' access or MFA settings. If you ignore them, the supplier's clean report does not protect you.

Reading a SOC 2 Type II report in 20 minutes

1. **Check the period and type** Type II covering a recent 6 to 12 month period.
2. **Check the scope** Does it include the service, regions and subservice organisations you use?
3. **Read the auditor's opinion** Unqualified, qualified or adverse?
4. **Scan the exceptions** Which controls failed testing, and what was management's response?
5. **List CUECs** Assign each to an owner in your organisation.
6. **Note carve-outs** Subservice providers excluded from scope are fourth parties you must assess separately.

Fourth parties are your suppliers' suppliers. Your payroll SaaS runs on a cloud provider, uses an email service and a support-desk tool. You have no contract with them, but their failure becomes yours. **Concentration risk**

Copyright © ZyeemZia

arises when many critical services, yours or your whole sector's, depend on the same provider. Regulators increasingly ask firms to map these dependencies.

Point-in-time versus continuous monitoring

Point-in-time

- Annual questionnaire and evidence review
- Deep but quickly outdated
- Misses changes between reviews

Continuous

- Breach news, security ratings, certificate expiry, financial alerts
- Timely signals of change
- Needs triage to avoid noise

Event-driven

- Reassess on supplier breach, ownership change, new service scope
- Focuses effort on real changes
- Requires contractual notification duties

SCENARIO · DECIDE · A CLEAN REPORT WITH A CATCH

A hospital is onboarding a cloud lab-results platform. The supplier's SOC 2 Type II report has an unqualified opinion but carves out its hosting provider and lists a CUEC requiring customers to enforce MFA for all users. The hospital's clinicians use shared logins. What should the TPRM lead do?

(A) Approve immediately because the opinion is unqualified.

(B) Approve only once the hospital can meet the CUEC with individual accounts and MFA, and separately assess the hosting provider as a critical fourth party.

(C) Reject the supplier because of the carve-out.

(D) Ask the supplier to enforce MFA for the hospital.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Supplier risk assessment summary**

Combine evidence into a decision on a tier 1 or tier 2 supplier.

SUPPLIER AND SERVICE	TIER	EVIDENCE REVIEWED	KEY FINDINGS	FOURTH PARTIES	RESIDUAL RISK	DECISION AND CONDITIONS
LabCloud results platform	*1*	*SOC 2 Type II (Jan to Dec), pen test summary, DR test report*	*1 exception in change control; CUEC on MFA*	*Hosting provider (carved out)*	*Medium*	*Approve once MFA live; annual review; 24-hour breach notice*

Copyright © ZyeemZia

REFLECT

Pick your most critical supplier. Which of its own suppliers would cause you an outage if they failed? How did you find out?

Key terms

SOC 2 report
An independent auditor's report on a service organisation's controls relevant to security, availability, processing integrity, confidentiality or privacy.

Type I report
An attestation that controls were suitably designed at a specific point in time.

Type II report
An attestation that controls were suitably designed and operated effectively over a period of time.

Complementary user entity control
A control the customer must operate for the service organisation's controls to achieve their objectives.

Carve-out
A subservice organisation excluded from the scope of a supplier's assurance report.

Fourth party
A supplier to your supplier, on which your service indirectly depends.

Concentration risk
The risk that many critical services depend on the same provider or technology.

Security rating
An external score of an organisation's observable security hygiene, based on internet-facing signals.

KNOWLEDGE CHECK

6. What does a SOC 2 Type II report provide that a Type I does not?

(A) A guarantee that the supplier will never suffer a security breach in future
(B) A certificate of ISO compliance
(C) A penetration test
(D) Evidence that controls operated effectively over a period

7. A supplier's assurance report lists a CUEC requiring customers to review user access quarterly. What does this mean for you?

(A) You must operate that control yourself
(B) The supplier will review your user access for you every quarter
(C) It can be ignored
(D) The report is invalid

8. What is a fourth party?

(A) A regulator that oversees your supplier's industry sector
(B) A competitor
(C) A supplier to your supplier
(D) An internal department

9. Many banks in one country rely on the same core banking hosting provider. Which risk does this illustrate?

(A) Insider risk at each bank's branch network
(B) Credential stuffing
(C) Concentration risk
(D) Data residency

Copyright © ZyeemZia

10. Why validate security ratings before acting on them?

(A) They are confidential and cannot be shared with the supplier

(B) They can include noisy or misattributed signals

(C) They are always perfectly accurate

(D) They are issued by regulators

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · EXTEND · LESSON 3 · 40 MIN

Software Supply Chain Security

Trusting the code you did not write and the pipelines that build what you did

- Explain how software supply-chain attacks work and why they scale
- Use SBOMs, provenance and signing to govern software components
- Secure build pipelines and manage open-source dependency risk

Most modern applications are assembled, not written: typically the large majority of the code comes from open-source libraries and third-party components. Build systems pull dependencies automatically and push releases to thousands of customers. Attackers target this chain because one compromise reaches many victims: a poisoned update, a malicious package with a name similar to a popular one, a hijacked maintainer account or a compromised build server.

Supply-chain attack patterns

PATTERN	HOW IT WORKS	KEY CONTROL
Compromised build or update	Attacker alters a vendor's build so signed updates carry malware	Hardened, isolated builds; provenance verification
Malicious maintainer	A contributor gains trust over years, then inserts a backdoor	Review of critical dependencies; reproducible builds
Typosquatting and dependency confusion	Fake package with a similar or internal name is pulled automatically	Private registries, pinned versions, allow-lists
Exploited popular component	A flaw in a widely used library affects thousands of apps	SBOMs and fast vulnerability matching
Stolen signing keys or tokens	Attacker signs malicious code as the vendor	HSM-protected keys, short-lived tokens

CASE STUDY · A BACKDOOR NEARLY EVERYWHERE

In March 2024 an engineer investigating unusually slow remote logins on a test Linux system traced the delay to a widely used open-source compression library. A contributor who had spent about two years building trust and gaining maintainer rights had hidden a backdoor in recent release packages, designed to undermine remote login authentication on some Linux distributions. It was caught before reaching most stable releases.

1. What made this attack possible, and why are such attacks hard to detect?
2. Which governance controls could an enterprise apply to reduce exposure to similar attacks?
3. What does the case teach about the role of open-source maintainers?

Copyright © ZyeemZia

Model answer: module answer key.

DEFINITION · SOFTWARE BILL OF MATERIALS (SBOM)

An **SBOM** is a machine-readable list of the components, versions and dependencies in a piece of software, commonly in SPDX or CycloneDX format. It lets you answer within hours, not weeks, the question 'where do we use the vulnerable library?' A related **VEX** statement tells you whether a known vulnerability is actually exploitable in that product.

Securing the build pipeline (bottom to top)

Release and distribution	`Signed artefacts` `Published provenance` `Verified on install`
Build	`Isolated, ephemeral build environments` `Generated provenance and SBOM` `No manual changes to artefacts`
Dependencies	`Private mirror or registry` `Pinned versions and checksums` `Automated vulnerability and licence checks`
Source	`Protected branches, two-person review` `Signed commits for critical repos` `Secrets scanning`
Identities	`Phishing-resistant MFA for developers and maintainers` `Least-privilege pipeline tokens`

PRO TIP · GRADUATED ASSURANCE LEVELS FOR BUILDS

Industry frameworks such as SLSA (Supply-chain Levels for Software Artifacts) describe increasing levels of build integrity, from simply documenting how something was built up to hardened, isolated builds with verifiable provenance. Use such levels to set requirements for internal teams and suppliers rather than inventing your own scale.

Governing open-source use

1. **Inventory** Generate SBOMs for every application in the pipeline.
2. **Set policy** Approved sources, licence rules, maximum vulnerability severity, minimum project health.
3. **Automate checks** Block builds that pull unapproved or critically vulnerable components.
4. **Respond fast** When a new critical flaw appears, query SBOMs and patch by exposure.
5. **Support critical projects** Fund or contribute to projects your business depends on.
6. **Require from suppliers** Ask for SBOMs, vulnerability disclosure policies and secure development evidence.

Copyright © ZyeemZia

SCENARIO · DECIDE · A CRITICAL LIBRARY FLAW

A widely used logging library is found to have a remotely exploitable flaw. A bank's CISO asks 'where are we exposed?' Teams estimate it will take three weeks to check all 400 applications manually. What capability would have shortened this MOST?

(A) SBOMs for all applications, stored centrally and queryable, combined with supplier SBOMs for bought software.

(B) An annual penetration test of the main internet banking site.

(C) A web application firewall rule for the main website.

(D) A policy banning open-source software.

Circle your choice. Answer and feedback: module answer key.

REFLECT

If a critical flaw were announced tomorrow in a component you depend on, how long would it take to know every system affected, including products you buy?

Key terms

Software supply chain
Everything involved in producing and delivering software: source, dependencies, build systems, signing and distribution.

SBOM
Software bill of materials: a machine-readable inventory of components and versions in a software product.

VEX
Vulnerability exploitability exchange: a statement of whether a known vulnerability affects a specific product.

Provenance
Verifiable information about where, when and how a software artefact was built.

SLSA
Supply-chain Levels for Software Artifacts: a framework of increasing build integrity requirements.

Typosquatting
Publishing malicious packages with names similar to popular ones to trick developers or tools.

Dependency confusion
Tricking build tools into pulling a public malicious package instead of an internal one with the same name.

Code signing
Digitally signing software so users can verify its publisher and that it has not been altered.

KNOWLEDGE CHECK

11. What is the main purpose of an SBOM?

(A) To prove the software has no vulnerabilities at the time of release

(B) To replace code review

(C) To license the software

(D) To list components and versions so exposure can be found quickly

12. A build tool pulls a public package that shares a name with an internal package. What is this attack called?

(A) Dependency confusion

(B) Typosquatting of a popular public package with a misspelled name

(C) Cross-site scripting

(D) SQL injection

Copyright © ZyeemZia

13. Which control best protects code-signing keys?

(A) Saving them in the repository so the build can find them easily

(B) Storing them in a hardware security module with strict access

(C) Emailing them to release managers

(D) Rotating them every ten years

14. What does a VEX statement add to an SBOM?

(A) Whether a known vulnerability is actually exploitable in the product

(B) A list of every developer who has ever contributed to the component

(C) The software licence price

(D) The build server's IP address

15. Why are malicious-maintainer attacks hard to detect?

(A) They always come from known hostile IP addresses that are easy to block

(B) They only affect closed-source software

(C) They abuse legitimate trust and may hide code in release artefacts

(D) They are prevented by antivirus

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · EXTEND · LESSON 4 · 35 MIN

Cloud, SaaS and Outsourcing: Contracts, Exit and Concentration

Writing security into contracts and planning for the day a provider fails

- Specify security, notification and audit terms in supplier contracts
- Design credible exit and substitution plans for critical providers
- Respond to supplier incidents as part of your own incident process

A contract is a security control. It defines what the supplier must do, what you can verify, how fast you will hear about problems and how you can leave. Financial regulators, including central banks in South Asia and the EU's Digital Operational Resilience Act (DORA), now set explicit expectations for outsourcing and ICT third-party contracts, especially for critical services.

Security clauses for critical supplier contracts

CLAUSE	WHAT IT SHOULD SAY
Security requirements	Reference your standards or an agreed annex; minimum controls such as MFA, encryption, logging
Incident notification	Notify suspected incidents affecting you within a defined time, such as 24 hours, with ongoing updates
Right to audit and assurance	Annual independent reports, right to audit or pooled audits, remediation of findings
Data location and handling	Where data is stored, sub-processing approvals, return and deletion on exit
Subcontracting	Notification and approval of material subcontractors; flow-down of obligations
Resilience	Recovery objectives, testing participation, capacity guarantees
Exit and transition	Assistance, data formats, timescales and continued service during transition
Liability and insurance	Caps and carve-outs appropriate to the data and service; cyber insurance requirements

INSIGHT · NEGOTIATING WITH VERY LARGE PROVIDERS

Hyperscale cloud and SaaS providers rarely accept bespoke clauses. Compensate by reading their standard terms, using their assurance reports and audit programmes, joining pooled audits where offered, configuring the controls you own and putting more effort into your exit plan.

Elements of a credible exit plan

E1

Trigger events

When you would leave: insolvency, repeated breaches, regulatory direction, price shock.

E2

Alternative options

Named substitute providers or in-house capability, with lead times.

E3

Data portability

Formats, export tools and volumes tested in practice.

Copyright © ZyeemZia

E4
Transition timeline
Realistic phased migration with business sign-off.

E5
Interim resilience
How the service continues if the provider stops suddenly, a stressed exit.

E6
Ownership and testing
A named owner and a periodic test or desk review.

Planned versus stressed exit

Planned exit

- Contract ends or strategy changes
- Months to migrate
- Provider cooperates
- Focus: cost and smooth transition

Stressed exit

- Provider fails, is breached or is sanctioned
- Days or hours to act
- Provider may not cooperate
- Focus: continuity of critical service and data access

Responding to a supplier incident

01 **Learn** — Notice from supplier, news, threat intel or your own detection →
02 **Assess exposure** — Which data, access and services connect to the supplier? →
03 **Contain** — Revoke tokens, disable integrations, block connections →
04 **Coordinate** — Joint bridge with supplier; agree facts and timeline →
05 **Notify** — Regulators and customers as required by your own obligations →
06 **Review** — Reassess the supplier; update contract and controls

SCENARIO · DECIDE · A FILE-TRANSFER SUPPLIER IS BREACHED

A news report says a managed file-transfer service used by a garment exporter to exchange purchase orders and payment files with buyers has a mass-exploited vulnerability. The supplier has not contacted its customers. What should the exporter's security lead do FIRST?

(A) Wait for the supplier's official notification before acting.
(B) Terminate the contract immediately.
(C) Issue a press statement that the company is unaffected.
(D) Treat it as a potential incident: identify what data and connections pass through the service, contain by suspending integrations and rotating credentials, and open a line to the supplier.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Critical supplier exit plan**

Record how a critical service would be moved or kept running if a supplier relationship ended, including in a stressed exit.

SERVICE AND SUPPLIER	EXIT TRIGGERS	ALTERNATIVES AND LEAD TIME	DATA EXPORT METHOD AND TEST DATE	STRESSED-EXIT CONTINUITY	OWNER	LAST REVIEWED
Core banking hosting by DataCo	*Insolvency, regulatory direction, repeated outages*	*Second provider (6 months); own DC (12 months)*	*Nightly encrypted export; tested March*	*Read-only replica in second site for 30 days*	*COO*	*June*

Copyright © ZyeemZia

SERVICE AND SUPPLIER	EXIT TRIGGERS	ALTERNATIVES AND LEAD TIME	DATA EXPORT METHOD AND TEST DATE	STRESSED-EXIT CONTINUITY	OWNER	LAST REVIEWED

REFLECT

For your most critical cloud or SaaS provider, could you continue the service for one week if it became unavailable without warning? What would break first?

Key terms

Outsourcing
Using an external provider to perform a function the organisation would otherwise perform itself.

Pooled audit
An audit of a supplier performed jointly on behalf of several customers to share cost and effort.

Stressed exit
Leaving a supplier suddenly because of failure, breach or legal action, with little cooperation.

Incident notification clause
A contract term requiring the supplier to report incidents affecting the customer within a set time.

Right to audit
A contractual right for the customer or its regulator to audit a supplier's relevant controls.

Exit plan
A documented plan for moving a service away from a supplier, in both planned and stressed situations.

Sub-processor
A third party engaged by a supplier to process your data on its behalf.

KNOWLEDGE CHECK

16. Which contract clause most directly reduces delays in learning about a supplier breach?

(A) A liability cap set at the value of one year's fees
(B) A clause on invoice formats
(C) A marketing clause
(D) Incident notification within a defined time

17. What is a stressed exit?

(A) A planned migration at contract expiry with full supplier cooperation and months of notice
(B) A price renegotiation
(C) Leaving a supplier suddenly after failure or breach
(D) A staff transfer

Copyright © ZyeemZia

18. A hyperscale provider will not accept a bespoke right-to-audit clause. What is a sensible compensating approach?

(A) Use its assurance reports and pooled audits, and strengthen your exit plan
(B) Accept no assurance at all and rely on the provider's marketing statements
(C) Refuse to use any cloud services
(D) Audit its data centres without permission

19. During a supplier incident, which action should you take without waiting for the supplier?

(A) Publicly blame the supplier on social media before facts are known
(B) Delete all supplier data from your systems
(C) Cancel all contracts
(D) Assess and contain your own exposure

20. Why should exit plans include tested data export?

(A) Regulators always ask to see the exported data in full
(B) Untested exports often fail on format, volume or time
(C) It reduces licence fees
(D) It improves supplier ratings

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 5 · EXTEND

Answer key

Knowledge checks

1. A Tiering by data, access and criticality directs effort where risk is greatest.

2. C The business owner benefits from the service and must own its risk.

3. D Offboarding closes the relationship safely.

4. B Undifferentiated assessment wastes effort on low-risk suppliers and starves critical ones.

5. B Supplier failures can cause major outages without any malicious actor.

6. D Type II tests operating effectiveness over time; Type I covers design at one point.

7. A CUECs are customer responsibilities that the supplier's controls rely on.

8. C Fourth parties sit one step further down the supply chain.

9. C Sector-wide dependence on one provider creates a systemic single point of failure.

10. B Ratings are useful signals but can misattribute assets or overweight minor issues.

11. D SBOMs are inventories; they do not prove absence of flaws.

12. A Dependency confusion abuses name resolution between public and private registries.

13. B HSM protection prevents theft and misuse of signing keys.

14. A VEX tells you if a listed vulnerable component matters in context.

15. C Trusted insiders and hidden artefacts evade normal review.

16. D Notification timelines ensure you hear quickly and can meet your own obligations.

17. C Stressed exits happen at short notice and often without cooperation.

18. A Standard reports, pooled audits and exit planning provide assurance where bespoke terms are unavailable.

19. D Your obligations and risk do not wait for supplier updates.

20. B Only testing reveals whether data can actually be moved in time.

Scenarios & case studies

> **Scenario · Assessment after signature**
> **A** is best. Best. It deals with the live exposure and closes the process gap that allowed it.

> **Scenario · A clean report with a catch**
> **B** is best. Best. The supplier's assurance depends on the customer's controls and the carved-out hosting provider; both gaps must be closed.

> **Case study · A backdoor nearly everywhere**
> The attack exploited social trust in an overstretched volunteer project and hid malicious code in release artefacts rather than in the visible source, making review difficult. Enterprises can maintain SBOMs to know where components are used, prefer stable releases, monitor for advisories and respond fast, verify provenance and reproducible builds for critical components, and limit what internet-facing services expose. The case shows that critical infrastructure depends on small, often unfunded maintainer teams; organisations that rely on them should contribute funding or engineering support and track project health as part of supplier risk.

> **Scenario · A critical library flaw**
> **A** is best. Best. A queryable inventory of components answers the exposure question in hours.

> **Scenario · A file-transfer supplier is breached**
> **D** is best. Best. Waiting for supplier notification loses time; the exporter must assess and contain its own exposure.

Copyright © ZyeemZia

06

MODULE 6 · OPERATE

Security Operations Strategy and Metrics

Run detection, response and exposure management as measurable, accountable services

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Choose and staff a security operations model that fits the organisation
- Build and validate threat-informed detection as code
- Govern incident response with decision rights, playbooks and evidence handling
- Prioritise vulnerabilities and exposures by real-world risk
- Design KPIs and KRIs that inform decisions from operations to the board

LESSONS

1. Security Operations Operating Models · 35 min
2. Detection Engineering and Threat-Informed Defence · 35 min
3. Incident Response Governance · 40 min
4. Vulnerability and Exposure Management · 35 min
5. Security Metrics, KPIs and KRIs · 35 min

MODULE 6 · OPERATE · LESSON 1 · 35 MIN

Security Operations Operating Models

In-house, outsourced or hybrid: designing a SOC that fits the organisation

- Compare in-house, MSSP, MDR and hybrid security operations models
- Estimate staffing for round-the-clock coverage
- Define the scope, services and maturity path of a security operations function

A **security operations centre (SOC)** is less a room full of screens than a set of capabilities: collecting telemetry, detecting threats, investigating, responding and improving defences. The strategic question for a leader is not 'do we need a SOC?' but 'which capabilities must we own, which can we buy, and how do we make them work together?'

Operating model options

In-house SOC

- Full control and deep business context
- Expensive: staff, tools, 24x7 rota
- Hard to hire and retain skills
- Fits large, highly regulated or high-threat organisations

Managed services (MSSP or MDR)

- Fast to start, 24x7 coverage included
- Provider sees many customers' threats
- Less business context; response limits
- Fits small and mid-sized organisations

Hybrid

- Provider covers monitoring and first response out of hours
- Internal team owns context, escalation, detection tuning and major incidents
- Needs clear runbooks and shared tooling
- The commonest model in 2026

Core SOC services and who typically owns them in a hybrid model

SERVICE	INTERNAL TEAM	PROVIDER
Log and telemetry onboarding	Owns sources and quality	Advises and monitors health
Alert triage 24x7	Daytime overlap	Primary
Investigation and containment	Decision authority for business-impacting actions	Pre-approved containment actions
Detection engineering	Business-specific use cases	Generic threat content
Threat hunting	Hypotheses from business context	Hunts across customer base
Major incident command	Primary	Support

Staffing a 24x7 seat

MEASURE	FORMULA	WHAT IT TELLS YOU
Hours to cover per seat	`24 × 365 = 8,760 hours per year`	One analyst position staffed every hour of the year.
Productive hours per analyst	`≈ 2,080 contracted − leave, holidays, training, sickness ≈ 1,600 to 1,800`	Varies by country and policy; use your own HR data.
FTE per 24x7 seat	`FTE = 8,760 ÷ productive hours ≈ 4.9 to 5.5`	Roughly five to six people for one continuous seat.

Copyright © ZyeemZia

MEASURE	FORMULA	WHAT IT TELLS YOU
Triage capacity	`Analysts needed = (alerts per day × minutes per alert) ÷ (60 × productive hours per shift)`	Shows why reducing noise is cheaper than hiring.

EXAMPLE · THE ARITHMETIC THAT CHANGES MINDS

A Dhaka bank wants two analysts on duty at all times. At about 1,700 productive hours each, that needs roughly 2 × 8,760 ÷ 1,700 ≈ 10.3 people before team leads, engineers and threat hunters. Presenting this calculation helps executives see why a hybrid model is often the realistic choice.

SOC maturity path

S1
Visibility
Critical log sources onboarded, time-synchronised and retained.

S2
Detection
Use cases mapped to priority threats; alerts triaged consistently.

S3
Response
Playbooks, decision rights and containment actions agreed and practised.

S4
Proactive
Threat hunting, purple teaming and detection-as-code.

S5
Optimising
Automation, metrics-driven improvement and business-aligned risk reporting.

SCENARIO · DECIDE · BUILD OR BUY?

A private university in Sylhet with 25,000 students has a four-person IT security team, no night cover and growing ransomware attacks on the education sector. The registrar asks whether to build an in-house 24x7 SOC. What should the CISO recommend?

(A) Build a full in-house 24x7 SOC with twelve new hires.

(B) Rely on the internal team during office hours and accept no night cover.

(C) A hybrid model: a managed detection and response provider for 24x7 monitoring and first containment, with the internal team owning context, escalation and improvement.

(D) Outsource everything, including major incident decisions.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **SOC service responsibility matrix**

Clarify which party performs, approves and is informed for each security operations service in a hybrid model.

SERVICE	INTERNAL SOC	PROVIDER	IT OPERATIONS	BUSINESS OWNER	RESPONSE TIME TARGET
Isolate an infected laptop	*Informed*	*Performs (pre-approved)*	*Informed*	*Not involved*	*15 minutes*
Disable a payment server	*Approves and leads*	*Recommends*	*Performs*	*Consulted*	*30 minutes*

Copyright © ZyeemZia

SERVICE	INTERNAL SOC	PROVIDER	IT OPERATIONS	BUSINESS OWNER	RESPONSE TIME TARGET

REFLECT

If a serious alert fired at 2 a.m. on a public holiday, who would see it, who could act on it and who could authorise disconnecting a business system?

Key terms

Security operations centre
The function that monitors, detects, investigates and responds to security threats.

MDR
Managed detection and response: an external service that monitors, investigates and performs response actions.

Full-time equivalent
A unit expressing staffing as the number of full-time workers needed.

Threat hunting
Proactive searching for threats that have evaded existing detection, based on hypotheses.

MSSP
Managed security service provider: an external company that operates security services such as monitoring for customers.

Hybrid SOC
An operating model combining internal security staff with an external provider.

Triage
The rapid assessment of alerts to decide which need investigation and in what order.

Telemetry
Logs, events and signals collected from systems for monitoring and analysis.

KNOWLEDGE CHECK

1. Roughly how many people does one continuously staffed 24x7 seat require?

   (A) Two, working twelve-hour shifts every day of the year without leave

   (B) Three

   (C) Ten

   (D) About five to six

Copyright © ZyeemZia

2. In a hybrid SOC, which decision should normally stay with the internal team?

(A) Disconnecting a business-critical system
(B) Triage of routine malware alerts on employee laptops overnight
(C) Updating generic threat signatures
(D) Collecting log health metrics

3. Which is a key advantage of MDR for a small organisation?

(A) Complete knowledge of the organisation's business processes from the first day
(B) No need for internal security staff at all
(C) Affordable round-the-clock coverage
(D) Guaranteed prevention of all incidents

4. Why is reducing alert noise often cheaper than hiring analysts?

(A) Noisy alerts are automatically ignored by the SIEM
(B) Analyst need scales with alert volume and handling time
(C) Hiring is illegal in some sectors
(D) Alerts do not affect staffing

5. Which stage of SOC maturity introduces threat hunting and purple teaming?

(A) Visibility
(B) Proactive
(C) Detection
(D) Response

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · OPERATE · LESSON 2 · 35 MIN

Detection Engineering and Threat-Informed Defence

Building detections deliberately, measuring coverage and testing that they work

- Run a detection engineering lifecycle with detections managed as code
- Measure detection coverage against priority threat techniques
- Validate defences through purple teaming and adversary emulation

Many SOCs run on default vendor rules and hope. **Detection engineering** treats detections as products: designed for specific threats, written and version-controlled as code, tested against realistic attacks, tuned with data and retired when no longer useful. Combined with threat intelligence about the adversaries most likely to target you, it becomes **threat-informed defence**.

Detection engineering lifecycle

01 Prioritise — Pick techniques used by priority threat groups →

02 Research — Understand the behaviour and data needed →

03 Build — Write detection logic as code with tests →

04 Validate — Run emulated attacks; check true and false positives →

05 Deploy — Release through change control with a runbook →

06 Tune and retire — Measure precision; improve or remove

A detection written as code (generic rule format)

Detection rule (YAML-style)

```
title: Backup catalogue deletion by non-backup admin
id: det-0142
status: production
description: Detects deletion of backup catalogues or shadow copies, common before ransomware
encryption
logsource: { product: windows, category: process_creation }
detection:
  selection:
    CommandLine|contains: ['delete shadows', 'resize shadowstorage', 'delete catalog']
  filter_backup_admins:
    User|endswith: ['svc-backup']
  condition: selection and not filter_backup_admins
level: high
tags: [attack.impact, inhibit_system_recovery]
runbook: RB-17 isolate host, confirm with backup team, check for encryption activity
```

Generic rule formats such as Sigma-style YAML let detections be reviewed, tested and converted for different SIEM platforms. Exclusions must be tightly scoped and reviewed.

Measuring detection coverage

MEASURE	HOW	CAUTION
Technique coverage	Share of priority techniques with at least one tested detection	Coverage on paper is not coverage in practice

Copyright © ZyeemZia

MEASURE	HOW	CAUTION
Data source coverage	Share of critical assets sending required telemetry	Gaps in logging make detections blind
Validated detection rate	Share of emulated attack steps detected in tests	The most honest measure; needs regular testing
Precision	True positives ÷ all alerts for a rule	Low precision burns analyst time
Time to detect in tests	From emulated action to alert	Shows whether detection is fast enough to stop impact

INSIGHT · PURPLE TEAMING BEATS ANNUAL PEN TESTS FOR DETECTION

In **purple teaming**, attackers (red) and defenders (blue) work together: the red team runs a technique, the blue team checks whether it was seen, and both improve detections on the spot. A few days of purple teaming against your priority techniques often improves detection more than a year of untargeted rule tuning.

Running a purple-team exercise

1. **Choose a threat profile** For example, a ransomware group known to target manufacturing in South Asia.
2. **Select techniques** Pick 15 to 30 techniques from that profile, across initial access to impact.
3. **Agree safety rules** Test environment or controlled production scope; rollback plans.
4. **Execute and observe** Run each technique; record prevented, detected, logged only or missed.
5. **Fix and retest** Write or tune detections; repeat until detected.
6. **Report** Coverage before and after, residual gaps with owners.

SCENARIO · DECIDE · A WALL OF GREEN

A SOC dashboard shows 85% coverage of a public technique matrix because rules exist for most techniques. A purple-team exercise then detects only 9 of 30 emulated techniques used by a priority ransomware group. What should the SOC manager report to the CISO?

(A) That validated detection is 30% for the priority threat, with a plan to fix the missed techniques and to report validated coverage instead of rule counts.

(B) That coverage is 85% and the exercise was unrealistic.

(C) That the SOC needs a new SIEM platform.

(D) That results should be kept within the SOC to avoid alarming executives.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Detection use-case register**

Track each detection from priority technique to validated status and owner.

ID	TECHNIQUE THEME	THREAT GROUPS	DATA SOURCES	LAST VALIDATED	PRECISION	OWNER
DET-0142	*Inhibit system recovery (backup deletion)*	*Ransomware groups A and C*	*Endpoint process logs*	*12 May, detected in 2 minutes*	*92%*	*Detection engineer 2*

Copyright © ZyeemZia

ID	TECHNIQUE THEME	THREAT GROUPS	DATA SOURCES	LAST VALIDATED	PRECISION	OWNER

REFLECT

Which three attacker techniques would hurt your organisation most if they went undetected for a week? When were detections for them last tested?

Key terms

Detection engineering
The discipline of designing, building, testing and maintaining threat detections as managed products.

Use case
A defined detection scenario linking a threat behaviour to data, logic, response and owner.

Adversary emulation
Reproducing the known behaviour of a specific threat group to test defences.

False positive
An alert that fires on benign activity.

Detection as code
Managing detection rules in version control with review, testing and automated deployment.

Purple teaming
Collaborative exercises in which attackers and defenders test and improve detections together.

Precision
The share of alerts from a detection that are true positives.

Validated coverage
The share of priority techniques shown by testing to be detected.

KNOWLEDGE CHECK

6. What is the most honest measure of detection capability?

(A) Validated detection rate from emulated attacks

(B) The number of rules installed in the SIEM, including disabled vendor defaults

(C) The size of log storage

(D) The number of analysts

Copyright © ZyeemZia

7. What is purple teaming?

   (A) A red team test kept secret from defenders until the final report is delivered
   (B) A compliance audit
   (C) Attackers and defenders testing and improving detections together
   (D) A vendor product evaluation

8. A rule raised 400 alerts last month and 8 were true positives. What is its precision?

   (A) 8%
   (B) 20%
   (C) 50%
   (D) 2%

9. Why manage detections as code?

   (A) Because SIEM platforms cannot accept any rules that are written through the user interface
   (B) To hide rules from auditors
   (C) For review, testing, version control and repeatable deployment
   (D) To avoid documentation

10. Where should detection engineering priorities come from?

    (A) Whatever rules the SIEM vendor shipped with the most recent product release
    (B) Techniques used by the most relevant threat groups
    (C) Alphabetical order of techniques
    (D) Random selection

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · OPERATE · LESSON 3 · 40 MIN

Incident Response Governance

Decision rights, playbooks and evidence before the crisis, not during it

- Design an incident response plan with clear roles, severity levels and decision rights
- Build playbooks for the most likely high-impact incidents
- Manage evidence, legal considerations and lessons learned

Incident response is where governance meets reality at speed. Technical skill matters, but most failures in major incidents are failures of decision-making: nobody knew who could take a payment system offline, legal joined too late, regulators heard from journalists first. An **incident response plan** sets these decisions in advance so that people can act within minutes.

Incident response phases

01 Prepare — Plan, roles, tools, playbooks, exercises

→

02 Detect and analyse — Triage, scope, severity

→

03 Contain — Stop spread; preserve evidence

→

04 Eradicate — Remove attacker access and tools

→

05 Recover — Restore services safely; monitor

→

06 Learn — Review, improve controls and plans

Severity levels with decision rights

SEVERITY	EXAMPLE	INCIDENT LEAD	WHO DECIDES BUSINESS-IMPACTING CONTAINMENT	NOTIFY
SEV1 Critical	Ransomware spreading; payment fraud in progress	Head of incident response	COO or delegate within 30 minutes	CEO, CISO, legal, regulator assessment
SEV2 High	Confirmed compromise of a server with sensitive data	SOC manager	Service owner	CISO, legal, privacy
SEV3 Medium	Malware on one laptop, contained	Duty analyst	Pre-approved actions	SOC manager
SEV4 Low	Blocked phishing campaign	Duty analyst	Not needed	Weekly report

CASE STUDY · THE 2016 CENTRAL BANK PAYMENT HEIST

In February 2016 attackers who had been inside Bangladesh Bank's network for weeks used its SWIFT payment messaging access to send dozens of fraudulent transfer instructions, worth nearly US$1 billion, to the bank's account at the Federal Reserve Bank of New York. Most were blocked, but about US$81 million reached accounts in the Philippines and was largely laundered through casinos; a further US$20 million sent to Sri Lanka was stopped and recovered. Malware had been used to hide transaction confirmations, and the timing exploited weekends and holidays across time zones, delaying detection and cross-border response.

1. Which preventive and detective weaknesses allowed the attack to succeed?

2. What incident response governance problems made recovery harder?

Copyright © ZyeemZia

3. What should a payments organisation in South Asia put in place today as a result?

Model answer: module answer key.

Playbooks every organisation should have

PB1
Ransomware
Isolation strategy, backup protection, decision on shutting down, extortion handling.

PB2
Business email compromise
Payment recall, mailbox investigation, partner notification.

PB3
Data breach
Scoping, legal privilege, notifications, customer support.

PB4
Cloud account compromise
Key revocation, resource audit, provider engagement.

PB5
Insider misuse
HR and legal coordination, evidence handling, discreet investigation.

PB6
Supplier compromise
Integration shutdown, joint investigation, contract levers.

Evidence and legal considerations

- Involve legal counsel early; in some jurisdictions this can protect investigation reports
- Preserve volatile evidence (memory, active connections) before rebuilding systems
- Keep a timestamped log of decisions and actions taken
- Maintain chain of custody for evidence that may be used in court or by regulators
- Know which incidents must be reported to police, regulators or national CERTs and within what time
- Use out-of-band communication if corporate email or chat may be compromised

SCENARIO · DECIDE · WHO CAN PULL THE PLUG?

At 1 a.m. the SOC of an MFS provider sees ransomware spreading from a file server towards the transaction-processing cluster. Isolating the cluster will halt all customer payments. The on-call engineer cannot reach the CTO. What should the incident response plan have defined?

(A) That the engineer always waits for the CTO.

(B) That the SOC may isolate any system at any time without consulting the business.

(C) A named, reachable decision-maker and deputy for SEV1 business-impacting containment, with pre-agreed criteria for isolation.

(D) That containment decisions are made at the next morning's stand-up.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

Incident response readiness

☐ Approved plan with severity levels and decision rights
☐ Contact sheet with deputies, including out-of-hours and out-of-band channels
☐ Playbooks for the top six incident types
☐ Retainers in place for forensics, legal and crisis communications
☐ Regulatory and contractual notification matrix
☐ Evidence collection tools and trained staff
☐ Exercises held at least twice a year, including executives
☐ Lessons-learned process with tracked actions

REFLECT

When did your organisation last practise an incident with the executives who would make the real decisions? What decision took the longest?

Key terms

Incident response plan
The documented approach, roles and decision rights for handling security incidents.

Severity level
A classification of incident impact that drives escalation, decision rights and notification.

Eradication
Removing the attacker's access, tools and persistence from the environment.

Out-of-band communication
Communication channels separate from potentially compromised corporate systems.

Playbook
Step-by-step guidance for responding to a specific type of incident.

Containment
Actions that stop an incident from spreading or causing further harm.

Chain of custody
The documented handling of evidence from collection to presentation, proving it was not altered.

Lessons learned
A structured post-incident review that produces tracked improvements.

KNOWLEDGE CHECK

11. Which incident response phase includes removing attacker persistence?

(A) Containment
(B) Detection
(C) Preparation
(D) Eradication

12. Why use out-of-band communication during some incidents?

(A) Attackers may be monitoring corporate email or chat
(B) It is cheaper than using corporate email during normal working hours
(C) Regulators require personal phones
(D) It avoids documentation

Copyright © ZyeemZia

13. What is chain of custody for?

(A) Tracking which supplier delivered the forensic laptops and when they were paid

(B) Assigning severity

(C) Choosing playbooks

(D) Proving evidence was not altered between collection and use

14. What lesson from the 2016 central bank heist relates directly to monitoring?

(A) Payment messages need independent, round-the-clock reconciliation including weekends

(B) Payment systems should be connected to the general office network for easier access

(C) Banks should avoid using correspondent accounts

(D) Incidents should only be reported after funds are recovered

15. Who should normally approve isolating a revenue-critical system during a SEV1 incident?

(A) Any analyst on shift, at their own discretion and without informing anyone

(B) The external forensics firm

(C) A pre-designated executive decision-maker or deputy

(D) The regulator

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · OPERATE · LESSON 4 · 35 MIN

Vulnerability and Exposure Management

From endless patch lists to risk-based exposure reduction

- Prioritise vulnerabilities using severity, exploitation evidence and asset context
- Set remediation SLAs and an exception route that the business accepts
- Run a continuous threat exposure management cycle

Organisations face tens of thousands of new published vulnerabilities each year, and large estates can show millions of open findings. Trying to fix everything by CVSS score alone is impossible and misdirects effort. **Risk-based vulnerability management** focuses on what attackers actually exploit, on assets that matter, and on exposure, not just software flaws.

Prioritisation signals

SIGNAL	WHAT IT TELLS YOU	LIMITATION
CVSS base score (v3.1 or v4.0)	Technical severity of the flaw in general	Ignores whether it is exploited and your context
EPSS	Estimated probability of exploitation activity in the next 30 days	A model; changes over time
Known-exploited lists (such as CISA KEV)	Confirmed exploitation in the wild	Lags new campaigns; not exhaustive
Asset criticality and exposure	Internet-facing, crown-jewel, reachable from untrusted zones	Needs an accurate asset inventory
Compensating controls	Whether the flaw is reachable or mitigated	Must be verified, not assumed

> INSIGHT · MOST VULNERABILITIES ARE NEVER EXPLOITED
> Only a small fraction of published vulnerabilities are ever seen exploited in the wild. Combining exploitation evidence with asset exposure can cut the 'must fix now' list dramatically while reducing more real risk than fixing by CVSS alone.

Example remediation SLAs

CATEGORY	DEFINITION	TARGET
Emergency	Known exploited and internet-facing or crown-jewel	72 hours or mitigate
High	High EPSS or critical CVSS on exposed asset	14 days
Medium	Critical or high on internal asset without exploitation evidence	30 to 60 days
Low	Everything else	Next maintenance cycle

Vulnerability management metrics

MEASURE	FORMULA	WHAT IT TELLS YOU
SLA compliance	`SLA% = vulnerabilities fixed within SLA ÷ vulnerabilities due in period × 100`	Shows discipline; report by category and owner.

Copyright © ZyeemZia

MEASURE	FORMULA	WHAT IT TELLS YOU
Mean time to remediate	`MTTR = Σ (fix date − discovery date) ÷ number fixed`	Track separately for emergency and high categories.
Exposure window	`Days a known-exploited flaw stays open on internet-facing assets`	The metric attackers care about.
Risk burn-down	`Σ risk score of open findings over time`	Shows whether exposure is falling, not just ticket counts.

Continuous threat exposure management (CTEM) cycle

01 Scope
Choose attack surfaces that matter to the business

→

02 Discover
Find assets, vulnerabilities, misconfigurations, identity exposures

→

03 Prioritise
Rank by exploitability, impact and control coverage

→

04 Validate
Test whether attack paths really work

→

05 Mobilise
Agree fixes with owners and track them

SCENARIO · DECIDE · PATCH EVERYTHING CRITICAL?

A telecom operator's scanner shows 41,000 'critical' CVSS findings. Infrastructure teams say they can patch about 3,000 per month. The CIO wants all criticals closed this quarter. What should the CISO propose?

(A) Patch in CVSS order until the quarter ends.

(B) Accept all criticals as a risk until a new patching tool arrives.

(C) Ask the vendor to lower CVSS scores.

(D) Prioritise known-exploited and high-EPSS flaws on internet-facing and crown-jewel assets first, with clear SLAs and reported risk burn-down.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Vulnerability exception request**

Request a time-limited exception to a remediation SLA with compensating controls.

FINDING	ASSET AND EXPOSURE	REASON FIX IS DELAYED	COMPENSATING CONTROLS	PROPOSED DATE	RISK OWNER APPROVAL
Remote code execution in VPN appliance firmware	*Internet-facing VPN, 900 users*	*Vendor patch breaks MFA integration*	*Restrict source IPs, enhanced monitoring, virtual patch on WAF*	*Within 10 days*	*Head of infrastructure, CISO consulted*

Copyright © ZyeemZia

REFLECT

What share of your organisation's open critical findings are on internet-facing systems with known exploitation? Can you get that number in under an hour?

Key terms

CVSS
Common Vulnerability Scoring System: a standard for rating the technical severity of vulnerabilities.

Known exploited vulnerability
A vulnerability with reliable evidence of active exploitation in the wild.

Remediation SLA
The agreed maximum time to fix or mitigate a vulnerability of a given category.

Virtual patch
A temporary control, such as a WAF or IPS rule, that blocks exploitation until a fix is applied.

EPSS
Exploit Prediction Scoring System: a model estimating the probability that a vulnerability will be exploited soon.

Risk-based vulnerability management
Prioritising remediation by exploitation likelihood, asset value and exposure rather than severity alone.

CTEM
Continuous threat exposure management: a cycle of scoping, discovering, prioritising, validating and mobilising fixes.

Attack surface
All the points where an attacker could try to enter or extract data from an environment.

KNOWLEDGE CHECK

16. Which signal most directly shows a vulnerability is being used by attackers now?
    - (A) A CVSS base score of 9.8 assigned at publication
    - (B) Listing on a known-exploited vulnerabilities catalogue
    - (C) The age of the vulnerability
    - (D) Vendor name

17. What does EPSS estimate?
    - (A) The cost of patching each affected system across the estate
    - (B) Technical severity
    - (C) The probability of exploitation activity in the near future
    - (D) Number of affected vendors

18. 43 of 50 high-category vulnerabilities due this month were fixed within SLA. What is SLA compliance?
    - (A) 43%
    - (B) 86%
    - (C) 93%
    - (D) 50%

19. Which CTEM stage tests whether an attack path really works?
    - (A) Validate
    - (B) Scope
    - (C) Discover
    - (D) Mobilise

20. What is a virtual patch?
    - (A) A patch that only exists in the vendor's release notes but is never actually shipped
    - (B) A patch for virtual machines
    - (C) A permanent replacement for patching
    - (D) A temporary blocking control until the real fix is applied

Copyright © ZyeemZia

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · OPERATE · LESSON 5 · 35 MIN

Security Metrics, KPIs and KRIs

Measuring what matters to decisions, not what is easy to count

- Distinguish activity metrics, KPIs and KRIs and when each is useful
- Design metrics with clear definitions, owners, targets and thresholds
- Build a metrics hierarchy from operations to the board

Security teams generate endless numbers: blocked emails, scanned hosts, closed tickets. Few of these help anyone decide anything. Good metrics answer a question someone needs answered: are we getting better, are we within appetite, where should we invest? An expert leader curates a small set of meaningful measures and retires the rest.

Three kinds of measures

Activity metrics

- Counts of work done: alerts handled, scans run, trainings delivered
- Useful for team management
- Say little about risk

Key performance indicators (KPIs)

- How well a process performs against a target
- Example: 95% of emergency vulnerabilities fixed in 72 hours
- Drive operational improvement

Key risk indicators (KRIs)

- Signals that exposure is rising towards tolerance
- Example: number of internet-facing assets with known-exploited flaws open beyond 7 days
- Drive governance decisions

Qualities of a good security metric

M1
Decision-linked
Someone will act differently depending on the value.

M2
Clearly defined
Exact formula, data source, scope and frequency are written down.

M3
Owned
A named owner explains movements and leads action.

M4
Targeted
A target or threshold shows what good and bad look like.

M5
Trended
Shown over time, not as a single snapshot.

M6
Hard to game
Improving the number requires improving the reality.

Useful operational formulas

MEASURE	FORMULA	WHAT IT TELLS YOU
Mean time to detect	`MTTD = Σ (detection time − compromise start) ÷ incidents`	From investigation timelines; shows dwell time.
Mean time to contain	`MTTC = Σ (containment time − detection time) ÷ incidents`	Shows response speed once alerted.
Phishing resilience	`Report rate = reports ÷ simulated emails delivered; Click rate = clicks ÷ delivered`	Report rate rising matters more than click rate falling.

Copyright © ZyeemZia

MEASURE	FORMULA	WHAT IT TELLS YOU
Control coverage	`Coverage = assets with control active ÷ assets in scope × 100`	Requires an accurate inventory as the denominator.
Privileged MFA coverage	`Phishing-resistant MFA privileged accounts ÷ all privileged accounts × 100`	A strong KRI for credential-based attack risk.

A metrics hierarchy

Board	`5 to 8 KRIs against appetite` `Top risks and trend` `Major incidents and lessons`
Executive committee	`KRIs by business unit` `Programme milestones and budget` `Exceptions and accepted risks`
CISO and domain owners	`KPIs per control area` `SLA compliance and backlogs`
Operational teams	`Activity and quality metrics` `Daily queues and health`

WATCH OUT · WATERMELON METRICS

A 'watermelon' dashboard is green outside and red inside: every KPI meets target because targets are too easy, scope excludes difficult systems or the denominator is wrong. A coverage figure of 98% is meaningless if the asset inventory misses a third of the estate. Audit your own metrics before others do.

SCENARIO · DECIDE · CHOOSING A BOARD KRI

A hospital group's CISO must pick one KRI for the board on ransomware readiness. Which is the MOST useful?

(A) Number of malware samples blocked last quarter.

(B) Percentage of critical clinical systems with immutable backups restored successfully in a test within the last 90 days.

(C) Number of staff who completed security training.

(D) Count of firewall rules reviewed.

Circle your choice. Answer and feedback: module answer key.

TEMPLATE **Metric definition card**

Define a metric precisely so that it is consistent, owned and actionable.

METRIC	QUESTION ANSWERED	FORMULA AND DATA SOURCE	OWNER	TARGET / THRESHOLD	FREQUENCY	ACTION IF BREACHED
Known-exploited exposure window	*Are we closing doors attackers are using?*	*Median days open for KEV-listed flaws on internet-facing assets; scanner + CMDB*	*Head of infrastructure*	*≤ 3 days / > 7 days red*	*Weekly; board quarterly*	*Escalate to CIO; emergency change window*

Copyright © ZyeemZia

METRIC	QUESTION ANSWERED	FORMULA AND DATA SOURCE	OWNER	TARGET / THRESHOLD	FREQUENCY	ACTION IF BREACHED

REFLECT

Look at the security metrics your leadership currently receives. Which one would you remove, and which missing measure would change a real decision?

Key terms

KPI
Key performance indicator: a measure of how well a process performs against a target.

Activity metric
A count of work performed, useful for managing teams but weak for judging risk.

MTTC
Mean time to contain: average time from detection to containment of an incident.

Watermelon metric
A metric that looks green on dashboards while the underlying reality is poor.

KRI
Key risk indicator: a measure signalling that risk exposure is approaching tolerance.

MTTD
Mean time to detect: average time from the start of a compromise to its detection.

Dwell time
How long an attacker remains in an environment before being detected or removed.

Denominator problem
Errors in the population a metric is measured against, such as an incomplete asset inventory.

KNOWLEDGE CHECK

21. Which is a key risk indicator rather than an activity metric?

(A) Number of phishing emails blocked last month by the email gateway
(B) Number of scans run
(C) Internet-facing assets with known-exploited flaws open beyond 7 days
(D) Tickets closed per analyst

22. In a phishing simulation, which trend most indicates growing resilience?

(A) Falling number of simulations sent each quarter
(B) Rising report rate
(C) Rising click rate
(D) Shorter emails

Copyright © ZyeemZia

23. Control coverage shows 98%, but the asset inventory misses a third of the estate. What is this?

(A) A denominator problem
(B) An excellent result that should be reported to the board immediately as a success
(C) A precision problem
(D) A KRI breach

24. What makes a metric 'decision-linked'?

(A) It is displayed on a large screen in the SOC so everyone can see it
(B) It is collected automatically
(C) It has many decimal places
(D) Someone will act differently depending on its value

25. Which level of the metrics hierarchy should see 5 to 8 KRIs against appetite?

(A) The board
(B) Operational teams
(C) Individual analysts
(D) Suppliers

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 6 · OPERATE

Answer key

Knowledge checks

1. D 8,760 hours divided by about 1,600 to 1,800 productive hours gives around five to six.

2. A Business-impacting actions need internal authority and context.

3. C Providers spread 24x7 costs across customers but still need internal context.

4. B The triage capacity formula shows fewer, better alerts reduce staffing needs.

5. B Proactive capabilities build on visibility, detection and response.

6. A Testing shows what is actually detected; rule counts do not.

7. C Purple teaming is collaborative and focused on improving detection.

8. D 8 ÷ 400 = 0.02, or 2%.

9. C Code practices bring quality control to detection logic.

10. B Threat-informed priorities focus effort on likely attacks.

11. D Eradication removes access and tools after containment.

12. A If systems are compromised, attackers can read response plans.

13. D Chain of custody preserves evidential integrity.

14. A Hidden confirmations and weekend timing delayed detection.

15. C Business-impacting decisions need pre-agreed, accountable authority.

16. B Known-exploited lists record confirmed exploitation.

17. C EPSS is a probability model for exploitation.

18. B 43 ÷ 50 = 0.86.

19. A Validation confirms exploitability before mobilising effort.

20. D Virtual patches mitigate exposure temporarily.

21. C The KRI signals rising exposure against a tolerance.

22. B People reporting suspicious messages is the behaviour that enables response.

23. A The metric is measured against an incomplete population.

24. D Metrics exist to inform decisions.

25. A Boards need a few risk measures tied to appetite.

Scenarios & case studies

Scenario · Build or buy?
C is best. Best. It delivers round-the-clock coverage affordably while keeping business knowledge and authority in-house.

Scenario · A wall of green
A is best. Best. It replaces a misleading paper metric with tested evidence and a remediation plan.

Case study · The 2016 central bank payment heist
Weaknesses included insufficient segmentation and hardening of the payment environment, compromised operator credentials, and no independent, out-of-band reconciliation that would reveal hidden confirmations. Response was slowed by weekend and holiday timing across countries, unclear escalation paths with correspondent banks and the time needed to coordinate legal action. Today a payments organisation should isolate payment systems in a protected zone with phishing-resistant MFA and privileged access controls, reconcile payment messages independently and in near real time, monitor 24x7 including weekends, pre-agree emergency contacts and procedures with correspondent banks and regulators, and exercise payment-fraud playbooks regularly. The industry also strengthened customer security controls for payment messaging in response.

Scenario · Who can pull the plug?
C is best. Best. Decision rights and criteria set in advance allow fast, authorised action at 1 a.m.

Scenario · Patch everything critical?
D is best. Best. It targets the vulnerabilities that attackers actually use on assets that matter, within real capacity.

Scenario · Choosing a board KRI
B is best. Best. It is outcome-focused, tied directly to recovery from ransomware and hard to game.

Copyright © ZyeemZia

07

MODULE 7 · ENDURE

Resilience, Continuity and Crisis Management

Keep important services running through disruption and lead the organisation through crisis

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Set impact tolerances and recovery objectives through business impact analysis
- Select continuity and DR strategies and design ransomware-resistant backups
- Lead crisis management with clear command, decisions and communications
- Prepare extortion policy and run exercises that produce lasting improvement

LESSONS

1. Operational Resilience and Business Impact Analysis · 35 min
2. Continuity and Disaster Recovery Strategy · 35 min
3. Crisis Management and Communications · 35 min
4. Ransomware Resilience and Exercising · 40 min

MODULE 7 · ENDURE · LESSON 1 · 35 MIN

Operational Resilience and Business Impact Analysis

Deciding what must keep running, how fast it must return and what it depends on

- Identify important business services and set impact tolerances
- Run a business impact analysis that produces defensible recovery objectives
- Map the people, technology, facilities and suppliers each service depends on

Security can reduce the chance of disruption but never remove it. Floods, power failures, cyber attacks, supplier collapse and human error will happen. **Operational resilience** is the ability to keep delivering important business services through disruption, or to recover them within tolerable limits. It shifts attention from protecting individual systems to protecting the services customers and society depend on.

Traditional continuity versus operational resilience

Traditional BCP and DR

- Starts from systems and sites
- Assumes disruption can be prevented or quickly fixed
- Plans per department
- Tests individual recovery steps

Operational resilience

- Starts from important business services
- Assumes severe but plausible disruption will happen
- Maps end-to-end dependencies across teams and suppliers
- Tests whether the service stays within impact tolerance

DEFINITION · IMPACT TOLERANCE

An **impact tolerance** is the maximum tolerable level of disruption to an important business service, usually expressed as a time limit, such as 'customers can make payments again within 4 hours', sometimes with volume or data limits. Several financial regulators now expect firms to set tolerances and prove they can stay within them in severe but plausible scenarios.

Recovery objectives

TERM	MEANING	EXAMPLE
MTPD (or MTD)	Maximum tolerable period of disruption before impact becomes unacceptable	Hospital emergency admissions: 2 hours
RTO	Recovery time objective: target time to restore a service or system	EHR read access: 1 hour
RPO	Recovery point objective: maximum acceptable data loss, measured in time	Payment ledger: 0 to 5 minutes
MBCO	Minimum business continuity objective: reduced service level acceptable during disruption	50% of branch transactions, cash withdrawals only

Consistency rules

MEASURE	FORMULA	WHAT IT TELLS YOU
Time ordering	`RTO < MTPD`	The recovery target must leave margin before disruption becomes intolerable.

Copyright © ZyeemZia

MEASURE	FORMULA	WHAT IT TELLS YOU
Dependency rule	`RTO(dependency) ≤ RTO(service) − time to restart the service on top of it`	A service cannot recover faster than the systems it relies on.
Data rule	`Backup or replication interval ≤ RPO`	If you back up every 24 hours, your real RPO cannot be one hour.

Running a business impact analysis (BIA)

1. **List services** Identify business services from the customer's point of view, not departments.
2. **Rate impact over time** Assess financial, customer, regulatory, safety and reputational impact at 1 hour, 4 hours, 1 day, 1 week.
3. **Set MTPD and MBCO** Find the point where impact becomes intolerable and the minimum acceptable service level.
4. **Map dependencies** People, sites, applications, data, third parties and utilities for each service.
5. **Derive RTO and RPO** Set objectives for each dependency consistent with the service tolerance.
6. **Validate and approve** Business owners sign off; compare with current capability to find gaps.

TEMPLATE Business impact analysis worksheet

Capture impact over time and recovery objectives for one important business service.

SERVICE	IMPACT AT 4 H	IMPACT AT 24 H	MTPD	RTO	RPO	KEY DEPENDENCIES
Mobile wallet transfers	*Customer complaints surge; regulator queries*	*Merchants switch providers; BDT 15 crore lost revenue; possible regulatory action*	*6 hours*	*2 hours*	*5 minutes*	*Core ledger, card switch, SMS gateway, two data centres, telecom APIs*

Copyright © ZyeemZia

SCENARIO · DECIDE · RECOVERY OBJECTIVES THAT DO NOT ADD UP

A hospital sets a 2-hour RTO for its electronic health record. The BIA reveals that the EHR depends on a database restored from nightly backups, which takes 9 hours to restore, and on an identity service with no recovery plan. What should the resilience lead do?

(A) Keep the 2-hour RTO in the plan because it is what clinicians need.

(B) Change the RTO to 9 hours without telling clinicians.

(C) Ask the database team to restore faster during an incident.

(D) Report the gap to the service owner and executive committee, and propose options such as a warm standby database and recovery plan for identity, or a formally accepted longer RTO with clinical downtime procedures.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Pick the most important service your organisation delivers. Can you list every dependency that would stop it, including suppliers and utilities, within ten minutes?

Key terms

Operational resilience
The ability to deliver important business services through disruption, or recover them within tolerable limits.

Impact tolerance
The maximum tolerable level of disruption to an important business service, often set as a time limit.

MTPD
Maximum tolerable period of disruption: the time after which impact becomes unacceptable.

RPO
Recovery point objective: the maximum acceptable amount of data loss, measured in time.

Important business service
A service provided to external customers or users whose disruption would cause intolerable harm.

Business impact analysis
A process that assesses the impact of disruption over time and sets recovery priorities and objectives.

RTO
Recovery time objective: the target time to restore a service, system or activity.

MBCO
Minimum business continuity objective: the minimum acceptable service level during disruption.

KNOWLEDGE CHECK

1. Which statement about RTO and MTPD is correct?

   (A) The RTO should always be longer than the MTPD to allow for testing and validation

   (B) They must be identical

   (C) MTPD applies only to IT systems

   (D) The RTO should be shorter than the MTPD

2. Backups run once every 24 hours. What is the best achievable RPO from backups alone?

   (A) Zero data loss, because the backups are encrypted and stored offsite

   (B) Up to 24 hours of data loss

   (C) One hour

   (D) Five minutes

Copyright © ZyeemZia

3. Operational resilience starts its analysis from:

(A) The list of servers in the data centre ordered by age
(B) The org chart
(C) Important business services
(D) The insurance policy

4. What does the MBCO describe?

(A) The minimum acceptable service level during disruption
(B) The maximum budget for continuity
(C) The number of backup copies
(D) The time to detect an incident

5. Why must dependencies be mapped in a BIA?

(A) Mapping dependencies is required before buying any cyber insurance policy
(B) To reduce licence costs
(C) To shorten the BIA
(D) A service cannot recover faster than what it depends on

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · ENDURE · LESSON 2 · 35 MIN

Continuity and Disaster Recovery Strategy

Choosing recovery strategies, protecting backups and proving recovery works

- Select continuity and DR strategies proportionate to recovery objectives
- Design backups that survive ransomware and insider attack
- Plan and evaluate recovery tests that build real confidence

Once recovery objectives are set, leaders must choose strategies that meet them at acceptable cost. Faster recovery and less data loss cost more. The art is to match strategy to the service's tolerance, then to prove through testing that it works under realistic conditions, including cyber attacks that target the recovery capability itself.

DR strategy options

STRATEGY	TYPICAL RTO	TYPICAL RPO	RELATIVE COST	NOTES
Backup and restore	Hours to days	Hours	Low	Restore time grows with data volume
Pilot light	Hours	Minutes to hours	Low to medium	Core components running minimally in a second site or cloud
Warm standby	Minutes to an hour	Minutes	Medium to high	Scaled-down full environment kept running
Active-active	Near zero	Near zero	High	Both sites serve traffic; design complexity and shared failure risk

WATCH OUT · REPLICATION IS NOT BACKUP

Real-time replication copies corruption and encryption as faithfully as good data. Ransomware or a destructive insider will happily destroy both sites of an active-active pair. You still need isolated, immutable, point-in-time copies.

The 3-2-1-1-0 backup rule

3

Three copies

Production data plus at least two backups.

2

Two media types

For example disk and object storage, or disk and tape.

1

One off-site

At least one copy in a different location.

1

One immutable or offline

At least one copy that cannot be altered or deleted, even by administrators, for the retention period.

0

Zero errors

Backups verified by automated restore tests with no errors.

Copyright © ZyeemZia

Protecting the backup system itself

- Separate backup administration identities from the main directory, with phishing-resistant MFA
- Enable immutability or object lock with retention that admins cannot shorten
- Alert on deletion of backup jobs, catalogues or snapshots
- Keep backup infrastructure in its own network zone
- Protect the backup catalogue and encryption keys so restores remain possible
- Store recovery documentation offline as well as online

Estimating real recovery time

MEASURE	FORMULA	WHAT IT TELLS YOU
Recovery time	`T(recover) = T(detect) + T(decide) + T(prepare) + data size ÷ restore throughput + T(validate)`	Most plans count only the restore step and forget detection, decision and validation.
Restore example	`20 TB ÷ 2 TB per hour = 10 hours of copying alone`	Shows why large systems may need standby rather than restore.
Test pass rate	`Pass rate = recoveries meeting RTO and RPO in tests ÷ recoveries tested × 100`	A strong KRI for resilience.

Types of continuity and recovery tests

TEST	WHAT HAPPENS	CONFIDENCE	DISRUPTION
Plan review	Owners read and update the plan	Low	None
Tabletop	Team discusses a scenario step by step	Low to medium	None
Technical restore test	Restore systems or data in isolation and validate	Medium to high	Low
Simulation	Teams perform recovery actions in a realistic exercise	High	Low to medium
Failover test	Production moves to the secondary site	Very high	Medium; needs careful planning

TEMPLATE

Recovery test plan

Plan a recovery test with clear objectives, success criteria and results.

Copyright © ZyeemZia

SYSTEM OR SERVICE	SCENARIO	OBJECTIVE (RTO / RPO)	SUCCESS CRITERIA	PARTICIPANTS	RESULT	ACTIONS
Core ERP (garment group)	*Ransomware encrypts primary site; restore from immutable copy in second site*	*8 h / 4 h*	*Orders and payroll processed by test users; data within 4 h of failure point*	*IT ops, ERP team, finance, security*	*Restored in 11 h; payroll interface failed*	*Automate interface reconfiguration; retest in 60 days*

SCENARIO · DECIDE · BACKUPS THAT WOULD NOT SURVIVE

A Chattogram logistics company backs up nightly to a disk appliance joined to the main Windows domain, using a domain admin account. Copies are replicated to a second site the same way. What is the MOST important change?

(A) Increase backup frequency to every hour.

(B) Add an immutable or offline copy managed by separate, MFA-protected backup identities outside the main domain, and test restores.

(C) Add a third replicated site.

(D) Encrypt the backups with the domain admin's key.

Circle your choice. Answer and feedback: module answer key.

REFLECT

When did your organisation last restore a critical system end to end, including validation by business users? How long did it really take?

Key terms

Disaster recovery
The technical capability and plans to restore IT services after a disruptive event.

Business continuity plan
A documented plan for continuing critical business activities during and after disruption.

Copyright © ZyeemZia

Warm standby
A scaled-down but running copy of the production environment ready to take over.

Immutable backup
A backup copy that cannot be altered or deleted for a defined retention period.

Failover
Switching service from a primary to a secondary system or site.

Active-active
An architecture where two or more sites serve traffic simultaneously.

3-2-1-1-0 rule
A backup principle: three copies, two media, one off-site, one immutable or offline, zero restore errors.

Tabletop exercise
A discussion-based exercise in which participants walk through a scenario.

KNOWLEDGE CHECK

6. Why is real-time replication not a substitute for backup?

   (A) It is always slower than nightly tape backup in a disaster
   (B) Regulators forbid it
   (C) It copies corruption and encryption to the replica
   (D) It only works in cloud

7. A system holds 30 TB and restores at 3 TB per hour. What is the minimum copying time?

   (A) 3 hours
   (B) 10 hours
   (C) 30 hours
   (D) 90 hours

8. Which test gives the most confidence with low disruption for a single system?

   (A) A plan review in which owners confirm the document is still accurate
   (B) A tabletop discussion
   (C) A technical restore test with business validation
   (D) Reading vendor documentation

9. What does the extra '1' in 3-2-1-1-0 add to the classic rule?

   (A) One extra copy stored on the same server as production
   (B) One additional administrator
   (C) One annual test
   (D) One immutable or offline copy

10. Which DR strategy generally offers the lowest cost and longest RTO?

    (A) Active-active across two regions with automatic traffic steering
    (B) Backup and restore
    (C) Warm standby
    (D) Pilot light

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · ENDURE · LESSON 3 · 35 MIN

Crisis Management and Communications

Leading the organisation when an incident becomes a crisis

- Structure a crisis management team with strategic, tactical and operational levels
- Make sound decisions under uncertainty and time pressure
- Communicate with staff, customers, regulators and media honestly and on time

Most security incidents are handled by technical teams. A **crisis** is different: it threatens the organisation's strategy, reputation, finances or people, attracts external attention and needs decisions at executive level. A major ransomware attack on a hospital, a breach of millions of customer records or a payment fraud wave at an MFS provider are crises. Technical response continues, but leadership must take the strategic decisions and speak for the organisation.

Crisis command structure

Strategic (gold)	`CEO or delegated executive chair` `Sets objectives and priorities; approves major decisions and statements`
Tactical (silver)	`Crisis manager, heads of operations, IT, security, legal, communications, HR` `Turns strategy into coordinated plans`
Operational (bronze)	`Incident response, IT recovery, customer service, site teams` `Executes actions and reports progress`
Support functions	`Logging and decision record` `External advisers: legal, forensics, crisis PR`

A decision cycle for uncertain situations

1. **Gather facts** What do we know, what do we not know, what are we assuming?
2. **Assess** What could happen next in the best, likely and worst cases?
3. **Consider options** At least two options plus 'do nothing', with consequences.
4. **Decide** Choose, record the rationale and the information available at the time.
5. **Communicate** Tell those who must act and those who must know.
6. **Review** Set a time to revisit the decision as facts change.

PRO TIP · DECIDE WITH THE FACTS YOU HAVE

Crises punish both paralysis and overconfidence. Record what you knew when you decided. Regulators and courts judge whether decisions were reasonable at the time, not with hindsight, and a clear decision log is the best defence.

Stakeholder communication map

STAKEHOLDER	WHAT THEY NEED	CHANNEL	TIMING
Staff	What happened, what to do and not do, what to say to customers	Out-of-band messaging, briefings	Early and regular

Copyright © ZyeemZia

STAKEHOLDER	WHAT THEY NEED	CHANNEL	TIMING
Customers	Impact on them, what to do, how you will help	Website, SMS, app notices, call centre scripts	As soon as facts allow
Regulators	Notification within required time, facts, actions, contacts	Formal channels	Per legal deadlines
Board	Situation, decisions needed, exposure	Briefings and decision papers	Within hours, then regularly
Partners and suppliers	Effect on shared services, actions needed	Account managers, technical bridges	Early if connected
Media and public	Accurate, consistent statement	Spokesperson, press release	When needed; avoid speculation

TEMPLATE

Holding statement

Prepare an initial public statement that can be issued quickly, saying only what is known and what people should do.

ELEMENT	CONTENT	APPROVED BY	CHANNEL	NEXT UPDATE TIME
What happened	*We are responding to a cyber security incident affecting some of our systems*	*Crisis chair and legal*	*Website, media*	*18:00 today*
What we are doing and what customers should do	*Services X and Y are temporarily unavailable; we never ask for PINs or passwords by phone*	*Communications lead*	*SMS, app, call centre*	*18:00 today*

WATCH OUT · COMMUNICATION MISTAKES THAT TURN INCIDENTS INTO CRISES

Saying 'no customer data was affected' before the investigation confirms it; going silent for days; blaming a supplier publicly before facts are known; inconsistent messages from different executives; and staff learning about the incident from social media. Scammers also exploit breaches by impersonating the organisation, so tell customers what you will never ask them for.

Copyright © ZyeemZia

SCENARIO · DECIDE · THE FIRST STATEMENT

Two hours into a ransomware attack, a Dhaka hospital's systems are down and journalists are calling. Forensics cannot yet say whether patient data was stolen. The CEO wants to announce that 'no patient data has been compromised' to reassure the public. What should the crisis communications lead advise?

(A) Issue a holding statement confirming an incident, its effect on services and patient safety measures, stating that the investigation into data impact is under way and when the next update will come.

(B) Announce that no patient data was compromised, as the CEO wishes.

(C) Say nothing until the investigation is complete.

(D) Blame a named hacker group to show the hospital is a victim.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Who is your organisation's crisis spokesperson? Have they ever rehearsed a cyber incident statement under time pressure?

Key terms

Crisis
An event that threatens the organisation's strategy, reputation, finances or people and needs executive-level decisions.

Gold, silver, bronze
A three-level command structure: strategic, tactical and operational.

Holding statement
A short, pre-approved initial statement acknowledging an incident while facts are gathered.

Stakeholder map
A list of groups affected by a crisis with their needs, channels and timing.

Crisis management team
The executive group that sets strategy, priorities and communications during a crisis.

Decision log
A record of decisions, their rationale and the information available at the time.

Spokesperson
The designated person who speaks for the organisation to media and the public.

KNOWLEDGE CHECK

11. Which level of the crisis structure approves major decisions and public statements?

(A) Strategic (gold)

(B) Operational (bronze), because it is closest to the technical facts on the ground

(C) Tactical (silver)

(D) Support functions

12. Why keep a decision log during a crisis?

(A) To assign blame to individuals once the crisis is over and the review begins

(B) To show decisions were reasonable given information at the time

(C) Because insurers require it in every policy

(D) To replace communications

Copyright © ZyeemZia

13. What should a first holding statement avoid?

(A) Telling customers what the organisation will never ask them for during the incident

(B) Saying when the next update will come

(C) Unverified claims about data impact

(D) Acknowledging the incident

14. Which stakeholder group must usually be notified within legal deadlines?

(A) Regulators

(B) Media outlets that have contacted the organisation asking for comment on the incident

(C) Competitors

(D) Former employees

15. Why warn customers about impersonation during a breach?

(A) Customers are legally required to change their names after a breach

(B) To reduce call volumes

(C) To delay notification

(D) Scammers exploit breaches by pretending to be the organisation

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · ENDURE · LESSON 4 · 40 MIN

Ransomware Resilience and Exercising

Preparing the hardest decisions in advance and practising until they are routine

- Govern the decision on extortion demands within legal and ethical limits
- Design and run executive tabletop exercises that change behaviour
- Turn exercise and incident lessons into funded improvements

Ransomware has become the most disruptive cyber threat for most organisations: attackers encrypt systems, steal data and threaten to publish it, sometimes adding denial-of-service attacks or contacting customers directly. Technical controls reduce the likelihood, but leadership must also prepare for the day they fail, including the decision whether to engage with criminals at all.

Factors in any extortion decision (prepared before an incident)

- Legal constraints: sanctions on certain groups, reporting duties and local law on facilitating crime
- Ability to recover without paying: state of backups, time to restore, safety implications
- Reliability: payment does not guarantee working decryption or deletion of stolen data
- Ethics and policy: funding criminal activity and encouraging future attacks
- Insurance terms and the insurer's role in negotiation
- Regulator and law-enforcement expectations and engagement

WATCH OUT · DECIDE THE POLICY, NOT THE PAYMENT, IN PEACETIME

Boards should agree in advance who decides, which advisers must be consulted, and the conditions under which the organisation would never pay, for example sanctions or no proof of decryption. This is not legal advice; laws on ransom payments differ by country and are changing, so take qualified advice before any incident.

Designing an executive tabletop exercise

1. **Set objectives** For example: test decision rights for shutting down services and the extortion policy.
2. **Choose a realistic scenario** Base it on threats facing your sector, such as ransomware with data theft at a hospital group.
3. **Write injects** Timed developments: encrypted systems, a leak site post, a journalist call, a regulator question.
4. **Invite the real decision-makers** CEO, COO, CFO, legal, communications, CISO, and their deputies.
5. **Facilitate, do not lecture** Ask what they would decide and why; capture disagreements.
6. **Debrief** Hot debrief immediately; written report with actions, owners and dates.

TEMPLATE Exercise inject schedule

Plan the timed developments that drive a tabletop exercise and the decision each one tests.

TIME	INJECT	DECISION TESTED	EXPECTED PARTICIPANTS	OBSERVER NOTES
T+0:00	*SOC reports encryption spreading in finance systems*	*Severity and activation of crisis team*	*CISO, COO*	

Copyright © ZyeemZia

TIME	INJECT	DECISION TESTED	EXPECTED PARTICIPANTS	OBSERVER NOTES
T+1:30	*Leak site lists the company with sample payroll files*	*Notification duties and extortion policy*	*CEO, legal, HR, comms*	

CASE STUDY · A HOSPITAL GROUP'S LONG NIGHT

A private hospital group in Dhaka with four sites is hit by ransomware at 11 p.m. on a Thursday before a long weekend. Clinical systems and the EHR are encrypted; laboratory and radiology results are unavailable. The attackers claim to have stolen 2 TB of patient records and demand payment within 72 hours. Backups exist but the last full restore test was 18 months ago, and the backup server was joined to the main domain.

1. What should the crisis team's first three decisions be?

2. How should the extortion demand be handled?

3. What would you change in the next 90 days?

Model answer: module answer key.

From lesson to improvement

01 Capture — Hot debrief and written observations → **02 Analyse** — Root causes, not only symptoms → **03 Assign** — Actions with owners, dates and budget → **04 Track** — Report progress to the risk committee → **05 Verify** — Retest in the next exercise

Copyright © ZyeemZia

SCENARIO · DECIDE · THE LESSON THAT NEVER CLOSES

A bank's last three cyber exercises all found that the out-of-hours contact list was out of date and no deputy could approve shutting down internet banking. Each report listed the same action. What should the CISO do?

(A) Add the same action to this year's report again.

(B) Stop running exercises because nothing changes.

(C) Escalate the repeated failure to the risk committee as a governance issue, assign the action to a named executive with a deadline, and verify it in a short unannounced call-tree test.

(D) Update the contact list personally the night before the next exercise.

Circle your choice. Answer and feedback: module answer key.

REFLECT

If ransomware hit your organisation tonight, who would decide whether to engage with the attackers, and on what basis? Is that written down and agreed?

Key terms

Ransomware
Malicious software or an attack that encrypts data or systems to extort payment, often combined with data theft.

Extortion policy
A pre-agreed board position on whether and how the organisation would respond to ransom demands.

Hot debrief
An immediate review held at the end of an exercise or incident while memories are fresh.

Clinical downtime procedures
Manual processes that allow healthcare to continue safely when clinical systems are unavailable.

Double extortion
Encrypting systems and also threatening to publish stolen data unless paid.

Inject
A scripted development introduced during an exercise to test decisions.

After-action report
A written record of what happened in an exercise or incident, findings and tracked actions.

KNOWLEDGE CHECK

16. When should an organisation set its policy on responding to ransom demands?

(A) Before any incident, approved by the board

(B) During the incident, once the size of the demand and the attacker's identity are known

(C) After paying

(D) Never

17. Why does paying a ransom not guarantee safety?

(A) Payments are always refunded by the attackers after recovery is complete

(B) Insurers always pay instead

(C) Decryption may fail and stolen data may still be leaked or sold

(D) Encryption stops after payment automatically

Copyright © ZyeemZia

18. What makes an executive tabletop effective?

(A) A long technical presentation delivered to the board by the security vendor

(B) Avoiding disagreements

(C) Keeping it secret from executives

(D) Real decision-makers, realistic injects and tracked actions

19. What does 'double extortion' combine?

(A) Two separate ransom payments requested from the same organisation in one month

(B) Encryption and threatened publication of stolen data

(C) Phishing and malware

(D) Two attackers

20. An exercise finding has been repeated three years in a row. What does this indicate?

(A) The exercise scenarios are too difficult and should be simplified next time

(B) The finding is unimportant

(C) The improvement loop is not working

(D) Exercises should stop

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 7 · ENDURE

Answer key

Knowledge checks

1. D Recovery must complete before disruption becomes intolerable.

2. B The backup interval limits the recovery point.

3. C Resilience focuses on end-to-end services delivered to customers.

4. A MBCO defines reduced but acceptable operations.

5. D Dependencies with slower recovery make service RTOs unachievable.

6. C Replication mirrors bad changes as well as good ones.

7. B 30 ÷ 3 = 10 hours, before detection, decisions and validation.

8. C Actually restoring and validating proves capability without moving production.

9. D Immutability or offline storage protects against deletion and ransomware.

10. B Backup and restore is cheapest but slowest.

11. A The strategic level sets direction and approves major decisions.

12. B A log provides accountability and protection against hindsight judgements.

13. C Premature reassurance can be proved false later.

14. A Regulatory notifications often have binding timelines.

15. D Fraudsters use publicity around breaches to phish customers.

16. A Peacetime decisions avoid rushed choices under pressure.

17. C Criminals are unreliable and stolen data cannot be 'returned'.

18. D Participation by real decision-makers under realistic pressure drives change.

19. B Attackers both lock systems and threaten leaks.

20. C Repeated findings show actions are not owned or verified.

Scenarios & case studies

Scenario · Recovery objectives that do not add up
D is best. Best. Objectives must be achievable or consciously accepted; the business must see the gap and the cost of closing it.

Scenario · Backups that would not survive
B is best. Best. Ransomware actors routinely use domain admin rights to delete domain-joined backups; isolation and immutability break that path.

Scenario · The first statement
A is best. Best. It is honest, timely and protects credibility if data theft is later confirmed.

Case study · A hospital group's long night
First decisions: activate the crisis team and clinical downtime procedures to protect patient safety (including diverting emergency cases if needed); isolate networks and preserve evidence while engaging forensic and legal advisers; and start the notification assessment for regulators, law enforcement and the national CIRT. The extortion demand should be handled under a pre-agreed policy: verify claims, check sanctions and legal constraints, assess whether backups are usable and how long recovery would take, involve the insurer and counsel, and avoid any commitment until facts are clear; payment does not guarantee data deletion. In the next 90 days: isolate and make backups immutable with separate admin identities, test full EHR restoration, segment clinical networks, enforce phishing-resistant MFA for admins and remote access, and exercise the crisis plan with executives before the next holiday period.

Scenario · The lesson that never closes
C is best. Best. Repeated findings show the improvement loop is broken; executive ownership and verification fix it.

Copyright © ZyeemZia

08

MODULE 8 · LEAD

Regulation, Audit and Board Leadership

Meet legal duties, earn assurance and lead the security programme in front of the board

BY THE END OF THIS MODULE YOU WILL BE ABLE TO

- Map international and Bangladeshi cyber and data obligations to controls and owners
- Plan and respond to audits, distinguishing design from operating effectiveness
- Report cyber risk to the board and build risk-based budgets and business cases
- Lead the security programme through strategy, operating model and people
- Complete the ZCSTG capstone and approach expert scenario questions with confidence

LESSONS

1. The Global Regulatory Landscape for Cyber and Data · 35 min
2. Bangladesh's Digital and Cyber Laws · 35 min
3. Audit and Assurance · 35 min
4. Board Reporting and Security Budgets · 35 min
5. Leading the Security Programme and the Capstone · 35 min

MODULE 8 · LEAD · LESSON 1 · 35 MIN

The Global Regulatory Landscape for Cyber and Data

Mapping the laws and rules that shape security programmes in 2026

- Summarise the main international cyber and data regulations security leaders meet
- Identify common regulatory themes such as management accountability and incident reporting
- Build an obligations register that links laws to controls and owners

Cyber security is no longer only a technical or voluntary matter. Governments now regulate how organisations manage cyber risk, report incidents, protect personal data and oversee suppliers, and many make senior management personally accountable. A security leader does not need to be a lawyer, but must know which rules apply, what they demand and when to call legal counsel. This lesson summarises major regimes in our own words; always check the official texts and seek legal advice.

Selected international regimes (simplified)

REGIME	WHO IT AFFECTS	KEY SECURITY EXPECTATIONS
EU GDPR (since 2018)	Organisations processing personal data of people in the EU, including from abroad	Security of processing, DPIAs, 72-hour breach notification, fines up to 4% of global turnover
EU NIS2 Directive (national laws from late 2024)	Essential and important entities in many sectors	Risk-management measures, management body approval and training, staged incident reporting (24 h, 72 h, one month)
EU DORA (applies from January 2025)	Financial entities and their critical ICT providers	ICT risk framework, incident reporting, resilience testing, third-party register and contracts
US SEC cyber disclosure rules (2023)	US-listed companies	Disclose material incidents within four business days of determining materiality; annual disclosure of risk management and governance
PCI DSS v4.x	Organisations storing, processing or transmitting payment card data	Prescriptive controls; future-dated requirements mandatory since March 2025
India DPDP Act 2023	Organisations processing digital personal data in India	Consent and notice, data fiduciary duties, breach reporting, phased rules

Themes that recur across regimes

- Boards and senior managers must approve, oversee and understand cyber risk measures
- Risk-based security measures proportionate to the organisation and its services
- Short, staged incident reporting deadlines to regulators
- Supplier and ICT third-party risk management with contractual requirements
- Resilience testing, from vulnerability scanning to threat-led penetration testing
- Evidence: documentation that demonstrates compliance on request

Copyright © ZyeemZia

INSIGHT · PERSONAL ACCOUNTABILITY IS SPREADING

Several regimes now let regulators sanction members of management bodies, require them to undergo training or expect boards to approve cyber risk measures explicitly. This has changed board behaviour: directors ask sharper questions and expect CISOs to give clear, documented answers.

Building an obligations register

1. **Identify applicable laws** By country of operation, customers' locations, sector and listing.
2. **Extract obligations** Break each law into specific, testable obligations in plain words.
3. **Map to controls** Link each obligation to controls in your unified control framework.
4. **Assign owners** Each obligation has an accountable owner and a legal adviser.
5. **Track change** Monitor new laws, amendments and regulator guidance.
6. **Evidence compliance** Keep evidence ready for inspections and audits.

TEMPLATE **Regulatory obligations register**

Record each regulatory obligation in plain words, mapped to controls, owners and evidence.

SOURCE	OBLIGATION (PLAIN WORDS)	APPLIES TO	MAPPED CONTROLS	OWNER	EVIDENCE	STATUS
NIS2 national law (EU subsidiary)	*Notify the national CSIRT of a significant incident with an early warning within 24 hours*	*EU operations*	*IR-03 notification matrix; IR-05 on-call*	*Head of incident response*	*Notification log; exercise report*	*Compliant*
GDPR	*Notify the supervisory authority of a notifiable personal data breach within 72 hours*	*EU customer data*	*PR-07 breach assessment; IR-03*	*Data protection officer*	*Breach register*	*Compliant*

Copyright © ZyeemZia

SCENARIO · DECIDE · WHICH INCIDENT CLOCK?

A Bangladeshi software exporter with an EU subsidiary and EU customer data suffers an intrusion that may have exposed personal data and disrupted a service provided to an EU hospital. The incident lead asks which notification deadline applies. What is the BEST response?

(A) Activate the pre-built notification matrix with legal counsel, because several regimes may apply at once with different deadlines and recipients, and start the earliest clock now.

(B) Only Bangladeshi law applies because the company is headquartered in Dhaka.

(C) Wait until the investigation confirms data theft before considering any notification.

(D) Let the EU hospital decide whether anyone needs to be told.

Circle your choice. Answer and feedback: module answer key.

REFLECT

Which regulation would hurt your organisation most if you breached it? Who owns compliance with it, and when were its obligations last mapped to your controls?

Key terms

GDPR
The EU General Data Protection Regulation, governing processing of personal data of people in the EU.

DORA
The EU Digital Operational Resilience Act for financial entities, covering ICT risk, incidents, testing and third parties.

Obligations register
A record of regulatory and contractual obligations mapped to controls, owners and evidence.

Extraterritorial effect
When a law applies to organisations outside the country that made it, for example because they serve its residents.

NIS2
The EU directive setting cyber risk-management and incident reporting duties for essential and important entities.

Materiality
The significance of an event to investors or the organisation, which can trigger disclosure duties.

Threat-led penetration testing
Intelligence-driven red-team testing of live production systems required for some financial firms.

KNOWLEDGE CHECK

1. Which regime focuses specifically on the digital operational resilience of financial entities in the EU?

   (A) GDPR, because it covers all information held by financial entities in the EU

   (B) DORA

   (C) PCI DSS

   (D) NIS2 only

2. Under NIS2-style reporting, what usually comes first after a significant incident?

   (A) An early warning within about 24 hours

   (B) A full final report within twenty-four hours, including root cause and lessons learned

   (C) A press release

   (D) Nothing for 30 days

Copyright © ZyeemZia

3. Why might GDPR apply to a company based in Dhaka?

(A) Because every company in the world must comply with GDPR regardless of its customers

(B) It uses cloud services

(C) It has a website

(D) It processes personal data of people in the EU, for example by serving them

4. What is the main purpose of an obligations register?

(A) To map laws to controls, owners and evidence

(B) To list every law in the world that mentions technology, whether it applies or not

(C) To replace legal advice

(D) To publish fines

5. Which theme appears across many recent cyber regulations?

(A) A ban on outsourcing any IT service to third parties

(B) Management accountability for cyber risk

(C) Mandatory use of one vendor's products

(D) Abolition of incident reporting

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · LEAD · LESSON 2 · 35 MIN

Bangladesh's Digital and Cyber Laws

A careful overview for security leaders working in or with Bangladesh

- Describe in general terms how Bangladesh's cyber and digital laws have evolved
- Identify the main authorities and sector regulators relevant to cyber risk
- Apply a prudent compliance approach while the legal framework continues to change

WATCH OUT · READ THIS FIRST

This lesson is a general, simplified overview for learning, written in our own words. Bangladesh's cyber and data laws have changed several times in recent years and may change again. Provisions, institutions and penalties described here may have been amended. Always read the current official texts, check regulator circulars and take advice from qualified Bangladeshi lawyers before acting. Nothing here is legal advice.

Bangladesh's digital economy has grown rapidly: mobile financial services, e-commerce, garment-sector digitisation, digital government services and a large IT exports sector. Its legal framework has evolved alongside, moving from early electronic transactions law to broader cyber security statutes, and more recently towards personal data protection. Security leaders need to understand the direction of travel, the authorities involved and how sector regulators such as the central bank set detailed expectations.

How the main cyber statutes have evolved (simplified)

01
2006: ICT Act
Recognised electronic records and digital signatures; created computer offences and a certifying authority regime; later amended

→

02
2018: Digital Security Act
Replaced the ICT Act's offence provisions; created a national digital security agency and the concept of critical information infrastructure; widely criticised for speech-related offences

→

03
2023: Cyber Security Act
Replaced the 2018 Act, keeping much of its structure while changing some penalties; the agency continued as the National Cyber Security Agency

→

04
2025: Cyber protection ordinance
The interim government replaced the 2023 Act, revising offences, notably removing several speech-related provisions, while retaining cyber crime and infrastructure protections

→

05
2025 onward: Personal data protection
After years of drafts, a personal data protection ordinance was approved; commencement, rules and regulator guidance should be checked

Authorities and bodies security leaders should know (check current names and mandates)

BODY	ROLE RELEVANT TO CYBER RISK
National Cyber Security Agency (NCSA)	National cyber security authority under the cyber law; policy, coordination, critical information infrastructure oversight
BGD e-GOV CIRT	National computer incident response team for government and critical sectors; advisories and incident coordination
Bangladesh Bank	Central bank; issues ICT security guidelines and incident expectations for banks and financial institutions; oversees MFS providers

Copyright © ZyeemZia

BODY	ROLE RELEVANT TO CYBER RISK
Bangladesh Financial Intelligence Unit (BFIU)	Anti-money-laundering supervision; relevant to fraud and payment incidents
BTRC	Telecommunications regulator; licence conditions for operators, including security and lawful interception
Office of the Controller of Certifying Authorities (CCA)	Licenses certifying authorities for digital signatures under the ICT law
Law enforcement cyber units	Investigation of cyber crime complaints and incidents

Concepts that commonly appear in the cyber statutes

- Critical information infrastructure (CII): systems the government designates as vital, with duties such as audits and incident reporting
- Offences such as illegal access, damage to computer systems, computer fraud and identity misuse
- Powers for investigation, search and seizure of digital evidence
- A national agency and emergency response teams with coordination roles
- Provisions affecting online content, which have been the most debated and amended part of the laws

EXAMPLE · SECTOR RULES OFTEN MATTER MORE DAY TO DAY

For a bank or MFS provider, Bangladesh Bank's ICT security guidelines and circulars typically drive most security requirements: governance roles, IT risk management, access control, data centre and DR expectations, payment system security, vendor management and incident reporting. Guidelines are revised periodically, so a bank's compliance team should track each new version and circular and map it into the control library.

A prudent compliance approach in a changing framework

1. **Track the law actively** Assign legal counsel to monitor gazette notifications, ordinances and rules; brief the risk committee on changes.
2. **Check CII status** Determine whether any of your systems are, or could be, designated as critical information infrastructure.
3. **Map sector rules** Load central bank, telecom or other regulator requirements into your obligations register.
4. **Prepare for personal data duties** Inventory personal data, set lawful bases, appoint a privacy lead and prepare breach procedures now.
5. **Agree reporting routes** Know which incidents go to which authority, within what time, and who reports.
6. **Protect people's rights** Handle any law-enforcement data requests through legal review and documented procedures.

Copyright © ZyeemZia

SCENARIO · DECIDE · A DATA REQUEST WITHOUT PAPERWORK

A Dhaka e-commerce company receives a phone call from someone claiming to be a law-enforcement officer, asking for a customer's order history and delivery address urgently for an investigation. No written request has been provided. What should the security or privacy lead do?

(A) Provide the data immediately to avoid obstructing an investigation.

(B) Refuse all requests from law enforcement as a matter of policy.

(C) Ask the customer for permission first by email.

(D) Follow the documented law-enforcement request procedure: verify the requester through official channels, require a written request with legal basis, and have legal counsel review before disclosing anything.

Circle your choice. Answer and feedback: module answer key.

CASE STUDY · GETTING READY FOR PERSONAL DATA PROTECTION

A mid-sized MFS provider in Bangladesh holds data on 6 million customers: national ID details, transaction histories, device identifiers and location data from agents. With a personal data protection ordinance approved and rules expected, the board asks the CISO and chief compliance officer for a readiness plan within six months.

1. What should the first three months of the plan contain?

2. Which data processing activities are likely to need impact assessments?

3. How should the plan stay robust if final rules differ from current drafts?

Model answer: module answer key.

REFLECT

Which Bangladeshi regulator would you hear from first after a serious cyber incident in your organisation, and do you have their incident reporting contact and timeline written down?

Key terms

ICT Act 2006
Bangladesh's early law recognising electronic records and digital signatures and defining computer offences, later amended.

Critical information infrastructure
Computer systems designated by the government as vital, which carry additional security and reporting duties.

Copyright © ZyeemZia

National Cyber Security Agency
Bangladesh's national authority for cyber security under the cyber law (check current mandate).

Bangladesh Bank ICT security guideline
The central bank's guidance setting ICT security expectations for banks and financial institutions.

Law-enforcement request procedure
A documented process for verifying and legally reviewing requests from authorities for customer data.

BGD e-GOV CIRT
Bangladesh's national computer incident response team serving government and critical sectors.

Ordinance
A law issued by the executive when parliament is not in session, which has legal force subject to later legislative processes.

KNOWLEDGE CHECK

6. Why does this course recommend checking current official texts for Bangladesh's cyber laws?

(A) Because the laws are only available in summaries prepared by private training organisations
(B) Because the laws do not apply to companies
(C) Because they are secret
(D) The framework has changed several times and may change again

7. For a Bangladeshi bank, which source typically drives most detailed security requirements day to day?

(A) The telecom regulator's licence conditions for mobile network operators
(B) Foreign data protection laws only
(C) Bangladesh Bank's ICT security guidelines and circulars
(D) Industry blogs

8. What is critical information infrastructure in the context of the cyber statutes?

(A) Any computer connected to the internet anywhere in the country
(B) Only military systems
(C) Social media accounts
(D) Systems designated as vital, with extra duties such as audits and incident reporting

9. Which part of Bangladesh's cyber laws has been most debated and amended?

(A) Provisions on recognising electronic records and digital signatures
(B) Provisions affecting online content and speech
(C) Rules on data centre cooling
(D) Software licensing fees

10. What is the best response to an unverified phone request from someone claiming to be police?

(A) Verify through official channels and require a written, legally reviewed request
(B) Disclose immediately, because refusing could be treated as obstruction of an investigation
(C) Ignore all such requests permanently
(D) Post the request on social media

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · LEAD · LESSON 3 · 35 MIN

Audit and Assurance

Proving that controls work, to yourself, your board and your regulators

- Distinguish design effectiveness from operating effectiveness and test each
- Plan risk-based audits with sensible sampling and well-written findings
- Use continuous controls monitoring to reduce audit effort and surprises

Assurance is confidence, based on evidence, that controls are designed and operating as intended. It comes from several sources: management self-assessment, second-line monitoring, internal audit, external audit, certification bodies and regulators. A mature security leader welcomes assurance, prepares evidence continuously and treats findings as free consulting rather than as attacks.

Design versus operating effectiveness

Design effectiveness

- Would the control, if performed as described, address the risk?
- Tested by walkthrough and inspection of design
- Example: the access review procedure covers all privileged accounts and requires revocation within 5 days

Operating effectiveness

- Did the control actually operate consistently over the period?
- Tested by sampling evidence across the period
- Example: 25 sampled reviews were completed on time and revocations happened

Typical sample sizes for operating effectiveness (illustrative)

CONTROL FREQUENCY	TYPICAL SAMPLE	NOTES
Annual	1	Test the single occurrence
Quarterly	2	Often the auditor's choice of quarters
Monthly	2 to 5	Higher for key controls
Weekly	5 to 15	
Daily	20 to 40	
Many times a day or automated	25 to 60, or test the configuration once plus change control	Automated controls can be tested by design plus change management

DEFINITION · IT GENERAL CONTROLS

IT general controls (ITGCs) are the foundation controls that make application controls reliable: access management (who can use and administer systems), change management (how changes are approved, tested and deployed) and IT operations (backups, job scheduling, incident handling). Weak ITGCs undermine trust in every automated control that depends on them.

Copyright © ZyeemZia

Writing a useful audit finding

C1
Condition
What was found, with facts: '12 of 25 sampled leavers kept access for more than 30 days.'

C2
Criteria
What should have happened: 'Policy requires disablement within 1 day.'

C3
Cause
Why it happened: 'HR feed to the directory fails for contractors.'

C4
Consequence
Why it matters: 'Former staff could access customer data.'

C5
Corrective action
What to do, by whom, by when: 'Fix contractor feed; IAM lead; 31 March.'

Preparing for an audit without panic

1. **Know the scope** Agree scope, criteria and timing with the auditor early.
2. **Self-assess** Test key controls yourself first; fix what you can.
3. **Organise evidence** Collect evidence continuously in a shared repository mapped to controls.
4. **Brief control owners** Owners explain their own controls; security coordinates.
5. **Respond to findings constructively** Agree facts, propose realistic actions and dates.
6. **Track to closure** Report action status to the audit committee until verified.

Continuous controls monitoring (CCM) automates testing of controls using data from systems: for example, checking daily that all privileged accounts use phishing-resistant MFA, that backups completed and were immutable, or that no public storage exists in cloud accounts. CCM turns annual sampling into continuous evidence, catches failures quickly and lets auditors rely on automated results after testing the monitoring itself.

SCENARIO · DECIDE · A REPEATED AUDIT FINDING

Internal audit at a telecom reports for the third year that change management for network devices is ineffective: 30% of sampled changes had no approval. The network head says the team is too busy for paperwork. What should the CISO recommend?

(A) Ask audit to reduce the sample size so fewer exceptions appear.

(B) Accept the finding again because the team is busy.

(C) Agree with the network head an automated change workflow integrated with device configuration tools and continuous monitoring of unapproved changes, with progress reported to the audit committee.

(D) Have the security team approve all network changes.

Circle your choice. Answer and feedback: module answer key.

Copyright © ZyeemZia

Signs of a healthy assurance relationship

☐ Audit plans are risk-based and include cyber, not only ITGCs
☐ Findings are agreed on facts within the agreed timeline
☐ Actions have owners and realistic dates and are rarely extended
☐ Repeated findings are escalated to the audit committee
☐ Evidence is collected continuously, not built the week before
☐ Automated controls and monitoring are relied upon after testing

REFLECT

Which of your key security controls could you prove worked every day of the last year? Which would rely on someone's memory?

Key terms

Assurance
Evidence-based confidence that controls are designed and operating as intended.

Operating effectiveness
Whether a control actually operated consistently as designed over a period.

Sampling
Testing a selection of control occurrences to draw conclusions about the whole population.

Continuous controls monitoring
Automated, ongoing testing of controls using system data.

Design effectiveness
Whether a control, as designed, would address the risk if performed correctly.

IT general controls
Foundation controls over access, change management and IT operations that support application controls.

Audit finding
A documented control weakness with condition, criteria, cause, consequence and corrective action.

Audit committee
A board committee that oversees financial reporting, internal control and audit, often including cyber risk.

KNOWLEDGE CHECK

11. A walkthrough confirms that a procedure, if followed, would detect unauthorised changes. What has been tested?

(A) Operating effectiveness over the whole audit period using a statistical sample
(B) Materiality
(C) Design effectiveness
(D) Business impact

12. Which of these is an IT general control?

(A) A three-way match between purchase order, invoice and goods receipt in the ERP
(B) A sales target
(C) Change management for production systems
(D) A marketing approval

Copyright © ZyeemZia

13. What does the 'cause' element of a finding explain?

(A) What the policy requires the control owner to do and how often
(B) The financial impact
(C) Who the auditor was
(D) Why the condition occurred

14. Why is continuous controls monitoring valuable?

(A) It detects control failures quickly and provides ongoing evidence
(B) It removes the need for any internal audit function in regulated organisations
(C) It replaces management accountability
(D) It is required by every law

15. For a control performed monthly, what sample size is typical?

(A) 1
(B) 2 to 5
(C) 25 to 60
(D) All 365 days

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · LEAD · LESSON 4 · 35 MIN

Board Reporting and Security Budgets

Speaking the board's language and funding the programme credibly

- Structure board reporting around risk, appetite, decisions and assurance
- Build a security budget and business case using risk-based reasoning
- Answer the questions boards most often ask about cyber risk

Boards do not want a tour of the security stack. They want to know: what are our most significant cyber risks, are they within appetite, are we getting better, what decisions do you need from us and how do we know your answers are true? A CISO who answers these clearly, consistently and honestly earns trust and budget.

A one-page board cyber report

Headline	`Overall position against appetite: within, approaching, outside` `One sentence on the trend`
Top risks	`5 to 7 scenarios with owner, trend and appetite status` `Quantified ranges where available`
Key risk indicators	`5 to 8 KRIs with thresholds and trend`
Programme	`Major milestones, budget versus plan, blockers`
Events	`Material incidents, near misses and lessons` `Regulatory developments`
Decisions needed	`Risk acceptances above threshold, investments, policy approvals`

Questions boards often ask, and what a good answer contains

QUESTION	GOOD ANSWER INCLUDES
Could what happened to company X happen to us?	The scenario, our relevant controls, test evidence, residual gap and plan
How much should we spend?	Risk-based business case, tolerance gaps closed, comparison with peers as context only
Are we compliant?	Obligations register status, open findings, regulator interactions
Would we know if we were breached?	Detection coverage validated by testing, dwell-time measures
Can we recover?	Tested recovery against impact tolerance for important services
Who is accountable?	Named risk owners, decision rights, three lines model

Copyright © ZyeemZia

Budgeting approaches

Benchmark-based

- Spend as a percentage of IT budget or revenue, compared with peers
- Easy to explain
- Ignores your actual risk and history of under-investment

Compliance-based

- Fund what regulations and audits require
- Clear justification
- Can miss risks no rule mentions

Risk-based

- Fund controls that bring top risks within tolerance most efficiently
- Directly tied to appetite and quantification
- Needs credible risk estimates and ongoing measurement

Business case arithmetic

MEASURE	FORMULA	WHAT IT TELLS YOU
Total cost of ownership	`TCO = initial cost + Σ annual running costs (licences, people, support) over the life`	People and operations often exceed the purchase price.
Net present value	`NPV = Σ (benefit_t − cost_t) ÷ (1 + r)^t`	Benefits here are reductions in expected loss; r is the organisation's discount rate.
Payback period	`Years until cumulative risk reduction exceeds cumulative cost`	Simple and intuitive, but ignores later years and the tail.
Spend benchmark (context only)	`Security spend ÷ IT spend × 100`	Surveys often report ranges around high single digits to low teens, varying widely by sector.

PRO TIP · BUDGET FOR RUNNING COSTS, NOT JUST PROJECTS

Many security programmes buy tools with capital budgets and then cannot afford the people to operate them. Present budgets in three parts: run (keep current controls working), grow (close gaps to target) and transform (strategic initiatives), and show what risk each part addresses.

TEMPLATE Board decision paper

Present a cyber risk decision to the board concisely with options and a recommendation.

DECISION REQUIRED	CONTEXT AND RISK	OPTIONS CONSIDERED	RECOMMENDATION	COST AND FUNDING	RESIDUAL RISK	IF WE DO NOTHING
Approve BDT 8 crore over 2 years for backup immutability and EHR recovery standby	*Ransomware 1-in-20-year loss estimated at BDT 60 crore, above tolerance of BDT 30 crore*	*Do nothing; immutability only; immutability plus standby*	*Immutability plus standby*	*BDT 5 crore capex, BDT 1.5 crore opex per year; within approved envelope*	*1-in-20 loss about BDT 25 crore, within tolerance*	*Remain outside appetite; regulator concern after peer incidents*

Copyright © ZyeemZia

DECISION REQUIRED	CONTEXT AND RISK	OPTIONS CONSIDERED	RECOMMENDATION	COST AND FUNDING	RESIDUAL RISK	IF WE DO NOTHING

SCENARIO · DECIDE · THE BUDGET CONVERSATION

The CFO of a listed garment group tells the CISO that peers spend about 7% of IT budget on security, so the CISO's request for 12% is 'excessive'. The group has had two ransomware near misses and its quantified ransomware tail risk is above board tolerance. What is the BEST response?

(A) Reduce the request to 7% to match peers.

(B) Present the risk-based case: the tolerance gap, options to close it, their cost and risk reduction, and treat peer benchmarks as context rather than a target.

(C) Argue that more spending is always better in security.

(D) Escalate to the board without discussing with the CFO.

Circle your choice. Answer and feedback: module answer key.

CASE STUDY · REBUILDING BOARD CONFIDENCE

A Dhaka-listed commercial bank suffered a card-fraud incident last year that the board first learned about from the media. The new CISO finds that the previous board reports were 30-page technical documents, risk was described only as 'medium', and no decisions were ever requested. The board chair asks for a new approach within one quarter.

1. What should the first new board report contain?

2. How should the CISO handle incident escalation to the board in future?

3. Which three decisions might the CISO reasonably ask the board to make in the first year?

Model answer: module answer key.

REFLECT

If you had five minutes with your board next week, which single decision would you ask them to make, and what evidence would you bring?

Copyright © ZyeemZia

Key terms

Board pack
The set of papers provided to board members before a meeting, including risk reports and decision papers.

Total cost of ownership
The full cost of a solution over its life, including purchase, operation, people and support.

Run, grow, transform
A budgeting structure separating keeping current controls running, closing gaps and strategic change.

Escalation criteria
Pre-agreed conditions under which incidents or risks must be reported to senior leaders or the board.

Decision paper
A concise paper asking a governing body for a specific decision, with options and a recommendation.

Net present value
The value today of future benefits minus costs, discounted at the organisation's cost of capital.

Risk-based budgeting
Allocating security funds to the controls that most efficiently bring top risks within tolerance.

KNOWLEDGE CHECK

16. What should a board cyber report always include?

(A) A complete list of every security tool deployed, with version numbers and licence counts
(B) Raw log samples
(C) Decisions the board is being asked to make
(D) Vendor marketing material

17. Why are spend benchmarks weak as the sole basis for a security budget?

(A) They are always calculated incorrectly by the survey providers that publish them
(B) They ignore the organisation's own risk and appetite
(C) They are illegal to use
(D) They are too precise

18. A tool costs BDT 2 crore to buy and BDT 1 crore a year to run for four years. What is its four-year TCO?

(A) BDT 2 crore
(B) BDT 4 crore
(C) BDT 8 crore
(D) BDT 6 crore

19. In a 'run, grow, transform' budget, what does 'run' fund?

(A) Keeping existing controls operating
(B) Strategic initiatives that will change the organisation's business model in five years
(C) Closing gaps to target only
(D) Board training

20. How should a board learn about a material cyber incident?

(A) Through pre-agreed escalation criteria, within hours
(B) From the annual report prepared at the end of the financial year
(C) From the media
(D) Only if customers complain

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · LEAD · LESSON 5 · 35 MIN

Leading the Security Programme and the Capstone

Strategy, operating model, people and the final defence

- Write a security strategy on a page linked to business goals
- Choose an operating model and build the team and culture to deliver it
- Prepare the ZCSTG capstone and approach expert scenario questions

Technology and governance come together in leadership. A security programme succeeds when its strategy is clearly linked to what the business is trying to do, when its operating model puts responsibility where knowledge and authority sit, and when its people are capable, trusted and sustainable. This final lesson pulls the eight blueprint sheets together and prepares you for the capstone.

Security strategy on a page

Mission	`Why security exists here, in business words: 'Keep customers' money and data safe so they can trust us'`
Outcomes (3 years)	`Top risks within appetite` `Resilient important services` `Regulator-ready assurance`
Strategic pillars	`Identity-first zero trust` `Data protection by design` `Resilience and recovery` `Third-party assurance` `People and culture`
Enablers	`Operating model, skills, budget, architecture standards, metrics`
Measures	`KRIs against tolerance` `Validated detection and recovery` `Audit and regulatory findings closed`

Security operating models

Centralised

- One security function sets policy and runs most controls
- Consistent and efficient
- Can be distant from business units

Federated

- Business units run their own security teams under central policy
- Close to the business
- Risk of inconsistency and duplication

Hybrid with BISOs

- Central function for policy, architecture, SOC and GRC
- Business information security officers embedded in major units
- Balances consistency with business intimacy; the common choice in large groups

People and culture levers

L1

Clear roles and career paths

Engineering, architecture, GRC and operations tracks with growth.

L2

Sustainable operations

Rotas, automation and leave that prevent burnout in the SOC.

L3

Security champions

Trained advocates in delivery teams and business units.

Copyright © ZyeemZia

L4

Psychological safety

People report mistakes and near misses without fear.

L5

Partnership with the business

Security framed as enabling safe growth, not saying no.

L6

Personal integrity and protection

Documented decisions, clear escalation, appropriate indemnity and insurance for leaders.

A three-horizon roadmap example

HORIZON	FOCUS	EXAMPLE INITIATIVES
Now (0 to 6 months)	Close critical exposures and set governance	Phishing-resistant MFA for admins; immutable backups; appetite approved; obligations register
Next (6 to 18 months)	Build core capabilities	Per-application access; data classification; tiered TPRM; hybrid SOC; BIA and recovery tests
Later (18 to 36 months)	Optimise and quantify	Micro-segmentation; CTEM; post-quantum inventory; risk-based budgeting; continuous controls monitoring

The ZCSTG capstone process

1. **Choose an organisation** Use a provided fictional case or an anonymised real one complex enough to touch all eight blueprint sheets.
2. **Govern** Draft decision rights, three lines, policy architecture and a CSF-style target profile.
3. **Quantify** Estimate the top ten risk scenarios with ranges and a loss exceedance view.
4. **Architect and protect** Set the target architecture, zero-trust, cloud and OT roadmaps, identity and data programmes.
5. **Extend, operate, endure** Design TPRM, SOC model, metrics, BIA and recovery strategy.
6. **Lead** Map regulation, plan assurance, build the budget and roadmap, present to a mock board and defend trade-offs.

Answering expert scenario questions

HABIT	WHY IT WORKS
Identify your role and the stage	A CISO, an auditor and a board member have different 'best' actions
Look for the governance gap	Many technical symptoms have an accountability or decision-rights root cause
Prefer risk-based, proportionate actions	Extreme or blanket options are rarely best
Respect authority and independence	Owners accept risk, audit stays independent, boards set appetite
Watch FIRST, BEST and MOST	Sequence and emphasis change the answer
Choose evidence over assertion	Tested results beat policies, promises and paper coverage

Copyright © ZyeemZia

SCENARIO · DECIDE · PRACTICE: THE NEW CISO'S FIRST MONTH

You join a regional power distribution company as its first CISO. There is no risk appetite for cyber, a flat IT/OT network, an unreviewed 60-page policy, a small IT security team and a regulator asking about critical infrastructure obligations. What should you do FIRST?

(A) Buy an OT monitoring platform in week one to show progress.

(B) Build a rapid picture of top risks and obligations with business and engineering leaders, then agree governance foundations with the executive (decision rights, appetite draft and a 90-day plan for the most critical exposures, such as IT/OT separation).

(C) Rewrite the 60-page policy before doing anything else.

(D) Start a full ISO/IEC 27001 certification project immediately.

Circle your choice. Answer and feedback: module answer key.

Capstone submission checklist

☐ Governance charter with decision rights and three lines

☐ Top-ten risk scenarios with ranges and a loss exceedance view

☐ Target architecture and phased roadmaps for zero trust, cloud and OT

☐ Identity, data protection and privacy programme with a sample DPIA

☐ Third-party and software supply-chain process with tiering and exit plans

☐ SOC model, metrics catalogue and KRIs linked to appetite

☐ BIA, recovery strategy and crisis playbook

☐ Regulatory obligations map and assurance plan

☐ Three-year budget, business case and roadmap

☐ Ten-slide board presentation and defence of three trade-offs

REFLECT

Looking across the eight blueprint sheets (govern, quantify, architect, protect, extend, operate, endure, lead), which is weakest in your organisation today, and what would you do about it in the next 90 days?

Key terms

Security strategy
A plan linking security outcomes, priorities and investments to business goals over several years.

BISO
Business information security officer: a security leader embedded in a business unit.

Operating model
How security responsibilities, people, processes and reporting lines are organised.

Federated model
An operating model in which business units run security teams under central policy.

Copyright © ZyeemZia

Roadmap horizon
A time band such as now, next and later used to sequence initiatives.

Capstone
The final ZCSTG project in which learners design and defend a complete security strategy and governance programme.

Psychological safety
A climate in which people can report mistakes and concerns without fear of blame.

KNOWLEDGE CHECK

21. What should a security strategy's mission be written in?

(A) Technical language naming the specific products and configurations to be deployed
(B) Legal language only
(C) Vendor terminology
(D) Business language linked to what the organisation values

22. What is the main advantage of a hybrid model with BISOs?

(A) Every business unit chooses its own policies and tools independently
(B) No central security function is needed
(C) Central consistency combined with close business partnership
(D) It eliminates the need for a SOC

23. In expert scenario questions, what often lies behind a technical symptom?

(A) A shortage of the latest security products in the organisation's toolset
(B) A governance or accountability gap
(C) A typing error
(D) Insufficient bandwidth

24. Which roadmap horizon typically contains 'close critical exposures and set governance'?

(A) Later (18 to 36 months)
(B) Next (6 to 18 months)
(C) Now (0 to 6 months)
(D) After the next audit

25. Why is psychological safety important in security teams?

(A) It removes the need for any incident response plan or escalation procedure
(B) It reduces salaries
(C) It replaces training
(D) People report mistakes and near misses early

☐ Lesson complete · Date _____ · Knowledge check score ____ / 5

Copyright © ZyeemZia

MODULE 8 · LEAD

Answer key

Knowledge checks

1. B DORA is the EU regulation dedicated to financial-sector ICT resilience.

2. A NIS2 introduces staged reporting starting with an early warning.

3. D GDPR has extraterritorial reach when organisations offer services to or monitor people in the EU.

4. A It turns legal text into managed, testable obligations.

5. B Regulators increasingly expect boards to approve and oversee cyber risk measures.

6. D Frequent amendments mean summaries can become outdated.

7. C Sector regulators set detailed expectations for regulated entities.

8. D CII designation brings specific obligations.

9. B Speech-related offences drew the most criticism and changes.

10. A Verification and legal review protect both the investigation and customers.

11. C Walkthroughs test whether the design addresses the risk, not whether it operated.

12. C Change management is a core ITGC; the three-way match is an application control.

13. D Cause identifies the root reason, guiding corrective action.

14. A CCM gives timely detection and reusable evidence.

15. B Monthly controls are usually tested with a small sample of occurrences.

16. C Boards govern through decisions; reports should make those explicit.

17. B Peers' spending does not reflect your threats, history or tolerance.

18. D 2 + (1 × 4) = 6 crore.

19. A Run covers the cost of operating current controls.

20. A Escalation criteria ensure timely, direct board awareness.

21. D A mission in business terms connects security to purpose.

22. C BISOs bring business intimacy while central functions keep consistency.

23. B Many symptoms stem from unclear ownership or decision rights.

24. C Urgent exposures and foundations come first.

25. D Early reporting of errors and near misses reduces harm.

Scenarios & case studies

Scenario · Which incident clock?
A is best. Best. Multiple obligations can run in parallel; a prepared matrix and legal advice prevent missed deadlines.

Scenario · A data request without paperwork
D is best. Best. It respects lawful requests while protecting customers from impersonation and unlawful disclosure.

Case study · Getting ready for personal data protection
The first three months should build a data inventory and data-flow maps, appoint accountable owners and a privacy lead, review notices and lawful bases for each processing purpose, assess security controls for national ID and transaction data, and prepare a breach assessment and notification procedure. Credit scoring, location tracking via agents, sharing with partner lenders and any use of biometrics or national ID data at scale are likely to need impact assessments. To stay robust, design to widely shared principles (minimisation, purpose limitation, security, transparency, accountability and rights handling) rather than to draft wording, track official rules through legal counsel and keep a change log so the plan can be adjusted when final requirements are published.

Scenario · A repeated audit finding
C is best. Best. It fixes the cause (manual, burdensome process) and gives continuous evidence, while accountability stays with the network head.

Scenario · The budget conversation
B is best. Best. Risk-based justification ties spending to the board's own appetite, which a percentage benchmark cannot do.

Copyright © ZyeemZia

Case study · Rebuilding board confidence

The first report should be short: overall position against an explicit cyber risk appetite, the top risks with owners and trends (quantified where possible), a handful of KRIs, an honest account of the card-fraud incident and lessons, programme status and clear decisions requested. Incident escalation should follow pre-agreed criteria so that material incidents reach the board chair or risk committee within hours, before media coverage. Reasonable first-year decisions include approving a cyber risk appetite with tolerances, approving a funded multi-year programme to close tolerance gaps, and approving the incident escalation and extortion policies, along with any risk acceptances above management's authority.

Scenario · Practice: the new CISO's first month

B is best. Best. It balances quick risk reduction with the governance foundations everything else depends on, and engages the people who own the risk.

Copyright © ZyeemZia

REFERENCE

Glossary

3

3-2-1-1-0 rule A backup principle: three copies, two media, one off-site, one immutable or offline, zero restore errors. (Endure)

A

ABAC Attribute-based access control: access decided from attributes of the user, resource and context. (Protect)

Access certification A periodic review in which owners confirm or revoke users' access. (Protect)

Accountability The duty to answer for an outcome; it cannot be delegated and sits with exactly one person per decision or risk. (Govern)

Active-active An architecture where two or more sites serve traffic simultaneously. (Endure)

Activity metric A count of work performed, useful for managing teams but weak for judging risk. (Operate)

Adversary emulation Reproducing the known behaviour of a specific threat group to test defences. (Operate)

After-action report A written record of what happened in an exercise or incident, findings and tracked actions. (Endure)

Annex A The reference list of 93 information security controls in ISO/IEC 27001:2022, grouped into organisational, people, physical and technological themes. (Govern)

Annualised loss expectancy The classic single-point expected yearly loss: single loss expectancy times annual rate of occurrence. (Quantify)

Architecture decision record A short document capturing a significant decision, its context, options and consequences. (Architect)

Assurance Evidence-based confidence that controls are designed and operating as intended. (Lead)

Attack surface All the points where an attacker could try to enter or extract data from an environment. (Operate)

Attestation A formal confirmation by a manager or owner that requirements are understood and met. (Govern)

Audit committee A board committee that oversees financial reporting, internal control and audit, often including cyber risk. (Lead)

Audit finding A documented control weakness with condition, criteria, cause, consequence and corrective action. (Lead)

Authoritative source The trusted system, usually HR, that triggers identity lifecycle events. (Protect)

B

Bangladesh Bank ICT security guideline The central bank's guidance setting ICT security expectations for banks and financial institutions. (Lead)

BGD e-GOV CIRT Bangladesh's national computer incident response team serving government and critical sectors. (Lead)

Birthright access Access granted automatically to everyone in a role on day one. (Protect)

BISO Business information security officer: a security leader embedded in a business unit. (Lead)

Blast radius The extent of damage an attacker or failure can cause from a single point of compromise. (Architect)

Board pack The set of papers provided to board members before a meeting, including risk reports and decision papers. (Lead)

Break-glass account An emergency account used only when normal access fails, protected and monitored closely. (Protect)

Broken object-level authorisation An API flaw where a user can access objects they do not own by changing identifiers in requests. (Architect)

Business continuity plan A documented plan for continuing critical business activities during and after disruption. (Endure)

Business impact analysis A process that assesses the impact of disruption over time and sets recovery priorities and objectives. (Endure)

Business owner of a supplier The person accountable for the relationship and for accepting its residual risk. (Extend)

BYOK Bring your own key: the customer controls encryption keys used by a cloud service through the provider's key service. (Protect)

C

Calibrated estimate A range given by a trained estimator whose stated confidence matches how often they are right. (Quantify)

Capability level A 0 to 5 rating of how well a process achieves its purpose and is defined, measured and improved. (Govern)

Capstone The final ZCSTG project in which learners design and defend a complete security strategy and governance programme. (Lead)

Carve-out A subservice organisation excluded from the scope of a supplier's assurance report. (Extend)

Copyright © ZyeemZia

Certification scope The defined boundary of organisation, locations, services and assets covered by an ISMS certificate. (Govern)

Chain of custody The documented handling of evidence from collection to presentation, proving it was not altered. (Operate)

CIS Controls A prioritised set of 18 cyber defence controls and 153 safeguards maintained by the Center for Internet Security. (Govern)

CISO Chief Information Security Officer: the executive responsible for the security programme, strategy and reporting on cyber risk. (Govern)

Clinical downtime procedures Manual processes that allow healthcare to continue safely when clinical systems are unavailable. (Endure)

CNAPP Cloud-native application protection platform: combined posture, workload and identity protection for cloud applications. (Architect)

COBIT ISACA's framework for governance and management of enterprise information and technology. (Govern)

Code signing Digitally signing software so users can verify its publisher and that it has not been altered. (Extend)

Community profile A shared target profile for a sector, threat or technology that organisations can adapt. (Govern)

Compensating control An alternative control that reduces risk when the required control cannot be applied. (Govern)

Complementary user entity control A control the customer must operate for the service organisation's controls to achieve their objectives. (Extend)

Concentration risk The risk that many critical services depend on the same provider or technology. (Extend)

Conditional access Access policy that considers conditions such as user risk, device state and location before granting access. (Architect)

Containment Actions that stop an incident from spreading or causing further harm. (Operate)

Continuous controls monitoring Automated, ongoing testing of controls using system data. (Lead)

Control coverage The degree to which preventive, detective and recovery controls address a given technique. (Quantify)

Crisis An event that threatens the organisation's strategy, reputation, finances or people and needs executive-level decisions. (Endure)

Crisis management team The executive group that sets strategy, priorities and communications during a crisis. (Endure)

Critical information infrastructure Computer systems designated by the government as vital, which carry additional security and reporting duties. (Lead)

Crosswalk A mapping between requirements in two or more frameworks showing where they overlap. (Govern)

Crypto-agility The ability to change algorithms and keys quickly without redesigning systems. (Protect)

CSF Core The hierarchy of functions, categories and subcategories describing desired cybersecurity outcomes. (Govern)

CSPM Cloud security posture management: tools that continuously check cloud configurations against policy. (Architect)

CTEM Continuous threat exposure management: a cycle of scoping, discovering, prioritising, validating and mobilising fixes. (Operate)

CVSS Common Vulnerability Scoring System: a standard for rating the technical severity of vulnerabilities. (Operate)

D

Data classification Assigning data to sensitivity levels that determine minimum protection requirements. (Protect)

Data custodian The person or team that operates systems storing data and applies controls set by the owner. (Protect)

Data governance The framework of ownership, policies and standards that ensures data is managed as an asset. (Protect)

Data loss prevention Technology and processes that detect and prevent unauthorised transfer of sensitive data. (Protect)

Data masking Replacing sensitive values with realistic but fictitious data, for example in test environments. (Protect)

Data owner The accountable person who decides classification, access and retention for a data set. (Protect)

Data protection officer A role that advises on and monitors compliance with data protection law within an organisation. (Protect)

Data residency Requirements about the geographic location where data is stored and processed. (Architect)

Decision log A record of decisions, their rationale and the information available at the time. (Endure)

Decision paper A concise paper asking a governing body for a specific decision, with options and a recommendation. (Lead)

Decision rights The documented authority to make specific decisions, such as accepting risk or approving exceptions, often with value thresholds. (Govern)

Defence in depth Using multiple independent layers of control so that a single failure does not lead to compromise. (Architect)

Copyright © ZyeemZia

Denominator problem Errors in the population a metric is measured against, such as an incomplete asset inventory. (Operate)

Dependency confusion Tricking build tools into pulling a public malicious package instead of an internal one with the same name. (Extend)

Design effectiveness Whether a control, as designed, would address the risk if performed correctly. (Lead)

Design factor A characteristic such as strategy, risk profile or sourcing model used to tailor a governance system. (Govern)

Detection as code Managing detection rules in version control with review, testing and automated deployment. (Operate)

Detection engineering The discipline of designing, building, testing and maintaining threat detections as managed products. (Operate)

Device posture The security state of a device, such as patch level, encryption and endpoint protection, used in access decisions. (Architect)

Disaster recovery The technical capability and plans to restore IT services after a disruptive event. (Endure)

DORA The EU Digital Operational Resilience Act for financial entities, covering ICT risk, incidents, testing and third parties. (Lead)

Double extortion Encrypting systems and also threatening to publish stolen data unless paid. (Endure)

DPIA Data protection impact assessment: a structured assessment of risks to individuals from high-risk processing. (Protect)

DSPM Data security posture management: tools that find sensitive data across cloud stores and assess its exposure. (Protect)

Due diligence Investigation of a supplier's security, resilience, financial, legal and other risks before contracting. (Extend)

Dwell time How long an attacker remains in an environment before being detected or removed. (Operate)

E

Envelope encryption Encrypting data with a data key and then encrypting that key with a key encryption key. (Protect)

EPSS Exploit Prediction Scoring System: a model estimating the probability that a vulnerability will be exploited soon. (Operate)

Eradication Removing the attacker's access, tools and persistence from the environment. (Operate)

Escalation criteria Pre-agreed conditions under which incidents or risks must be reported to senior leaders or the board. (Lead)

Essential cyber hygiene The IG1 baseline of safeguards that every organisation should implement to resist common attacks. (Govern)

Exit plan A documented plan for moving a service away from a supplier, in both planned and stressed situations. (Extend)

Extortion policy A pre-agreed board position on whether and how the organisation would respond to ransom demands. (Endure)

Extraterritorial effect When a law applies to organisations outside the country that made it, for example because they serve its residents. (Lead)

F

Failover Switching service from a primary to a secondary system or site. (Endure)

FAIR Factor Analysis of Information Risk, an open standard model that expresses risk as the probable frequency and magnitude of future loss. (Quantify)

False positive An alert that fires on benign activity. (Operate)

Federated model An operating model in which business units run security teams under central policy. (Lead)

Fourth party A supplier to your supplier, on which your service indirectly depends. (Extend)

Full-time equivalent A unit expressing staffing as the number of full-time workers needed. (Operate)

G

GDPR The EU General Data Protection Regulation, governing processing of personal data of people in the EU. (Lead)

Gold, silver, bronze A three-level command structure: strategic, tactical and operational. (Endure)

Govern function The CSF 2.0 function covering context, risk strategy, roles, policy, oversight and supply-chain risk management; it informs the other five. (Govern)

Governance objective A COBIT-style objective for the governing body: evaluate options, direct management and monitor results. (Govern)

Governing body The board or equivalent group that sets direction, approves appetite and holds management to account. (Govern)

Guardrail An automated policy that prevents, detects or corrects actions outside agreed security rules. (Architect)

H

Hardware security module A tamper-resistant device that generates and protects keys and performs cryptographic operations. (Protect)

Harvest now, decrypt later Collecting encrypted data today to decrypt it once more powerful computing becomes available. (Protect)

Copyright © ZyeemZia

HMI Human-machine interface: the screens and software operators use to monitor and control a process. (Architect)

Holding statement A short, pre-approved initial statement acknowledging an incident while facts are gathered. (Endure)

Hot debrief An immediate review held at the end of an exercise or incident while memories are fresh. (Endure)

Hybrid SOC An operating model combining internal security staff with an external provider. (Operate)

I

ICT Act 2006 Bangladesh's early law recognising electronic records and digital signatures and defining computer offences, later amended. (Lead)

Identity governance and administration Processes and tools that manage the identity lifecycle, access requests, reviews and evidence of appropriate access. (Protect)

Immutable backup A backup copy that cannot be altered or deleted for a defined retention period. (Endure)

Impact tolerance The maximum tolerable level of disruption to an important business service, often set as a time limit. (Endure)

Implementation group One of three CIS tiers (IG1 to IG3) indicating which safeguards suit an organisation's resources and risk. (Govern)

Implementation tier One of four levels (Partial, Risk informed, Repeatable, Adaptive) describing the rigour of cyber risk practices. (Govern)

Implicit trust Access granted simply because a user or device is inside a network or zone, without verification. (Architect)

Important business service A service provided to external customers or users whose disruption would cause intolerable harm. (Endure)

Incident notification clause A contract term requiring the supplier to report incidents affecting the customer within a set time. (Extend)

Incident response plan The documented approach, roles and decision rights for handling security incidents. (Operate)

Industrial control system Systems such as PLCs, SCADA and distributed control systems used to operate industrial processes. (Architect)

Industrial DMZ A buffer zone between enterprise and control networks where data is brokered so no traffic passes directly. (Architect)

Informative reference A mapping from a CSF outcome to a specific clause or control in another standard or guide. (Govern)

Inherent risk The risk level before considering controls; useful mainly to show how much controls matter. (Quantify)

Inherent supplier risk The risk a supplier relationship carries before considering the supplier's controls, based on data, access and criticality. (Extend)

Inject A scripted development introduced during an exercise to test decisions. (Endure)

ISMS Information security management system: the policies, processes, roles and controls used to manage information security risk and improve continually. (Govern)

ISO/IEC 27001 The international standard specifying requirements for establishing, running and improving an ISMS; organisations can be certified against it. (Govern)

IT general controls Foundation controls over access, change management and IT operations that support application controls. (Lead)

J

Joiner-mover-leaver The lifecycle events of starting, changing role and leaving that should drive access changes. (Protect)

Just-in-time access Granting elevated access only for a specific task and time window, then removing it automatically. (Protect)

K

Key management The governance and processes for generating, storing, distributing, rotating and destroying cryptographic keys. (Protect)

Key risk indicator A metric that signals increasing risk exposure before a loss occurs. (Quantify)

Known exploited vulnerability A vulnerability with reliable evidence of active exploitation in the wild. (Operate)

KPI Key performance indicator: a measure of how well a process performs against a target. (Operate)

KRI Key risk indicator: a measure signalling that risk exposure is approaching tolerance. (Operate)

L

Landing zone A pre-configured, governed cloud environment with identity, network, logging and policy foundations for workloads. (Architect)

Law-enforcement request procedure A documented process for verifying and legally reviewing requests from authorities for customer data. (Lead)

Lawful basis The legal ground, such as consent or contract, that permits processing of personal data. (Protect)

Least privilege Granting only the minimum access needed for the minimum time required. (Architect)

Lessons learned A structured post-incident review that produces tracked improvements. (Operate)

Copyright © ZyeemZia

Lognormal distribution A right-skewed distribution often used for loss sizes because most losses are small but a few are very large. (Quantify)

Loss event frequency How often, within a time frame, a threat event is expected to result in loss. (Quantify)

Loss exceedance curve A chart showing the probability that annual losses will exceed each possible amount. (Quantify)

Loss scenario A specific, plausible story of a threat event and its business consequence that can be estimated. (Quantify)

M

Management review A planned review by top management of ISMS performance, risks, audit results and improvement opportunities. (Govern)

Materiality The significance of an event to investors or the organisation, which can trigger disclosure duties. (Lead)

MBCO Minimum business continuity objective: the minimum acceptable service level during disruption. (Endure)

MDR Managed detection and response: an external service that monitors, investigates and performs response actions. (Operate)

Micro-segmentation Fine-grained segmentation that applies policy at the level of individual workloads or application tiers. (Architect)

MITRE ATT&CK A public knowledge base of adversary tactics and techniques based on real-world observations. (Quantify)

Monte Carlo simulation A method that repeatedly samples from input distributions to build the distribution of an outcome, such as annual loss. (Quantify)

MSSP Managed security service provider: an external company that operates security services such as monitoring for customers. (Operate)

MTPD Maximum tolerable period of disruption: the time after which impact becomes unacceptable. (Endure)

MTTC Mean time to contain: average time from detection to containment of an incident. (Operate)

MTTD Mean time to detect: average time from the start of a compromise to its detection. (Operate)

N

National Cyber Security Agency Bangladesh's national authority for cyber security under the cyber law (check current mandate). (Lead)

Near miss An event that could have caused loss but was stopped or did not do so; valuable risk evidence. (Quantify)

Net present value The value today of future benefits minus costs, discounted at the organisation's cost of capital. (Lead)

NIS2 The EU directive setting cyber risk-management and incident reporting duties for essential and important entities. (Lead)

NIST CSF 2.0 A voluntary, outcome-based cybersecurity framework from the US National Institute of Standards and Technology, released in 2024 with six functions. (Govern)

Non-human identity An identity used by software rather than a person, such as a service account, API key or workload role. (Protect)

Nonconformity A failure to meet a requirement of the standard or of the organisation's own ISMS; major ones can block certification. (Govern)

O

Obligations register A record of regulatory and contractual obligations mapped to controls, owners and evidence. (Lead)

Offboarding Ending a supplier relationship safely, including access removal and data return or destruction. (Extend)

Operating effectiveness Whether a control actually operated consistently as designed over a period. (Lead)

Operating model How security responsibilities, people, processes and reporting lines are organised. (Lead)

Operational resilience The ability to deliver important business services through disruption, or recover them within tolerable limits. (Endure)

Operational technology Hardware and software that monitors and controls physical devices and processes. (Architect)

Ordinal scale A ranking scale such as 1 to 5 where numbers show order but not size; arithmetic on them is misleading. (Quantify)

Ordinance A law issued by the executive when parliament is not in session, which has legal force subject to later legislative processes. (Lead)

Organisational profile A description of an organisation's current or target cybersecurity outcomes, used to find and prioritise gaps. (Govern)

Out-of-band communication Communication channels separate from potentially compromised corporate systems. (Operate)

Outsourcing Using an external provider to perform a function the organisation would otherwise perform itself. (Extend)

P

Passkey A FIDO-based credential stored on a device or synced securely that replaces passwords and resists phishing. (Protect)

Percentile The value below which a given percentage of simulated outcomes fall; the 95th percentile is a 1-in-20 bad year. (Quantify)

Copyright © ZyeemZia

Personal data Any information relating to an identified or identifiable living person. (Protect)

Phishing-resistant MFA Authentication, such as FIDO2 keys or passkeys, that cannot be relayed by a fake website. (Protect)

Playbook Step-by-step guidance for responding to a specific type of incident. (Operate)

PLC Programmable logic controller: a ruggedised computer that controls machinery and processes. (Architect)

Poisson distribution A distribution commonly used to model the number of events in a fixed period at a given average rate. (Quantify)

Policy architecture A layered structure of policies, standards, procedures and guidelines with clear owners and approval levels. (Govern)

Policy as code Expressing security and compliance rules in machine-readable code that can be tested and enforced automatically. (Architect)

Policy decision point The logical component, made up of the policy engine and policy administrator, that decides whether a session is allowed. (Architect)

Policy enforcement point The component that intercepts requests and allows or blocks sessions according to the decision. (Architect)

Policy exception A documented, time-limited and approved deviation from a policy or standard with accepted risk. (Govern)

Pooled audit An audit of a supplier performed jointly on behalf of several customers to share cost and effort. (Extend)

Post-quantum cryptography Algorithms designed to resist attack by quantum computers, such as those standardised by NIST in 2024. (Protect)

Precision The share of alerts from a detection that are true positives. (Operate)

Primary loss Loss borne directly by the organisation as a result of the event, such as downtime and response costs. (Quantify)

Privacy by design Building privacy protections into systems and processes from the start rather than adding them later. (Protect)

Privileged access management Controls and tools that minimise, broker, monitor and record the use of high-level privileges. (Protect)

Procedure Step-by-step instructions for performing a task in line with a standard. (Govern)

Protect surface The small set of critical data, applications, assets and services that a zero trust programme protects first. (Architect)

Provenance Verifiable information about where, when and how a software artefact was built. (Extend)

Pseudonymisation Processing data so it cannot be linked to a person without separately held additional information. (Protect)

Psychological safety A climate in which people can report mistakes and concerns without fear of blame. (Lead)

Purple teaming Collaborative exercises in which attackers and defenders test and improve detections together. (Operate)

Purpose limitation The principle that data collected for one purpose should not be reused for incompatible purposes. (Protect)

R

Range compression The heat-map effect where very different risks fall into the same score or cell. (Quantify)

Ransomware Malicious software or an attack that encrypts data or systems to extort payment, often combined with data theft. (Endure)

RBAC Role-based access control: access granted through roles that match job functions. (Protect)

Reference architecture A reusable, approved design pattern for a common problem, including zones, controls and variations. (Architect)

Remediation SLA The agreed maximum time to fix or mitigate a vulnerability of a given category. (Operate)

Residual risk The risk that remains after treatment and existing controls are taken into account. (Quantify)

Retention schedule Rules stating how long each type of data is kept and when it must be destroyed. (Protect)

Right to audit A contractual right for the customer or its regulator to audit a supplier's relevant controls. (Extend)

Risk The effect of uncertainty on objectives; in cyber, the possibility of loss when a threat exploits a weakness. (Quantify)

Risk acceptance A documented decision by an authorised owner to retain a risk, usually time-limited and reviewed. (Quantify)

Risk appetite The amount and type of risk an organisation is willing to pursue or retain to meet its objectives, set by the board. (Quantify)

Risk capacity The maximum level of loss an organisation can absorb before failing its obligations or survival. (Quantify)

Risk criteria The terms of reference, including appetite and rating scales, against which risks are evaluated. (Quantify)

Risk owner The person with the authority and budget to decide how a specific risk is treated and to accept what remains. (Govern)

Copyright © ZyeemZia

Risk register The managed record of identified risks with owners, ratings, treatments and status. (Quantify)

Risk tolerance A measurable limit that turns appetite into thresholds for specific risks or metrics. (Quantify)

Risk tolerance curve A board-defined curve of the maximum acceptable probability of exceeding each loss level. (Quantify)

Risk transfer Sharing the financial consequences of a risk with another party, such as an insurer or supplier. (Quantify)

Risk-based budgeting Allocating security funds to the controls that most efficiently bring top risks within tolerance. (Lead)

Risk-based vulnerability management Prioritising remediation by exploitation likelihood, asset value and exposure rather than severity alone. (Operate)

Roadmap horizon A time band such as now, next and later used to sequence initiatives. (Lead)

ROSI Return on security investment: risk reduction minus cost, divided by cost. (Quantify)

RPO Recovery point objective: the maximum acceptable amount of data loss, measured in time. (Endure)

RTO Recovery time objective: the target time to restore a service, system or activity. (Endure)

Run, grow, transform A budgeting structure separating keeping current controls running, closing gaps and strategic change. (Lead)

S

Safeguard A specific, measurable action within a CIS Control, such as maintaining a software inventory. (Govern)

Safety instrumented system An independent control system that brings a process to a safe state when dangerous conditions arise. (Architect)

Sampling Testing a selection of control occurrences to draw conclusions about the whole population. (Lead)

SASE Secure access service edge: the convergence of SSE security services with software-defined WAN networking. (Architect)

SBOM Software bill of materials: a machine-readable inventory of components and versions in a software product. (Extend)

Secondary loss Loss arising from reactions of external parties such as regulators, customers or litigants. (Quantify)

Secrets vault A secured system that stores, issues and rotates credentials and keys for people and applications. (Protect)

Secure development lifecycle A software process that builds security activities into every phase from requirements to operation. (Architect)

Security architecture The design of how security controls, technology and processes fit together across the enterprise to meet business goals within risk appetite. (Architect)

Security champion A developer or engineer in a delivery team who promotes and supports secure practices. (Architect)

Security governance The system by which leaders direct and oversee security so it supports objectives, stays within risk appetite and meets obligations. (Govern)

Security level In IEC 62443, the target strength of protection for a zone, from SL1 to SL4. (Architect)

Security management Planning, organising and running the security activities that carry out governance direction. (Govern)

Security operations centre The function that monitors, detects, investigates and responds to security threats. (Operate)

Security rating An external score of an organisation's observable security hygiene, based on internet-facing signals. (Extend)

Security service edge A cloud-delivered set of security services such as secure web gateway, CASB and zero trust network access. (Architect)

Security strategy A plan linking security outcomes, priorities and investments to business goals over several years. (Lead)

Segmentation Dividing networks or systems into zones with controlled communication to limit the spread of attacks. (Architect)

Segregation of duties Splitting conflicting tasks between different people so one person cannot complete a sensitive process alone. (Protect)

Sensitive personal data Categories such as health, biometrics, religion or financial details that need extra protection under many laws. (Protect)

Severity level A classification of incident impact that drives escalation, decision rights and notification. (Operate)

Shadow IT Technology services used without the knowledge or approval of the organisation's IT and security functions. (Architect)

Shared responsibility model The division of security duties between cloud provider and customer, which varies by service model. (Architect)

SLSA Supply-chain Levels for Software Artifacts: a framework of increasing build integrity requirements. (Extend)

SOC 2 report An independent auditor's report on a service organisation's controls relevant to security, availability, processing integrity, confidentiality or privacy. (Extend)

Copyright © ZyeemZia

Software supply chain Everything involved in producing and delivering software: source, dependencies, build systems, signing and distribution. (Extend)

Spokesperson The designated person who speaks for the organisation to media and the public. (Endure)

Stakeholder map A list of groups affected by a crisis with their needs, channels and timing. (Endure)

Standard A mandatory, measurable requirement that implements a policy, such as minimum encryption settings. (Govern)

Standing privilege Privileged rights that remain permanently assigned whether or not they are being used. (Protect)

Statement of Applicability A document listing each control, whether it is applicable, why, and its implementation status. (Govern)

Stressed exit Leaving a supplier suddenly because of failure, breach or legal action, with little cooperation. (Extend)

STRIDE A threat modelling mnemonic: spoofing, tampering, repudiation, information disclosure, denial of service and elevation of privilege. (Architect)

Sub-processor A third party engaged by a supplier to process your data on its behalf. (Extend)

Subcategory The most specific CSF outcome statement, used for assessment and target setting. (Govern)

Supplier tiering Classifying suppliers by inherent risk to decide the depth and frequency of assurance. (Extend)

Supply-chain attack An attack that compromises a trusted supplier or its products to reach the supplier's customers. (Extend)

Surveillance audit A periodic audit by the certification body between recertifications to confirm the ISMS still works. (Govern)

Susceptibility The probability that a threat event becomes a loss event, driven by threat capability versus resistance strength. (Quantify)

T

Tabletop exercise A discussion-based exercise in which participants walk through a scenario. (Endure)

Tactics, techniques and procedures The behaviour of an adversary: its goals, the methods it uses and its specific implementations. (Quantify)

Tail risk The risk of rare, very large losses at the extreme end of the distribution. (Quantify)

Telemetry Logs, events and signals collected from systems for monitoring and analysis. (Operate)

Third-party risk management The discipline of identifying, assessing, controlling and monitoring risks arising from suppliers and partners. (Extend)

Threat Anything capable of acting against an asset to cause harm, such as a criminal group, insider or natural event. (Quantify)

Threat community A group of threat agents with similar goals and methods, such as ransomware groups or insiders. (Quantify)

Threat event frequency How often, within a time frame, threat agents are expected to act against an asset. (Quantify)

Threat hunting Proactive searching for threats that have evaded existing detection, based on hypotheses. (Operate)

Threat intelligence Evidence-based knowledge about threats, their capabilities and intentions, used to inform decisions. (Quantify)

Threat modelling A structured method to identify threats to a system by analysing its components, data flows and trust boundaries. (Architect)

Threat-informed defence Prioritising controls and detection according to the techniques of the most relevant adversaries. (Quantify)

Threat-led penetration testing Intelligence-driven red-team testing of live production systems required for some financial firms. (Lead)

Three lines model An accountability model separating risk ownership (first line), oversight and challenge (second line) and independent assurance (third line). (Govern)

Tokenisation Replacing a sensitive value with a non-sensitive token that maps back to it only in a secured vault. (Protect)

Total cost of ownership The full cost of a solution over its life, including purchase, operation, people and support. (Lead)

Triage The rapid assessment of alerts to decide which need investigation and in what order. (Operate)

Trust boundary A point in a system where data or control passes between areas with different levels of trust. (Architect)

Type I report An attestation that controls were suitably designed at a specific point in time. (Extend)

Type II report An attestation that controls were suitably designed and operated effectively over a period of time. (Extend)

Typosquatting Publishing malicious packages with names similar to popular ones to trick developers or tools. (Extend)

U

Unified control framework A single library of controls, each mapped to all the frameworks and obligations it satisfies. (Govern)

Use case A defined detection scenario linking a threat behaviour to data, logic, response and owner. (Operate)

Copyright © ZyeemZia

V

Validated coverage The share of priority techniques shown by testing to be detected. (Operate)

VEX Vulnerability exploitability exchange: a statement of whether a known vulnerability affects a specific product. (Extend)

Virtual patch A temporary control, such as a WAF or IPS rule, that blocks exploitation until a fix is applied. (Operate)

Vulnerability A weakness that a threat could exploit, in technology, process or people. (Quantify)

W

Warm standby A scaled-down but running copy of the production environment ready to take over. (Endure)

Watermelon metric A metric that looks green on dashboards while the underlying reality is poor. (Operate)

Z

Zero trust A security strategy that removes implicit trust based on network location and grants access per request based on policy and context. (Architect)

Zone and conduit Grouping of assets with similar security needs (zone) and the controlled communication path between groups (conduit). (Architect)

Copyright © ZyeemZia

CAPSTONE

Capstone: Security strategy and governance programme for a regulated organisation

Design and defend a three-year security strategy and governance programme for a fictional regulated organisation (for example a mobile financial service, a hospital group or a power generation company in South Asia), covering every blueprint sheet, with quantified risk, an architecture roadmap, a budget and a board presentation.

Deliverables

☐ Governance charter: decision rights, three lines, policy architecture and framework profile

☐ Top-ten cyber risk scenarios with FAIR-style estimates and a loss exceedance view

☐ Target security architecture with zero-trust, cloud and OT roadmaps

☐ Identity, data protection and privacy programme with a sample DPIA

☐ Third-party and software supply-chain risk process with tiering and exit plans

☐ Security operations model, metrics catalogue and KRIs linked to appetite

☐ Business impact analysis, resilience strategy and crisis playbook

☐ Regulatory obligations map, including Bangladesh law where relevant, and an assurance plan

☐ Three-year budget, business case and programme roadmap

☐ Ten-slide board presentation and a defence of the three hardest trade-offs

Self-assessment rubric

CRITERION	DEVELOPING	PROFICIENT	EXCELLENT
Governance	○ Undefined roles	○ Roles and policies set	○ Clear decision rights, owned risks and lean controls
Risk quantification	○ Heat map only	○ Scenarios estimated	○ Calibrated ranges, tail risk and investment comparison
Architecture	○ Tool list	○ Coherent target state	○ Phased zero-trust, cloud and OT roadmap traced to risk
Identity and data	○ Ad hoc access	○ Lifecycle and classification in place	○ Privilege minimised, data and privacy by design
Third parties	○ Questionnaires only	○ Tiered assessments	○ Lifecycle, software supply chain and concentration managed
Operations and metrics	○ Activity counts	○ Useful KPIs	○ Outcome metrics and KRIs tied to appetite
Resilience and compliance	○ Untested plans	○ Tested plans, obligations mapped	○ Impact tolerances met, assured and regulator-ready
Leadership and communication	○ Technical jargon	○ Clear plan	○ Funded, sequenced programme with a compelling board story

Copyright © ZyeemZia

CAPSTONE

Planning pages

Sketch your design, timeline or architecture here.

Copyright © ZyeemZia

EXAM PREPARATION

Practice exam · 60 questions

The official online exam draws 45 questions at random from a separate, secret bank that tests the same skills, with a 90-minute limit and a 85% pass mark. Practise with these questions first: time yourself, mark your answers, then check the key and read every explanation, including for the questions you got right.

Govern — Security Governance and Frameworks

1. At a hospital group, the CIO tells the board that cyber risk is 'under control' because 95% of laptops have endpoint protection. The board's risk committee wants a meaningful view of cyber risk. What should the CISO propose FIRST?

   (A) Quarterly reporting of top risks to clinical services, with owners and appetite status

   (B) A monthly dashboard showing every security tool's coverage percentage across all sites and device types

   (C) An annual penetration test summary presented directly to the board by the testing vendor

   (D) A comparison of the security budget against published industry spending benchmarks

2. A telecom operator's internal audit team has been asked to design and run the new access-review process because 'they understand controls best'. What is the main governance concern?

   (A) Audit staff usually lack the technical skills needed to run access reviews on network equipment

   (B) Audit would later assess a control it designed and runs

   (C) Access reviews must always be run personally by the CISO

   (D) The regulator forbids internal audit from ever reviewing access controls

3. A regional power distribution company wants one framework to explain its security programme in plain outcome language to the board and the regulator, with current and target states. Which is the BEST fit?

   (A) CIS Controls implementation group 3 safeguards for every system

   (B) ISO/IEC 27001 Annex A technological controls only

   (C) COBIT capability assessments of every IT process in the company

   (D) NIST CSF 2.0 profiles with chosen target tiers

4. During ISO/IEC 27001 preparation, a consultant offers a complete set of risk assessments and an SoA copied from another client in the same industry. What is the BEST response?

   (A) Adopt them as they are, since the industry, regulators and threat actors are the same

   (B) Adopt them but ask the certification auditor to waive the evidence requirements

   (C) Use them as reference only and run the organisation's own risk assessment

   (D) Reject Annex A entirely and use the consultant's control list instead

5. A fintech has 300 staff, a small IT team and no security specialists. Ransomware attempts are rising. The CEO asks which technical safeguards to implement first. What should the security lead recommend?

   (A) CIS Controls IG1 safeguards: inventory, MFA, patching, recoverable backups

   (B) Start an ISO/IEC 27001 certification project covering the entire company and all its suppliers

   (C) Assess every COBIT objective to capability level 3 before buying anything

   (D) Build a 24x7 internal security operations centre

6. A university's information security policy is 46 pages long, mixes board principles with firewall port rules and has not been approved since 2019. What is the BEST improvement?

   (A) Add a new chapter on cloud security and send the whole document for board re-approval

   (B) Publish it on the intranet with a mandatory read receipt for all staff

   (C) Replace it with the ISO/IEC 27002 control text

   (D) A short approved policy, with technical rules moved into owned standards

Copyright © ZyeemZia

7. An MFS provider's security team approves policy exceptions itself and none has an expiry date. Two years later there are 210 open exceptions. Which change addresses the root cause?

   (A) Have the security team carefully re-review all 210 open exceptions before the next audit
   (B) Ban all exceptions to the policy in the future
   (C) Risk-owner approval at set thresholds, expiry dates and ageing reports
   (D) Move the exception list into a new GRC tool with better dashboards

8. A bank must comply with central-bank ICT guidance, PCI DSS and ISO/IEC 27001, and receives customer questionnaires. Each compliance team tests the same firewall review separately. What should the GRC lead implement?

   (A) A separate compliance team for every framework, each with its own calendar and evidence store
   (B) A unified control framework with evidence collected once
   (C) An outsourced audit of each framework every quarter
   (D) A policy that customer questionnaires will no longer be answered

Quantify — Risk Assessment and Cyber-Risk Quantification

9. An insurer's CISO presents a 5x5 heat map with two risks in the same red cell. One could cost BDT 80 lakh, the other BDT 60 crore. The CFO asks why they look equal. What is the BEST explanation and next step?

   (A) The heat map is correct because both risks have the same likelihood score assigned by the workshop
   (B) Add a sixth impact level to the matrix for very large losses
   (C) Ordinal scoring compresses ranges; quantify both as money ranges
   (D) Average the two impacts and show one combined risk

10. The board of an MFS provider approves 'low appetite for payment disruption'. Operations asks how it will know when appetite is close to being breached. What should be defined next?

    (A) Measurable tolerances and key risk indicators linked to them
    (B) A longer appetite statement covering every system in the company in detail
    (C) A new insurance policy with higher limits
    (D) An annual penetration test

11. A risk owner wants to accept a risk that sits outside the board's appetite because the fix is expensive. What should happen?

    (A) Allow the risk owner to accept it, as the owner understands the business best and holds the budget
    (B) Record it as accepted and inform the board next year
    (C) Transfer it by buying insurance with no further discussion
    (D) Escalate to the board or its risk committee for decision

12. In a FAIR-style analysis, threat event frequency is 20 per year and susceptibility is 5%. Primary loss per event is BDT 4 crore and there is a 25% chance of a BDT 8 crore secondary loss. What is the expected annual loss?

    (A) BDT 4 crore
    (B) BDT 6 crore
    (C) BDT 12 crore
    (D) BDT 24 crore

13. A workshop participant gives a 90% confidence range of 'exactly 3 incidents' for next year. What should the facilitator do?

    (A) Accept the estimate, because precise numbers make the model easier to explain to the board
    (B) Replace it with the industry average without discussion
    (C) Ask for a range wide enough to be right about 90% of the time
    (D) Exclude the participant from future workshops

Copyright © ZyeemZia

14. A Monte Carlo shows mean annual cyber loss of BDT 5 crore but a 1-in-20 loss of BDT 45 crore. The board tolerance is BDT 30 crore at 1-in-20. What is the correct conclusion?

(A) Risk is within appetite because the mean is well below BDT 30 crore
(B) Risk is outside tolerance even though the mean looks manageable
(C) The simulation should be rerun until the tail falls below BDT 30 crore
(D) Tail results should be ignored because they are rare

15. Two controls each reduce expected loss by BDT 4 crore when assessed alone. The team reports that together they will save BDT 8 crore. What is the main flaw?

(A) Savings must always be multiplied, not added, so the true combined figure is BDT 16 crore
(B) ROSI cannot be calculated for two controls
(C) Savings should be reported only as percentages
(D) Overlapping controls rarely give additive savings

Architect — Security Architecture, Zero Trust, Cloud and OT

16. A bank's architecture review board is a bottleneck, and teams are bypassing it. Most requests are for common designs such as internal web apps. What is the BEST way to restore governance without slowing delivery?

(A) Approved reference patterns with self-certification for conforming designs
(B) Require every team to attend the monthly board in person with a full design pack, however simple the change
(C) Replace reviews with a penetration test before go-live
(D) Allow each team's lead developer to approve designs

17. A power company starting zero trust has a flat network and VPN access to everything for staff and contractors. Which step reduces implicit trust MOST in the first phase?

(A) Replace all firewalls with new devices marketed as zero trust and keep the existing access rules
(B) Micro-segment every workload in one release
(C) Wait for legacy systems to be retired
(D) Per-application access with phishing-resistant MFA for admins and contractors

18. Ransomware at a logistics company spread from one laptop to every server within hours. Leadership asks for an architectural fix. Which proposal BEST limits the blast radius?

(A) Buy more antivirus licences so that every server and laptop runs two separate products
(B) Increase password length to 20 characters
(C) Segment critical zones, starting from real flow data in monitor mode
(D) Block internet access for all staff

19. An e-commerce firm learns that customers can view others' orders by changing a number in an API call. Beyond fixing the bug, what governance change addresses the root cause?

(A) Ask the developer who wrote the API to be more careful in future and sign a declaration
(B) An API inventory, threat modelling and API authorisation testing before release
(C) Move the API to a different cloud provider
(D) Hide order numbers in the user interface

20. A hospital moves email to a SaaS platform. The CIO says 'the provider is now responsible for our email security'. Which responsibility stays with the hospital?

(A) Managing identities, access and data sharing settings
(B) Patching the servers that run the provider's mail service in its data centres
(C) Physical security of the provider's buildings
(D) Maintaining the provider's network hardware

21. Cloud teams at a telecom keep creating public storage buckets that are later found by researchers. Detective alerts are ignored. What is the MOST effective control?

(A) Send the weekly misconfiguration report to a larger distribution list including senior managers
(B) An organisation-level preventive guardrail blocking public buckets, with an exception route
(C) Train cloud engineers once a year
(D) Ask the provider to monitor the buckets

Copyright © ZyeemZia

22. A textile mill's PLC network is directly reachable from the corporate network so the ERP can read production counts. What should the security architect recommend?

(A) Install the corporate endpoint agent on every PLC and controller so they are monitored like laptops
(B) Allow the connection but change the PLC passwords monthly
(C) Disconnect the ERP from production data permanently
(D) An industrial DMZ that brokers production data so no traffic crosses directly

23. A hospital's new imaging-device vendor requests permanent VPN access to the clinical network. What is the BEST response?

(A) Brokered, approved and recorded access to the device's segment only, under contract
(B) Grant the VPN because the vendor holds a security certification and has many hospital customers
(C) Refuse all remote support
(D) Grant access but review logs once a year

Protect — Identity, Data Protection and Privacy

24. An audit at a bank finds that a branch manager promoted to head-office treasury two years ago can still approve branch cash transactions. Which control failure does this show MOST clearly?

(A) The joiner process gave the manager too little access when they first started at the branch
(B) Password complexity rules were too weak
(C) The mover process did not remove old access
(D) The leaver process failed

25. Quarterly access reviews at an insurer show 99.7% approvals, yet audit finds dozens of inappropriate entitlements. What is the MOST effective redesign?

(A) Require every manager to review every entitlement in every system each month and sign a declaration
(B) Let the IAM team approve all access centrally
(C) Risk-focused reviews with plain-language entitlements, usage data and SoD flags
(D) Remove reviews and rely on audit

26. Attackers phished an MFS provider's finance staff with a fake login page that relayed authenticator-app codes in real time. Which control would have defeated this attack?

(A) A longer one-time code with eight digits instead of six, refreshed every thirty seconds
(B) Phishing-resistant MFA such as FIDO2 keys or passkeys
(C) SMS codes instead of app codes
(D) Quarterly phishing awareness videos

27. A cloud breach at a software firm began with an API key committed to a public code repository four years earlier. The key had full administrative rights. Which combination addresses the root causes?

(A) Rotate the leaked key and keep using static keys for all other systems as before
(B) Make the repository private
(C) Require developers to sign a secrets policy
(D) Short-lived workload credentials, secrets scanning and least-privilege roles

28. A hospital's staff paste patient summaries into a public AI chatbot to draft discharge letters. What is the BEST governance response?

(A) Provide an approved AI tool with data controls, set rules by classification and monitor uploads
(B) Block every AI-related website at the firewall and discipline any staff member found using one
(C) Ignore it because the chatbot is popular
(D) Ask the chatbot provider to delete the data

29. A government land registry signs digital land records that must remain trustworthy for decades. Which cryptographic action should be prioritised?

(A) Increase the RSA key length once and treat the matter as permanently solved
(B) Stop signing records digitally
(C) Wait for regulators to issue a deadline
(D) Inventory signing systems and plan post-quantum migration with crypto-agility

Copyright © ZyeemZia

30. A telecom wants to use subscribers' location history for targeted advertising sold to third parties. What should happen BEFORE processing starts?

(A) Encrypt the location data and proceed, because encryption satisfies data protection law in full
(B) A DPIA with a confirmed lawful basis, transparency and safeguards
(C) Inform subscribers after the campaign launches
(D) Seek approval from the IT steering committee only

Extend — Third-Party and Supply-Chain Risk

31. A TPRM team sends the same 280-question questionnaire to all 1,400 suppliers. Critical suppliers receive no deeper review, and response rates are low. What should the team change FIRST?

(A) Tier suppliers by inherent risk and scale assurance to the tier
(B) Shorten the questionnaire to 50 questions and send it to every supplier twice a year instead
(C) Hire more analysts to read all responses
(D) Stop assessing suppliers and rely on contracts

32. A business unit signs a SaaS contract and uploads customer data before security is informed. Which process control would prevent this MOST effectively?

(A) Security reviews all purchase orders after payment, looking for unapproved software suppliers
(B) Annual awareness training for business units
(C) Procurement cannot issue orders for higher-tier suppliers until TPRM is complete
(D) A clause in the code of conduct

33. A supplier's SOC 2 Type II report is unqualified, but its hosting provider is carved out. The service is critical. What should the TPRM lead do?

(A) Accept the report because an unqualified opinion covers all of the supplier's dependencies
(B) Assess the hosting provider separately as a critical fourth party
(C) Reject the supplier because carve-outs are not allowed
(D) Ask the auditor to reissue the report

34. A clinic's cloud booking supplier's assurance report lists a CUEC requiring customers to remove leavers' access promptly. The clinic has no leaver process for the platform. What is the implication?

(A) The supplier's controls may not achieve their objectives until the clinic fixes its leaver process
(B) None, because the supplier is responsible for all user access to its platform
(C) The report is invalid
(D) The clinic should change supplier

35. A new critical flaw appears in a popular open-source library. A telecom needs to know within a day which products, including bought software, are affected. Which capability matters MOST?

(A) A contract clause requiring suppliers to declare that their products are free of all vulnerabilities
(B) An annual code review
(C) A firewall rule blocking the library's website
(D) Central, queryable SBOMs for in-house apps and supplier products

36. An internal package named 'payments-core' is replaced in builds by a public package with the same name containing malware. Which control would have prevented this?

(A) Running antivirus on developer laptops and requiring weekly full-disk scans
(B) Rotating developer passwords
(C) Resolving internal names only from a private registry with pinned versions
(D) Increasing code review time

37. A central bank asks a commercial bank how it would keep payments running if its card-processing provider failed suddenly. The bank has only a planned-exit clause in the contract. What is missing?

(A) A tested stressed-exit and continuity plan for the service
(B) A longer contract term with the current provider so that it is less likely to leave the market
(C) A higher liability cap
(D) A pooled audit

Copyright © ZyeemZia

38. A logistics firm learns from the news that its file-transfer supplier is being mass-exploited. The supplier is silent. What should the firm do FIRST?

(A) Wait for formal notice from the supplier, as required by the contract, before taking any action
(B) Identify affected data and connections, then contain by suspending integrations and rotating credentials
(C) Terminate the contract at once
(D) Announce publicly that customers are not affected

Operate — Security Operations Strategy and Metrics

39. A mid-sized hospital wants 24x7 security monitoring but has a five-person security team. The CFO asks for the most realistic model. What should the CISO recommend?

(A) Build an internal 24x7 SOC by asking the five staff to rotate night shifts every week
(B) Monitor only during office hours
(C) A hybrid model with MDR for round-the-clock monitoring and internal ownership of escalation
(D) Outsource all incident decisions to the provider

40. A SOC reports 90% coverage of a public technique matrix based on rules installed. A purple-team test detects 8 of 25 emulated techniques. What should be reported to leadership?

(A) The 90% figure, because rules exist and the purple-team test used an unrealistic environment
(B) Nothing until all gaps are fixed
(C) That a new SIEM is required
(D) Validated detection of about one-third for the tested threat, with a plan to close gaps

41. During a SEV1 ransomware incident at night, the SOC cannot reach anyone authorised to isolate the core billing system. What is the root cause in the incident response plan?

(A) No named deputies and criteria for business-impacting containment
(B) The SOC lacks enough analysts on the night shift to monitor the billing system closely
(C) The playbook format is outdated
(D) The SIEM retention is too short

42. An attacker may have access to corporate email during an active intrusion. The incident team plans to coordinate by email. What should the incident lead require?

(A) Encrypt all incident emails with the existing corporate certificates and continue as planned
(B) Pause the response until email is rebuilt
(C) Switch to a pre-agreed out-of-band communication channel
(D) Use public social media to coordinate

43. A bank has 60,000 open vulnerabilities and can fix 4,000 per month. Which prioritisation approach reduces the MOST real risk?

(A) Highest CVSS scores first, regardless of asset exposure or any evidence of exploitation
(B) Known-exploited and high-EPSS flaws on exposed and crown-jewel assets first
(C) Oldest vulnerabilities first
(D) Those easiest to patch first

44. An internet-facing VPN has a known-exploited flaw, but the vendor patch breaks MFA. What is the BEST action?

(A) Apply the patch immediately even though MFA will stop working for all remote users
(B) Accept the risk until next quarter
(C) Disable the VPN permanently
(D) Time-limited exception with source restrictions, monitoring and a virtual patch

45. A board asks for one measure of the organisation's resilience to credential-based attacks. Which KRI is BEST?

(A) Number of password resets processed by the service desk last quarter
(B) Number of security awareness emails sent
(C) Share of privileged accounts using phishing-resistant MFA
(D) Total number of user accounts

Copyright © ZyeemZia

Endure — Resilience, Continuity and Crisis Management

46. A payments company sets a 2-hour RTO for its wallet service. Its ledger database restores from nightly backups in 7 hours. What should the resilience lead do?

(A) Show the gap to the owner with options such as warm standby, or a formally accepted longer RTO

(B) Keep the 2-hour RTO in the plan, because it reflects what the business needs from the service

(C) Quietly change the RTO to 7 hours

(D) Ask the database team to work faster in an incident

47. A firm replicates its ERP in real time to a second data centre and believes it does not need backups. What is the main flaw?

(A) The second data centre may be too far away for real-time replication to keep up during busy periods

(B) Replication copies corruption and encryption to the second site

(C) Replication is too expensive

(D) Regulators ban replication

48. Ransomware groups often delete backups using stolen domain admin rights. Which design change BEST protects recovery?

(A) Running backups every hour instead of every night using the same domain administrator account

(B) Adding a third replicated site

(C) Renaming the backup server

(D) Immutable copies managed by separate, MFA-protected backup identities

49. A 40 TB file service restores at 4 TB per hour. Detection and decision usually take 3 hours and validation 2 hours. What is a realistic recovery time?

(A) About 10 hours

(B) About 5 hours

(C) About 15 hours

(D) About 40 hours

50. Three hours into a breach, the CEO wants to announce that 'no customer data was affected', but forensics has not confirmed this. What should the crisis team issue?

(A) The CEO's reassurance, because customers need confidence and the statement can be corrected later if needed

(B) A holding statement with known facts, customer advice and a time for the next update

(C) Nothing until the investigation finishes

(D) A statement blaming a named supplier

51. Which is the MOST appropriate time for a board to agree its position on ransom payments?

(A) In advance, with legal advice, decision rights and conditions documented

(B) During the incident, once the negotiators have assessed the attacker's reliability and demand

(C) After the incident, as part of the lessons-learned review

(D) Never; it should be left to the insurer

52. Three successive exercises at a hospital found that nobody could authorise clinical downtime procedures at night. What is the BEST corrective action?

(A) Record the same action in this year's report and repeat the full exercise in twelve months' time

(B) Stop exercises until the issue is fixed

(C) Let the CISO approve clinical downtime

(D) Assign the action to a named executive, report it to the risk committee and verify it in a short unannounced test

53. A regulator asks a bank to show it can stay within impact tolerance for payments under a severe but plausible scenario. Which evidence is STRONGEST?

(A) Results of a scenario test showing payments restored within tolerance, with lessons tracked

(B) A signed policy stating that the bank will always restore payments within its stated tolerance

(C) A list of DR products

(D) An ISO certificate for the data centre

Copyright © ZyeemZia

Lead — Regulation, Audit and Board Leadership

54. A Bangladeshi IT services firm with EU customers and an EU subsidiary detects an intrusion affecting an EU client service and possibly personal data. Which approach to notifications is BEST?

(A) Apply only Bangladeshi law, since the firm's head office and main data centre are both in Dhaka

(B) Use a prepared multi-regime notification matrix with legal counsel and start the earliest applicable clock

(C) Wait until data theft is confirmed by forensics

(D) Leave notification to the EU client

55. A bank's compliance team summarises Bangladesh's cyber law from a two-year-old training slide. What is the MAIN risk?

(A) Training slides are copyrighted and cannot be used by compliance teams under any circumstances

(B) Older laws are always stricter, so the bank will over-comply

(C) There is no risk if the slide was accurate at the time

(D) The law may have been replaced or amended since, so obligations could be wrong

56. Internal audit finds for the third consecutive year that network device changes lack approval. Which response BEST resolves the issue?

(A) Ask audit to use a smaller sample size next year so that the number of exceptions reported falls

(B) Accept the finding again due to workload

(C) Automate the change workflow with continuous monitoring and report progress to the audit committee

(D) Let security approve all network changes

57. An auditor confirms through a walkthrough that a backup procedure would meet the RPO if followed, but has not examined any actual backup records. What can be concluded?

(A) Design effectiveness only; operating effectiveness is untested

(B) The control is fully effective, because a walkthrough covers both its design and its operation

(C) The control is ineffective

(D) Operating effectiveness only

58. A CFO rejects a security budget because it exceeds peer spending ratios. The organisation's quantified tail risk is above board tolerance. What should the CISO present?

(A) A revised budget reduced to match the peer average, with a note that risk may increase as a result

(B) A risk-based case showing how options close the tolerance gap and at what cost

(C) A list of tools other companies have bought

(D) A warning that breaches are inevitable

59. A board learned of a major incident from the media. Which control would MOST directly prevent this recurring?

(A) A longer and more detailed quarterly board report covering all incidents of every severity level

(B) A new SIEM platform

(C) Pre-agreed escalation criteria and timelines for informing the board

(D) Mandatory security training for directors

60. A newly appointed CISO at a power utility finds no cyber risk appetite, a flat IT/OT network and regulator questions about critical infrastructure. What should the CISO do FIRST?

(A) Purchase an OT monitoring platform immediately so that the regulator can see visible progress

(B) Rewrite the security policy first

(C) Start ISO/IEC 27001 certification

(D) Engage business and engineering leaders on top risks and obligations, then agree governance foundations and a 90-day plan

Copyright © ZyeemZia

EXAM PREPARATION

Practice exam answers & explanations

1. A Boards need risk expressed against business services and appetite, with owners. Tool coverage, test reports and benchmarks are inputs, not a governance view of risk.

2. B The third line must stay independent of the controls it assures. Skills and regulatory claims are not the core issue.

3. D CSF profiles describe outcomes in plain language and support current-to-target planning. The other choices are useful but are either too technical or too broad for this purpose.

4. C The SoA must reflect the organisation's own risks and decisions. Copied assessments are a common audit failure; Annex A remains the comparison list.

5. A IG1 targets essential hygiene for organisations with limited resources and directly addresses common ransomware entry points. The others are larger, slower or unaffordable.

6. D A layered architecture keeps the policy stable and lets detailed standards change through their owners. Adding chapters or read receipts keeps the structural problem; copying standard text does not fit the organisation.

7. C The root cause is the wrong approver and no time limit. Re-reviewing, banning or moving the list does not change who accepts risk or for how long.

8. B A UCF removes duplicate testing while keeping every obligation covered. The other options either keep duplication or ignore obligations.

9. C Range compression puts very different losses in the same cell. Quantifying in money resolves it; adding levels or averaging hides the difference.

10. A Tolerances turn appetite into measurable limits and KRIs warn before they are breached. The other actions do not make appetite measurable.

11. D Risks outside appetite need acceptance at the level that set the appetite. Owner-level acceptance, delayed disclosure or insurance alone undermine governance.

12. B LEF = 20 × 0.05 = 1 event per year. LM = 4 + (0.25 × 8) = 6 crore. Expected loss = 1 × 6 = BDT 6 crore.

13. C A single number expresses false certainty. Calibration asks for honest ranges; replacing or excluding inputs loses knowledge.

14. B Tolerance was set on the tail, and the 95th percentile exceeds it. The mean does not answer the board's question.

15. D Controls often affect the same events, so combined savings are less than the sum. Simulating the combination gives the realistic figure.

16. A Patterns scale secure design and focus experts on deviations. Heavier process, late testing or self-approval weaken governance.

17. D Brokered per-application access with strong identity removes the broadest trust for the riskiest users. Product swaps, big-bang segmentation or waiting do not.

18. C Segmentation based on observed flows stops lateral movement without breaking operations. More antivirus, longer passwords or blocking the internet do not address spread.

19. B The failure was missing design and testing for authorisation. Personal promises, hosting moves or UI changes leave the process gap.

20. A In SaaS, customers keep responsibility for identities, access and how data is shared; the provider runs infrastructure and application.

21. B Preventive guardrails stop the risky configuration at source. Wider reports, annual training or provider monitoring leave the action possible.

22. D An industrial DMZ preserves the business need while removing direct IT-to-OT paths. PLCs rarely support IT agents; password changes do not remove the path; disconnection removes business value.

23. A Controlled, narrow access meets the need while limiting risk. Certifications do not restrict access; outright refusal can endanger support; annual reviews are too late.

24. C Retaining old access after a role change is a mover failure. The person did not leave, and passwords are unrelated.

25. C Context and focus enable real decisions. More volume, central IT approval or relying on audit remove ownership or worsen fatigue.

26. B Phishing-resistant methods bind authentication to the genuine site, so relayed codes are useless. Longer codes or SMS are still relayable; training helps but does not stop the technique.

27. D The causes were long-lived, over-privileged, unmanaged keys in code. Rotation, privacy settings or signatures leave those causes in place.

28. A Giving a safe, approved route with clear rules and monitoring meets the need and reduces leakage. Blanket bans drive workarounds; ignoring or asking for deletion does not control future risk.

29. D Long-lived signatures are a priority for post-quantum planning. Larger keys only delay the problem; stopping signing or waiting adds risk.

Copyright © ZyeemZia

30. B High-risk profiling and sharing needs a DPIA and lawful basis. Encryption alone, retrospective notice or IT approval do not meet privacy obligations.

31. A Tiering focuses effort on critical relationships. Shorter or more frequent uniform questionnaires, more staff or dropping assessment do not fix the misallocation.

32. C A hard gate in procurement stops data flowing before assessment. After-the-fact review, training or conduct clauses are weaker.

33. B Carved-out subservice organisations are not covered by the opinion, so they need their own assessment. Rejection or reissue are not appropriate responses.

34. A CUECs are customer responsibilities; failing them undermines the assurance. The report remains valid and changing supplier is unnecessary.

35. D SBOMs provide the inventory needed to answer quickly. Declarations, annual reviews or blocking websites do not reveal where components are used.

36. C Dependency confusion is prevented by controlling where packages resolve from and pinning versions.

37. A Stressed exit planning addresses sudden failure. Longer terms, liability caps or audits do not keep payments running.

38. B The firm must assess and contain its own exposure promptly. Waiting, terminating without assessment or premature statements increase risk.

39. C A hybrid model provides affordable 24x7 coverage while retaining context and authority. A five-person rota is unsustainable; office hours leave gaps; full outsourcing removes accountability.

40. D Tested results are the honest measure. Reporting paper coverage misleads; hiding results undermines governance; the platform is not shown to be the cause.

41. A Decision rights with deputies and criteria enable action out of hours. Staffing, formatting or retention do not resolve authority.

42. C If email is compromised, encryption with the same environment may not help. Out-of-band channels keep the response hidden from the attacker.

43. B Exploitation evidence combined with asset context targets what attackers use against what matters. CVSS alone, age or ease misdirect effort.

44. D Compensating controls reduce exposure until a working fix is available. Breaking MFA, long acceptance or permanent shutdown are worse trade-offs.

45. C Phishing-resistant MFA coverage for privileged accounts directly reflects exposure to credential attacks. The others are activity counts.

46. A Objectives must be achievable or consciously accepted. Keeping an impossible target, silent changes or hope are not governance.

47. B Replication mirrors destructive changes; isolated point-in-time copies are still needed.

48. D Separation and immutability break the attacker's path to deletion. Frequency, more replicas or renaming do not.

49. C 3 hours to detect and decide + 40 ÷ 4 = 10 hours of copying + 2 hours to validate ≈ 15 hours.

50. B Honest holding statements protect credibility. Unverified reassurance, silence or premature blame cause harm.

51. A Peacetime policy avoids rushed decisions and clarifies constraints. Leaving it to the insurer or to the moment is poor governance.

52. D Executive ownership and verification close the loop. Repeating the action, stopping exercises or giving clinical authority to the CISO are wrong.

53. A Tested evidence against the scenario demonstrates capability; statements, product lists or certificates do not.

54. B Several regimes may apply with different deadlines; a prepared matrix and counsel prevent missed obligations. The other options ignore applicable duties or delay.

55. D Bangladesh's cyber statutes changed several times in recent years; outdated summaries can misstate obligations.

56. C Fixing the process cause and adding monitoring closes the gap with evidence. Smaller samples hide it; acceptance or shifting work does not fix it.

57. A Walkthroughs test design. Operating effectiveness needs evidence that the control ran over the period.

58. B Linking investment to the board's own tolerance is the strongest justification; benchmarks are context only.

59. C Escalation criteria ensure the board hears promptly about material incidents. Longer reports, tools or training do not guarantee timely escalation.

60. D Foundations and urgent risk reduction with risk owners come first. Tools, policy rewrites or certification are later or narrower steps.

Copyright © ZyeemZia

ZyeemZia™

ZCSTG

Cyber Security – Technology and Governance

CERTIFICATE OF ACHIEVEMENT

This certifies that

_____

has successfully completed all modules of the ZyeemZia™ Cyber Security – Technology and Governance track and passed the ZCSTG certification exam

- Security governance & frameworks
- Cyber-risk quantification
- Zero-trust, cloud & OT architecture
- Third-party, resilience & compliance
- Board reporting & programme leadership

ISSUED _____

CREDENTIAL ID _____

Earn the official certificate online at zcstg.zyeemzia.com: complete every lesson and pass the official exam. Anyone can verify your credential ID at zcstg.zyeemzia.com/#verify. This page is for your printed record.

Copyright © ZyeemZia

NOTES

My notes

Copyright © ZyeemZia